

University Of Pune

Credit System

Cyber Security

Module-I

Prerequisites in information and network security:

Chapter 1: Overview of Networking Concepts

Communications

Systems

The topics within this unit are:

- Basics Of Communication System
- Transmission Media
- Topology and Types Of Networks
- TCP/IP Protocol Stack
- The Internet

1) Basics Of Communication System

Characteristics of communication systems.

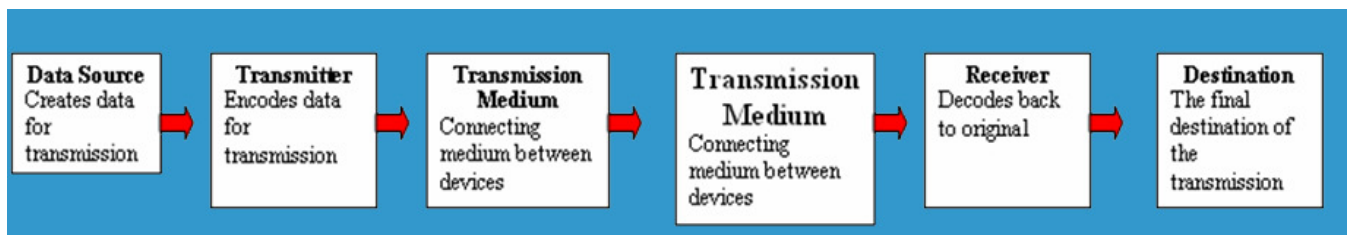
- must be a Sender and Receiver
- All communication systems include a message, a sender, a communication channel, and a receiver.
- A **communication channel** is the path over which a message must travel to get from the sender to the receiver
- Protocol - A protocol is a set of rules which governs the transfer of data between computers. Protocols allow communication between computers and networks.
- Handshaking is used to establish which protocols to use. Handshaking controls the flow of data between computers
- protocols will determine the speed of transmission, error checking method, size of bytes, and whether synchronous or asynchronous

- Examples : token ring, CSMA/CD, X.25, TCP/IP

5 Basic Components

Every communication system has 5 basic requirements

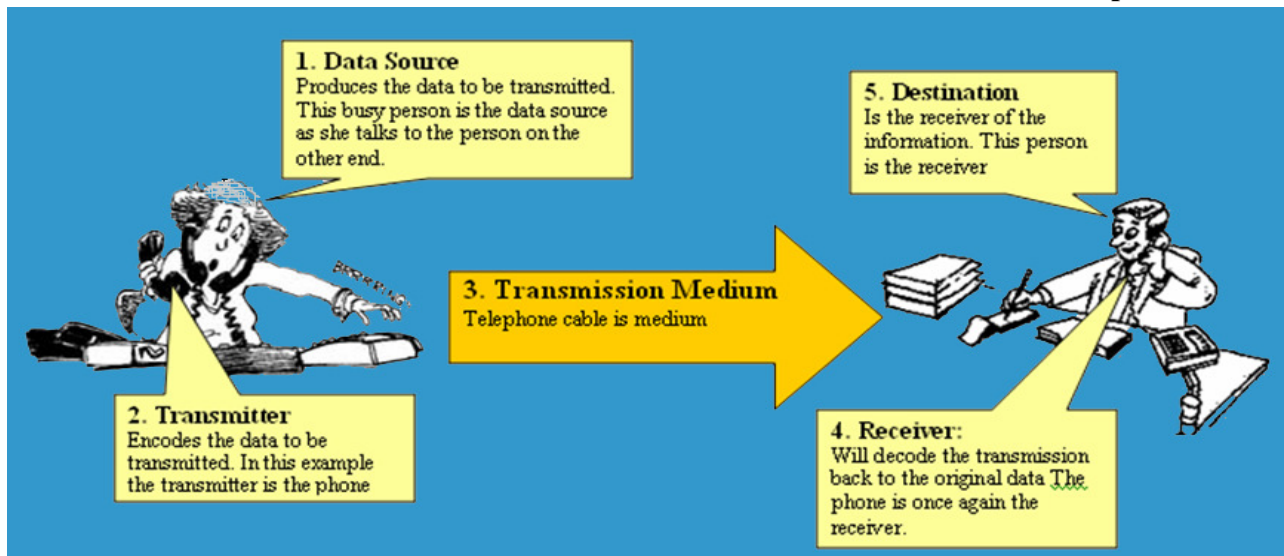
- **Data Source** (where the data originates)
- **Transmitter** (device used to transmit data)
- **Transmission Medium** (cables or non cable)
- **Receiver** (device used to receive data)
- **Destination** (where the data will be placed)



5

Basic

Components



Transmission media-

- **Bandwidth:** The amount of data which can be transmitted on a medium over a fixed amount of time (second). It is measured on Bits per Second or Baud

- **Bits per Second (bps):** A measure of transmission speed. The number of bits (0 or 1) which can be transmitted in a second
- **Baud Rate:** Is a measure of how fast a change of state occurs (i.e. a change from 0 to 1)

Packets - Transmissions are broken up into smaller units or data transmissions called packets

Example - A data file is divided into packets.

It does not matter what the transmission is. It could be Word

document, a PowerPoint or an MP3. Imagine this Green box

is a file for transfer

Network:

A network is set of device which are connected by communication links may be computer, print, any device

Computer Network:

Collection of autonomous computers inter connected by communication line or channels so they exchange information.

Goals:

Resource sharing, provide high reliability, distribution of work, saving memory, power full communication medium, protecting information, preserving information.

Application of communication network:

Business, home application, mobile users.

Transmission Technology:

1.Point-To-Point=Dedicated link between two devices link may be physical cable, microwave, satellite link used for large network.

2.Broadcast: Packets are broadcasted single communication channel, shared by all machines (small networks).

Classification Of Networks:

Inter Processor distance is used for classification of networks

PAN: -Personal Area Network

1M square meter

LAN : Local Area Network

10M Room

100M Building

1KM Campus

10KM: City Metropolitan Area Network

100KM : Country Wide area network

1000KM : Continent

10000KM :Planet The Internet

Examples of Communication Systems

- E-mail
- Voice Mail
- Smart Phone
- Telecommuting
- Groupware
- E-Commerce
- Bulletin board system
- global positioning system
- Fax
- instant Messaging
- Video-conferencing
- Telephony
- The Internet
- The Web

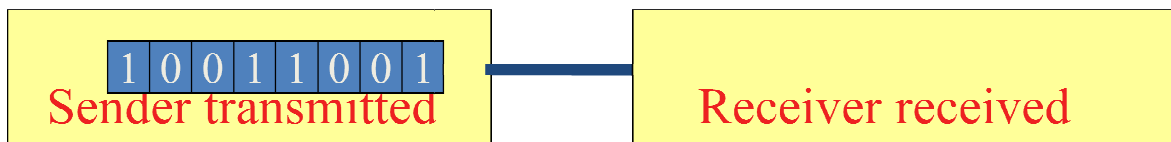
Communication Concepts –

Any transmission May be:

- analog or digital
- Serial or parallel

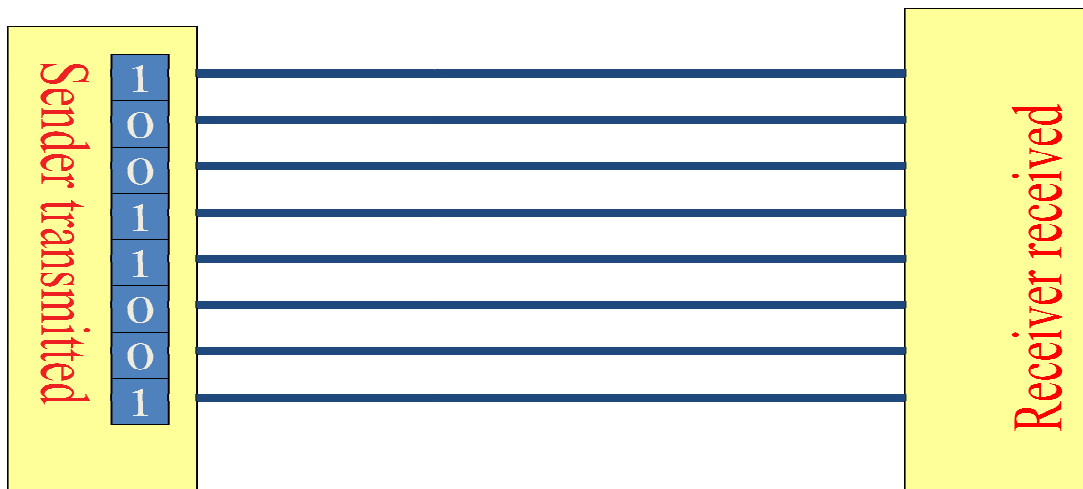
1)Serial Transmission –Data is transmitted, on a single channel, one bit at a time one after another

- Much faster than parallel because of way bits processed (e.g. USB and SATA drives)



2)Parallel Transmission

- each bit has it's own piece of wire along which it travels- often used to send data to a printer



All bits are sent simultaneously

Transmission media :

Transmission media is a pathway that carries the [information](#) from sender to receiver. We use different types of cables or waves to transmit data. Data is transmitted normally through electrical or electromagnetic signals.

An electrical signal is in the form of current. An electromagnetic signal is series of electromagnetic energy pulses at various frequencies. These signals can be transmitted through copper wires, optical fibers, atmosphere, water and vacuum. Different Media have different properties like bandwidth, delay, cost and ease of installation and maintenance. Transmission media is also called **Communication channel**.

Types of Transmission Media

Transmission media is broadly classified into two groups.

1. Wired or Guided Media or Bound Transmission Media
2. Wireless or Unguided Media or Unbound Transmission Media

1) Wired or Guided Media or Bound Transmission Media: [Bound transmission media](#) are the cables that are tangible or have physical existence and are limited by the physical

geography. Popular [bound transmission media](#) in use are twisted pair cable, co-axial cable and fiber optical cable. Each of them has its own characteristics like transmission speed, effect of noise, physical appearance, cost etc.

a) A **Twisted Pair** is a pair of copper wires, with diameters of 0.4-0.8 mm, twisted together and wrapped with a plastic coating. The twisting increases the electrical noise immunity, and reduces the bit error rate (BER) of the data transmission. A UTP cable contains from 2 to 4200 twisted pairs.

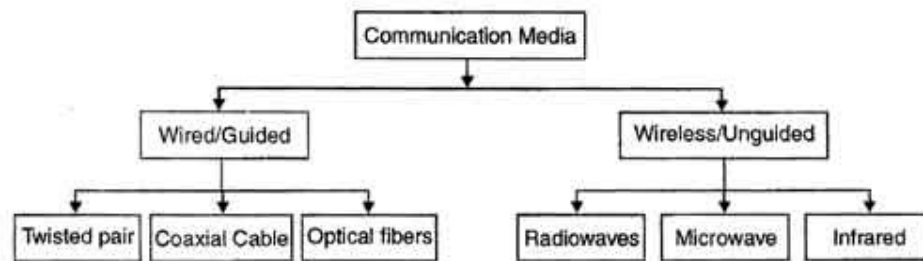
b) **Coaxial Cable:** Coaxial cable is a two-conductor cable in which one conductor forms an electromagnetic shield around the other. The two conductors are separated by insulation. It is a constant impedance transmission cable. This media is used in base band and broadband transmission. Coaxial cables do not produce external electric and magnetic fields and are not affected by them. This makes them ideally suited, although more expensive, for transmitting signals.

c) **Optical Fiber :** Optical fiber consists of thin glass fibers that can carry [information](#) at frequencies in the visible light spectrum and beyond. The typical optical fiber consists of a very narrow strand of glass called the core. Around the core is a concentric layer of glass called the cladding.

1) **Wireless or Unguided Media or Unbound Transmission Media:** Unbound transmission media are the ways of transmitting data without using any cables. These media are not bounded by physical geography. This type of transmission is called **Wireless communication**. Nowadays wireless communication is becoming popular. Wireless LANs are being installed in office and college campuses. This transmission uses Microwave, Radio wave, Infra red are some of popular unbound transmission media.

a) **Radio Frequencies :** The frequency spectrum operates from 0 Hz (DC) to gamma rays (10¹⁹ Hz). Radio frequencies are in the range of 300 kHz to 10 GHz. We are seeing an emerging technology called wireless LANs. Some use radio frequencies to connect the workstations together, some use infrared technology.

- b) Microwave :** Microwave transmission is line of sight transmission. The transmit station must be in visible contact with the receive station. This sets a limit on the distance between stations depending on the local geography. Typically the line of sight due to the Earth's curvature is only 50 km to the horizon! Repeater stations must be placed so the data signal can hop, skip and jump across the country.
- c) Satellite :** Satellites are transponders (units that receive on one frequency and retransmit on another) that are set in geostationary orbits directly over the equator. These geostationary orbits are 36,000 km from the Earth's surface. At this point, the gravitational pull of the Earth and the centrifugal force of Earth's rotation are balanced and cancel each other out. Centrifugal force is the rotational force placed on the satellite that wants to fling it out into space.



UTP is a very flexible, low cost media, and can be used for either voice or data communications. Its greatest disadvantage is the limited bandwidth, which restricts long distance transmission with low error rates.

The data transmission capabilities of various Medias vary differently depending upon the various factors. These factors are:

1. **Bandwidth.** It refers to the data carrying capacity of a channel or medium. Higher bandwidth communication channels support higher data rates.
2. **Radiation.** It refers to the leakage of signal from the medium due to undesirable electrical characteristics of the medium.
3. **Noise Absorption.** It refers to the susceptibility of the media to external electrical noise that can cause distortion of data signal.
4. **Attenuation.** It refers to loss of energy as signal propagates outwards. The amount of energy lost depends on frequency. Radiations and physical characteristics of media contribute to attenuation.

Transmission Media

In Network to connect a communicate computer you need transmission media.

Cable Transmission Media :

- 1) **Twisted Pair Cable :-**Two copper wires are twisted round each other(like wires used in home)

UTP(Unshielded Twisted Pair) cable :-

UTP cables does not have the covering of copper very cheap to connect their cable to the hub & pc,R5-45 conector connected to both ends.

STP –shielded wisted pair cable(STP): covered with copper costly and used to connect cables.

- 2) **Coaxial cable :-** coaxial cable is made up of two conductors .Both the cables are around the common axis. A pastic coated wire is present at the center of coaxial cable. There is a coating of cylindrical conductor like and over the plastic coating & it is covered with though plastic. This cable is useful for preventing from electrical & electromagnetic fields.

Two Types:

- 1) Thick Ethernet Cable
- 2) Thine Ethernet Cable
- 3) **Fiber Optic Cable :** Fiber optic cable is made up of glass or plastic tube.The glass tube is covering on this plastic tube is called as cladding. Outermost cover is of hard sheet. Thin glass fiber carry information frequency in the visible light spectrum or beyond that very fast.

Wireless Media :-

- Electrical/optical conductor not used to send signals.
 - It uses Electro magnetic waves as transmission media.
- 1) **Radio Waves :-**
 - Coves long distance.
 - travels in any direction
 - do not have to care about physical alignments of transmitter and reciver
 - available in range 300KHz to 10GHz frequency
 - radio waves communications affected by range ,sound, opstaclas like buildings etc.
 - Used in arm forces ,police department
 - 2)Microwave Comunicaton:

- Used for long distance up to 50KM
- After 50KM need repeaters towers
- Used in data communication in computer networks
- Transmission station must be in visible contact of receiving station.

3)Satelite Communication

- Satelite is artificial space scraft place in a orbit (36000KM)from each having transponders receive signal from earth station and send signals to earth from satellite dish antennas satellite station.
- Covers world wide area
- Micrwaves between 12GHz to 14GHz used.

Synchronous Transmission:

All data is send at once and no packet switching

Asynchronous Transmission:

Use start/stop bits
Serial data transfer
Allow packet switching
Sharing of bandwidth.

Simple Transmission:

One way transmission you can not communicate back
e.g. TV, Radio.

Half-Duplex:

Communication occurs in both direction but not at same time only one direction at a time.
e.g. fax

Full-Duplex:

Communication occurs in both direction at same time send as well as receives at once.
e.g. mobile phone, telephone

Switch:

Smart hubs which transmit packets to the destination port only

Bridge:

Connect two or more small networks.

Gateway:

Offen use to connect LAN with WAN(different network).

Hub:

In star topology Hub is used as central controlling device.

Router:

If more than two LANs are connected to each other than sends a data frame or packet to correct LAN routers are used.

Topology

A Network Topology is the way computer systems or network equipment connected to each other. Topologies may define both physical and logical aspect of the network. Both logical and physical topologies could be same or different in a same network.

Two or more computers connected together through communication media form a computer network. The arrangement of computers in a network is called **Network Topology**.

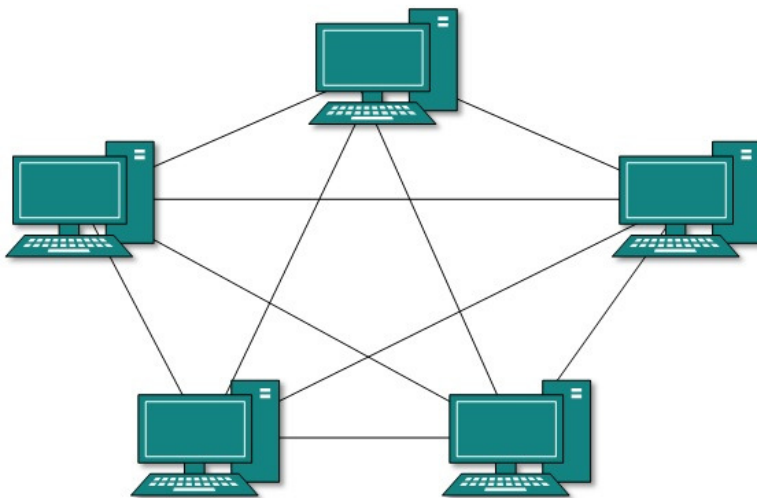
The physical topology of a network refers to the configuration of cables, computers, and other peripherals. Physical topology should not be confused with logical topology which is the method used to pass information between workstations.

Types of Network Topology

- 1) Mesh
- 2) Star
- 3) Bus
- 4) Ring
- 5) Tree
- 6) Hybride

1) Mesh Topology

In this type of topology, a host is connected to one or two or more than two hosts. This topology may have hosts having point-to-point connection to every other hosts or may also have hosts which are having point to point connection to few hosts only.



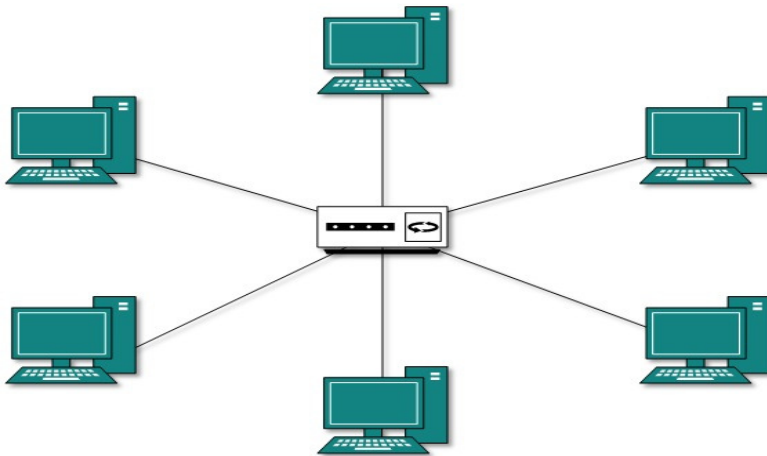
Hosts in Mesh topology also work as relay for other hosts which do not have direct point-to-point links. Mesh technology comes into two flavors:

- **Full Mesh:** All hosts have a point-to-point connection to every other host in the network. Thus for every new host $n(n-1)/2$ cables (connection) are required. It provides the most reliable network structure among all network topologies.

- **Partially Mesh:** Not all hosts have point-to-point connection to every other host. Hosts connect to each other in some arbitrary fashion. This topology exists where we need to provide reliability to some host whereas others are not as such necessary.
 - Fully interconnected topology every computer connected point to point link
 - If in network there is n device connected so total links are
 - $n(n-1)/2$
 - Puts direct communication between two devices,
- Advantages:**
- Delimitate traffic problem.
 - Some links may down till communication problem
 - Fault identification easy.
 - Maintain privacy.
 - Reliable and Security.
- Disadvantages:**
- More input output port required ,expensive.

2) Star Topology

All hosts in star topology are connected to a central device, known as Hub device, using a point-to-point connection. That is, there exists a point to point connection between hosts and Hub. The hub device can be Layer-1 device (Hub / repeater) or Layer-2 device (Switch / Bridge) or Layer-3 device (Router / Gateway).



As in bus topology, hub acts as single point of failure. If hub fails, connectivity of all hosts to all other hosts fails. Every communication happens between hosts, goes through Hub only. Star topology is not expensive as to connect one more host, only one cable is required and configuration is simple.

- Each device has dedicated point to point link to a central controller called hub.
- Two devices can not directly communicate.

Advantages:

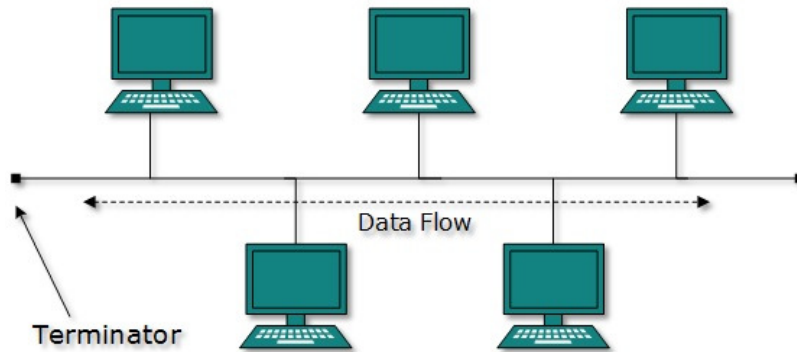
- Less I/O port
- easy to install.
- Fault identification easy.

Disadvantages:

Hub fails

3) Bus Topology

In contrast to point-to-point, in bus topology all devices share a single communication line or cable. All devices are connected to this shared line. Bus topology may have a problem while more than one host sends data at the same time. Therefore, the bus topology either uses CSMA/CD technology or recognizes one host as Bus Master to solve the issue. It is one of the simple forms of networking where a failure of a device does not affect the others. But failure of the shared communication line makes all other devices fail.



Both ends of the shared channel have line terminators. The data is sent in only one direction and as soon as it reaches the extreme end, the terminator removes the data from the line.

Multipoint technology devices in the network are linked by a single cable.

Advantages:

- Easy to install
- Less cable required

Disadvantage:

Signal travels on single line.

Different identify faults if single line breaks, communication stop

4) Ring Topology

In ring topology, each host machine connects to exactly two other machines, creating a circular network structure. When one host tries to communicate or send message to a host which is not adjacent to it, the data travels through all intermediate hosts. To connect one more host in the existing structure administrator may need only one more extra cable.

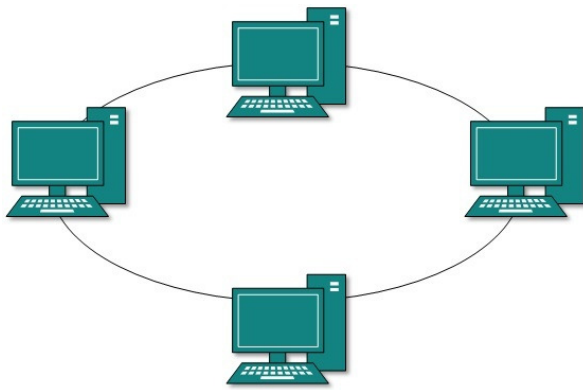


Image: Ring Topology

Failure of any host results in failure of the whole ring. Thus every connection in the ring is point of failure. There exists methods which employs one more backup ring.

In the ring topology two devices are connected by dedicated point to point link signals travels one direction along ring till it reaches its destination.

Advantages:

Easy to install and configure.

Fault finding is easy.

Tokens circulate on ring all the time

Disadvantage:

Break in ring results in disconnected communication

Data transfer is slow

5) Tree Topology

Also known as Hierarchical Topology is the most common form of network topology in use present day. This topology imitates an extended Star Topology and inherits properties of Bus topology.

This topology divides the network into multiple levels/layers of network. Mainly in LANs, a network is bifurcated into three types of network devices. The lowest most is access-layer where user's computer are attached. The middle layer is known as distribution layer, which works as a mediator between upper layer and lower layer. The highest most layer is known as Core layer, and is the central point of the network, i.e. root of the tree from which all nodes fork.

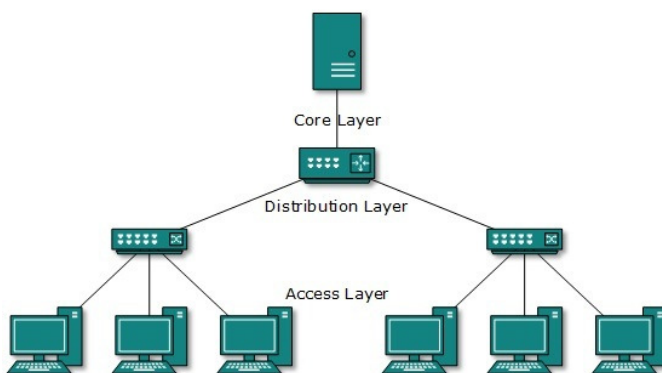


Image: Tree Topology

All neighboring hosts have point-to-point connection between them. Like bus topology, if the root goes down, the entire network suffers. Though it is not the single point of failure. Every connection serves as point of failure, failing of which divides the network into unreachable segment and so on.

Integrates star topology into linear bus topology

Advantages:

Expansion in pomibce.

6) Hybrid Topology

A network structure whose design contains more than one topology is said to be Hybrid Topology. Hybrid topology inherits merits and demerits of all the incorporating topologies.

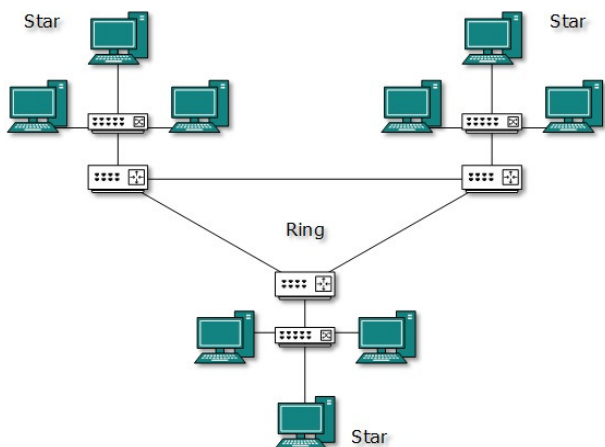


Image: Hybrid Topology

The above picture represents an arbitrarily Hybrid topology. The combining topologies may contain attributes of Star, Ring, Bus and Daisy-chain topologies. Most WANs are connected by means of dual Ring topology and networks connected to them are mostly Star topology networks.

Combination of two or more basic topology.(WANs)

Cellular Topology:

In cellular topology wireless point to point and multipoint links are combined to divided a geographic area into cells. Devices within a cell are communication with central cell station.

Cell station are interconnected to route data across network.

ISO/OSI MODEL

- After the file is divided into packets extra information is required to make sure it all goes back together correctly. The OSI model helps to look after this.
- The OSI model also provides much more information which is included with each package.

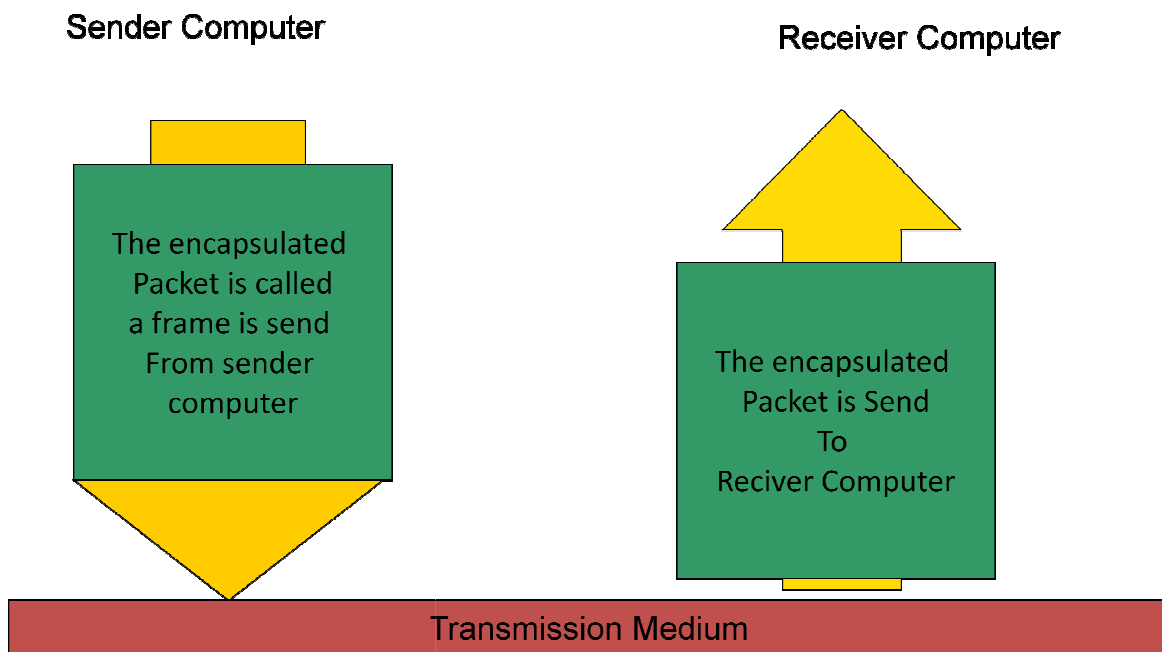
OSI 7 Layer Model

- OSI “Open System Interconnection”
- OSI is not a protocol but a list of protocols divided between 7 layers with each layer having a different set of functions.
- Each packet is layered/packaged with protocols from each of the layers as it is processed.
- The process of layering the protocols around each package is called encapsulation. The final encapsulated data packet is called a frame.

It is 7 layer Model

- Layer 7 application Layer
- Layer 6 presentation Layer
- Layer 5 session Layer
- Layer 4 transport Layer
- Layer 3 network Layer
- Layer 2 data link Layer
- Layer 1 physical Layer

OSI Reference model



To send file from sander to receiver computer Following steps are performed

- 1: File is broken into packets
- 2: at each layaaer packet is encapsulated with appropriate protocol
3. encapsulated packets is called frame .frames are send from sender to reciver
4. Packets are send on transmission media
- 5; At racier end packet is accepted and unpacked in apposite order to receive file

Services Performed at Each Layer

- Layer 7 application - Identification, authentication
- Layer 6 presentation - Format conversion
- Layer 5 session - Set-up coordinate conversation
- Layer 4 transport - Ensures error-free transfer
- Layer 3 network - Routing of data through network
- Layer 2 data link - Error control and synchronisation
- Layer 1 physical - Placing signals on the carrier

Examples of protocols USED IN ISO/OSI MODEL AT EACH LAYER

- Layer 7 application - E-mail, Web browser, Directory
- Layer 6 presentation - POP, SMTP, FTP, HTTP, DNS
- Layer 5 session - Sockets
- Layer 4 transport - TCP
- Layer 3 network - IP
- Layer 2 data link - PPP, Ethernet, Token ring
- Layer 1 physical - 100baseT

OSI Overview

4. Data Encapsulation

- a) PDU conception – each protocol on the diff. layer has its own format.
- b) Headers are added while a packet is going down the stack at each layer.
- c) Trailers are usually added on the second layer.

TCP/IP Stack

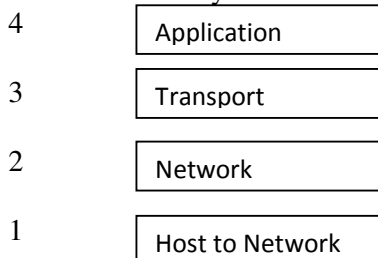
TCP/ IP Stack / TCP /IP Suit / Model

Internet: Internet is vast collection of interconnected and diverse networks. Even diverse networks (Heterogeneous H/W, S/W, Diff data they communicate with each other)

Due to TCP/IP protocol stack or suit

TCP/IP based on ARPANET model advanced Research Project Agency of US Dept (DOD) Dept of Defense

TCP /IP Model has 4 Layers



TCP/ IP Stack

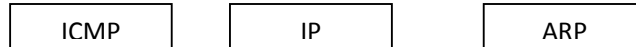
Application Layer



Host to Host Layer



Internet Layer



Host to Network Layer



4. Application Layer : Contains all protocols commonly used for user service

Email : SMTP

File Transfer : FTP

Remote Technical access : TELNET

Domain Name System : DNS

H access www : HTTP

3. Transport Layer : This layer is designed to allow communication between peer entities on the source and destination hosts.

1. TCP : (Transmission Control Protocol) ensures end to end error free delivery uses datagrams

2. UDP : (User Datagram Protocol) this is unreliable connectionless protocol used in C/S, request-reply application where prompt delivery is important.

2. Network (Internet) Layer : Its job is to transport (datagram) data packet from source machine to destination machine

Uses : IP (Internet Protocol) : It takes care of addressing and routing the datagram through internetwork. This protocol does not take responsibility for error-free delivery

Network Layer Protocols : IP : Internet Protocol

ICMP : Internet Control Message Protocol

ARP : Address Resolution protocol

DHCP : Dynamic Host Configuration Protocol

1. Host to Network Layer : This Layer supports any low-level communication Protocol (Physical / & Data Link Layer) Support corresponding physical and data link layer

Internet : Network of Networks

Used for – Sharing Resource Operation Supports Sharing Information
Communication

Need: ISP, Internet Connection, Modem Modulation & Demodulation

Internet Facility

Web Browser : To used internet with internet , we use client application program call Web Browse

IE – Microsoft Internet Explore

Firefox – Mozilla :

TC/IP becomes a standard

A standard for software

A standard for hardware

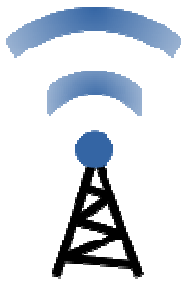
Four layers architecture

Each layer independent on the others

OSI	TCP / IP
Application (Layer 7)	Application
Presentation (Layer 6)	
Session (Layer 5)	
Transport (Layer 4)	Transport
Network (Layer 3)	Internet
Data Link (Layer 2)	Subnet
Physical (Layer 1)	

Wireless network

From Wikipedia, the free encyclopedia



A **wireless network** is any type of [computer network](#) that uses wireless data connections for connecting [network nodes](#).

Wireless networking is a method by which homes, [telecommunications networks](#) and enterprise (business) installations avoid the costly process of introducing cables into a building, or as a connection between various equipment locations.^[1] [Wireless](#) telecommunications networks are generally implemented and administered using [radio communication](#). This implementation takes place at the physical level (layer) of the [OSI model](#) network structure.^[2]

Examples of wireless networks include cell phone networks, Wi-Fi local networks and terrestrial microwave networks.

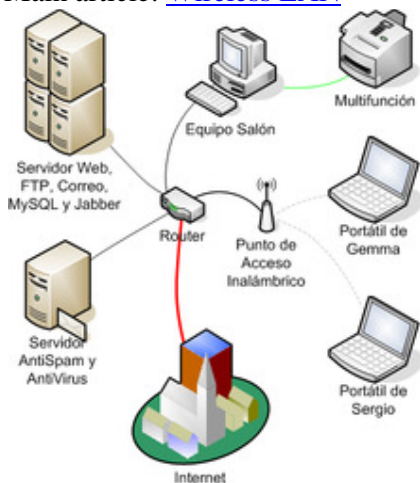
Types of wireless networks

Wireless PAN

Wireless [personal area networks](#) (WPANs) interconnect devices within a relatively small area, that is generally within a person's reach.^[3] For example, both [Bluetooth](#) radio and invisible [infrared](#) light provides a WPAN for interconnecting a headset to a laptop. [ZigBee](#) also supports WPAN applications.^[4] Wi-Fi PANs are becoming commonplace (2010) as equipment designers start to integrate Wi-Fi into a variety of consumer electronic devices. [Intel](#) "My WiFi" and [Windows 7](#) "virtual Wi-Fi" capabilities have made Wi-Fi PANs simpler and easier to set up and configure.^[5]

Wireless LAN

Main article: [Wireless LAN](#)



Wireless LANs are often used for connecting to local resources and to the Internet

A wireless local area network (WLAN) links two or more devices over a short distance using a wireless distribution method, usually providing a connection through an access point for [Internet access](#). The use of [spread-spectrum](#) or [OFDM](#) technologies may allow users to move around within a local coverage area, and still remain connected to the network.

Products using the [IEEE 802.11](#) WLAN standards are marketed under the [Wi-Fi](#) brand name. [Fixed wireless](#) technology implements [point-to-point](#) links between computers or networks at two distant locations, often using dedicated [microwave](#) or modulated [laser light](#) beams over [line of sight](#) paths. It is often used in cities to connect networks in two or more buildings without installing a wired link.....

Wireless mesh network

Main article: [wireless mesh network](#)

A wireless mesh network is a wireless network made up of radio nodes organized in a mesh topology. Each node forwards messages on behalf of the other nodes. Mesh networks can "self heal", automatically re-routing around a node that has lost power.

Wireless MAN

Wireless [metropolitan area networks](#) are a type of wireless network that connects several wireless LANs.

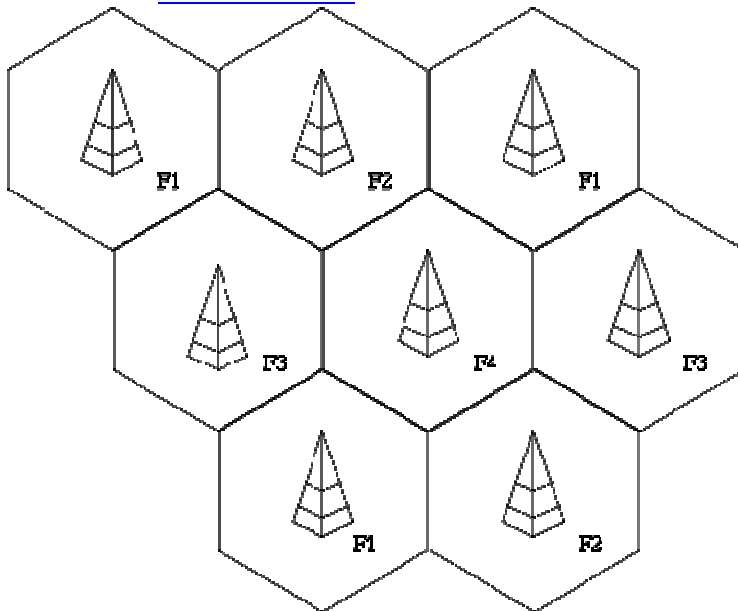
- [WiMAX](#) is a type of Wireless MAN and is described by the [IEEE 802.16](#) standard.^[6]

Wireless WAN

[Wireless wide area networks](#) are wireless networks that typically cover large areas, such as between neighboring towns and cities, or city and suburb. These networks can be used to connect branch offices of business or as a public internet access system. The wireless connections between access points are usually [point to point microwave links](#) using [parabolic dishes](#) on the 2.4 GHz band, rather than [omnidirectional antennas](#) used with smaller networks. A typical system contains base station gateways, access points and wireless bridging relays. Other configurations are mesh systems where each access point acts as a relay also. When combined with renewable energy systems such as photo-voltaic solar panels or wind systems they can be stand alone systems.

Cellular network

Main article: [cellular network](#)



Example of frequency reuse factor or pattern 1/4

A **cellular network** or **mobile network** is a radio network distributed over land areas called cells, each served by at least one fixed-location [transceiver](#), known as a [cell site](#) or [base station](#). In a cellular network, each cell characteristically uses a different set of radio frequencies from all their immediate neighbouring cells to avoid any interference.

When joined together these cells provide radio coverage over a wide geographic area. This enables a large number of portable transceivers (e.g., mobile phones, [pagers](#), etc.) to communicate with each other and with fixed transceivers and telephones anywhere in the network, via base stations, even if some of the transceivers are moving through more than one cell during transmission.

Although originally intended for cell phones, with the development of [smartphones](#), [cellular telephone networks](#) routinely carry data in addition to telephone conversations:

- [Global System for Mobile Communications](#) (GSM): The GSM network is divided into three major systems: the switching system, the base station system, and the operation and support system. The cell phone connects to the base system station which then connects to the operation and support station; it then connects to the switching station where the call is transferred to where it needs to go. GSM is the most common standard and is used for a majority of cell phones.^[7]
- [Personal Communications Service](#) (PCS): PCS is a radio band that can be used by mobile phones in North America and South Asia. Sprint happened to be the first service to set up a PCS.
- [D-AMPS](#): Digital Advanced Mobile Phone Service, an upgraded version of AMPS, is being phased out due to advancement in technology. The newer GSM networks are replacing the older system.

The Internet:: what is Internet? It is Network of networks

Internet used for : Sharing Resources

Sharing Information & used for communication

You Need : ISP 's Internet Connection , Modem & Machine (Computer) with any OS, Web Browser

Web browser : It is client application used to interact with Internet. Example : IE (Internet Explorer), Mozilla Firefox ect

Uses of Internet: email , web surfing ,downloading , Chatting, Newsgroup, social networking , Video Conferencing , ecommerce , things of internet ect.

Information searching : To download we search information first , for that we use search Eng. Examples of search eng. : Google search eng, Yahho search eng ect.

MCQ & descriptive Questions

1) Basic Components of Communication systems are _____

1: Data source 2: Transmitter 3: Transmission media 4: Receiver & Destination

a) 1 & 2 b) 1 & 3 c) 2 & 4 **d) 1,2, 3 & 4**

2) BIT means _____

a) Basic Intelligent Text **b) Binary Digit** c) Basic Text d) Binary Text

3) Example of serial port is _____

a) USB port b) Printer port

4) ISO/OSI model is _____ layer model.

a) 7 b) 5 c) 4 d) 3

5) TCP/IP model is _____ layer model.

a) 7 b) 5 **c) 4** d) 3

6) FTP protocol is used in _____ layer of ISO/OSI model.

a) application **b) presentation** c) network d) data link

7) Full form of B.P.S. is _____

a) Bits Per Second b) Bytes Per Second c) Bill Per Second d) Baud Per Second

8) In simplex transmission method data is transmitted in _____

a) one direction only b) bi-direction but one direction at a time c) bi-direction, simultaneous

d) no data is send

9) In computer network, fastest transmission media is _____

a) twisted-pair cable b) co-axial cable **c) fiber optic cable** d) radio waves

10) In TCP/IP, at application layer, protocol used is _____

a) SMTP b) TCP c) UPD d) IP

11) In TCP/IP, at transport layer, protocol used is _____

a) SMTP **b) TCP** c) UPD d) IP

12) In TCP/IP, at network layer, protocol used is _____

a) SMTP b) TCP c) UPD **d) IP**

13) Internet Explorer is a web browser used in _____ operating system.

a) Windows O.S. b) UNIX O.S. c) LINUX O.S. d) SUN SOLARACIS

14) Full form of MAN is _____

a) Metropolitan Area Network b) Municipal Area Network c) Man Area Network d)
Master Area Network

15) Area covered in PAN is _____

a) 1 meter b) 1 km. c) 10 km. d) 100 km.

Theory Questions:

1) What are the basic components of basic communication system?

2) What is a transmission media?

3) What are the types of transmission media?

4) What is a computer network topology?

5) Give only the names of different topologies?

6) What is a computer network? What are the types of different computer networks?

7) Write a short note on TCP/IP protocol stack.

8) What is a wireless network?

9) What is the internet?

10) What is a web browser? Give the names of web-browsers.

11) what is packet, hub, switch, gateway?

=====

Model-1

Chapter-2: Information Security Concepts

Network Security Types of attacks

-  Security is a fundamental component of every network design. When planning, building, and operating a network, you should understand the importance of a strong security policy.

Network Security

A security policy defines what people can and can't do with network components and resources.

Need for Network Security

In the past, hackers were highly skilled programmers who understood the details of computer communications and how to exploit vulnerabilities. Today almost anyone can become a hacker by downloading tools from the Internet. These complicated attack tools and generally open networks have generated an increased need for network security and dynamic security policies.

The easiest way to protect a network from an outside attack is to close it off completely from the outside world. A closed network provides connectivity only to trusted known parties and sites; a closed network does not allow a connection to public networks.

Because they have no Internet connectivity, networks designed in this way can be considered safe from Internet attacks. However, internal threats still exist.

There is a estimates that 60 to 80 percent of network misuse comes from inside the enterprise where the misuse has taken place.

With the development of large open networks, security threats have increased significantly in the past 20 years. Hackers have discovered more network vulnerabilities, and because you can now download applications that require little or no hacking knowledge to implement, applications intended for troubleshooting and maintaining and optimizing networks can, in the wrong hands, be used maliciously and pose severe threats.

An adversary

A person that is interested in attacking your network; his motivation can range from gathering or stealing information, creating a DoS, or just for the challenge of it

Types of attack:

Classes of attack might include passive monitoring of communications, active network attacks, close-in attacks, exploitation by insiders, and attacks through the service provider. Information systems and networks offer attractive targets and should be resistant to attack from the full range of threat agents, from hackers to nation-states. A system must be able to limit damage and recover rapidly when attacks occur.

There are five types of attack:

Passive Attack

A **passive attack** monitors unencrypted traffic and looks for clear-text passwords and sensitive information that can be used in other types of attacks. **Passive attacks** include traffic analysis, monitoring of unprotected communications, decrypting weakly encrypted traffic, and capturing

authentication information such as passwords. Passive interception of network operations enables adversaries to see upcoming actions. Passive attacks result in the disclosure of information or data files to an attacker without the consent or knowledge of the user.

Active Attack

In an **active attack**, the attacker tries to bypass or break into secured systems. This can be done through stealth, viruses, worms, or Trojan horses. Active attacks include attempts to circumvent or break protection features, to introduce malicious code, and to steal or modify information. These attacks are mounted against a network backbone, exploit information in transit, electronically penetrate an enclave, or attack an authorized remote user during an attempt to connect to an enclave. Active attacks result in the disclosure or dissemination of data files, DoS, or modification of data.

Distributed Attack

A **distributed attack** requires that the adversary introduce code, such as a Trojan horse or back-door program, to a “trusted” component or software that will later be distributed to many other companies and users. Distribution attacks focus on the malicious modification of hardware or software at the factory or during distribution. These attacks introduce malicious code such as a back door to a product to gain unauthorized access to information or to a system function at a later date.

Insider Attack

An **insider attack** involves someone from the inside, such as a disgruntled employee, attacking the network. Insider attacks can be malicious or non-malicious. Malicious insiders intentionally eavesdrop, steal, or damage information; use information in a fraudulent manner; or deny access to other authorized users. Non-malicious attacks typically result from carelessness, lack of knowledge, or intentional circumvention of security for such reasons as performing a task.

Close-in Attack

A **close-in attack** involves someone attempting to get physically close to network components, data, and systems in order to learn more about a network. Close-in attacks consist of regular individuals attaining close physical proximity to networks, systems, or facilities for the purpose of modifying, gathering, or denying access to information. Close physical proximity is achieved through surreptitious entry into the network, open access, or both.

One popular form of close-in attack is **social engineering**. In a social engineering attack, the attacker compromises the network or system through social interaction with a person, through an e-mail message or phone. Various tricks can be used by the individual to reveal information about the security of a company. The information that the victim reveals to the hacker would most likely be used in a subsequent attack to gain unauthorized access to a system or network.

Phishing Attack

In a phishing attack, the hacker creates a fake web site that looks exactly like a popular site such as the SBI bank or paypal. The phishing part of the attack is that the hacker then sends an e-mail message trying to trick the user into clicking a link that leads to the fake site. When the user attempts to log on with their account information, the hacker records the username and password and then tries that information on the real site.

Hijack attack

Hijack attack In a hijack attack, a hacker takes over a session between you and another individual and disconnects the other individual from the communication. You still believe that you are talking to the original party and may send private information to the hacker by accident.

Spoof attack

Spoof attack In a spoof attack, the hacker modifies the source address of the packets he or she is sending so that they appear to be coming from someone else. This may be an attempt to bypass your firewall rules.

Buffer overflow

Buffer overflow A buffer overflow attack is when the attacker sends more data to an application than is expected. A buffer overflow attack usually results in the attacker gaining administrative access to the system in a command prompt or shell.

Exploit attack

Exploit attack In this type of attack, the attacker knows of a security problem within an operating system or a piece of software and leverages that knowledge by exploiting the vulnerability.

Password attack

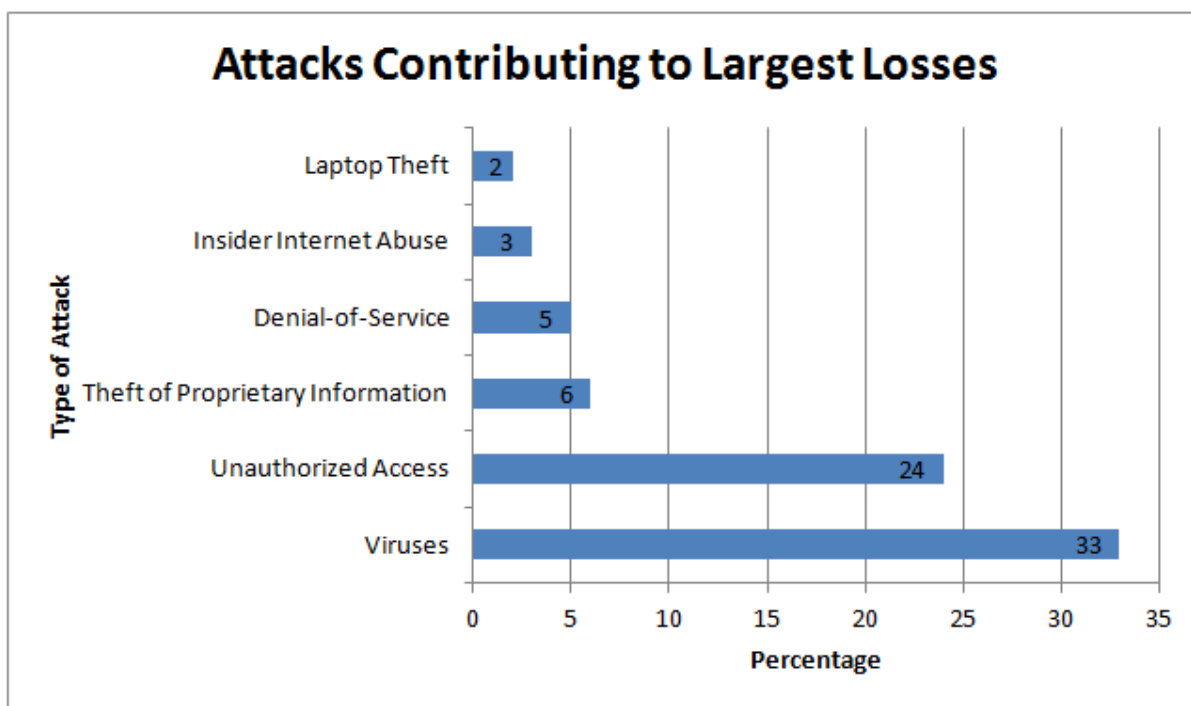
Password attack An attacker tries to crack the passwords stored in a network account database or a password-protected file. There are three major types of password attacks: a dictionary attack, a brute-force attack, and a hybrid attack. A dictionary attack uses a word list file, which is a list of potential passwords. A brute-force attack is when the attacker tries every possible combination of characters.

Types of Attacks

Because technology has no set form, there are many different avenues of attack that a victim can fall susceptible to. The types of attacks listed below are just a short sampling of the threats that exist. Though a simple computer virus may hold the record for the most commonplace attack, new attacks are bursting at the seams with creativity, keeping information security professionals on their toes.

Figure 1 portrays data found in the CSI/FBI 2005 Computer Crime and Security Survey in regards to the types of cyber attacks causing the greatest amount of losses. According to the survey, viruses are the number one attack to cause the most damage.

Figure 1: Attacks Contributing to Largest Losses



Data Source: "Current Cyber"

Malware

Simply defined, malware is any computer code that has a malicious intent. Malware is often used to destroy something on a computer or to steal private information. Odds are, nearly everyone with a computer has fallen victim to some form of malware in their time.

Viruses

As the name implies, **viruses** make a computer "sick". They infect a computer, just like a real virus that infects a person, and then they hide inside the depths of the computer. Viruses replicate themselves, and they survive by attaching to other programs or files. Though viruses are one of the oldest types of cyber attacks, they can be some of the craftiest. The capability of viruses has evolved, and they are often hard to spot and remove from a computer ("Current Cyber").

Spyware

Spyware is a form of malware that monitors or spies on its victims. It usually remains in hiding, but even so, it can log the various activities performed by a user. Spyware is capable of recording keystrokes (what a user types on the keyboard), which means that the attacker can view passwords that the victim enters into the computer. Spyware is also used to steal confidential information (Konklin 418).

Worms

Similar to viruses, **worms** replicate themselves many times to fulfill a nefarious purpose. However, worms differ from viruses in that they do not need to attach themselves to other files or programs. Worms are capable of surviving all by themselves, and not only do they replicate on a single computer host, but they can also replicate across an entire network of computers ("Current Cyber"). It is these features that can make a worm significantly more dangerous than a virus.

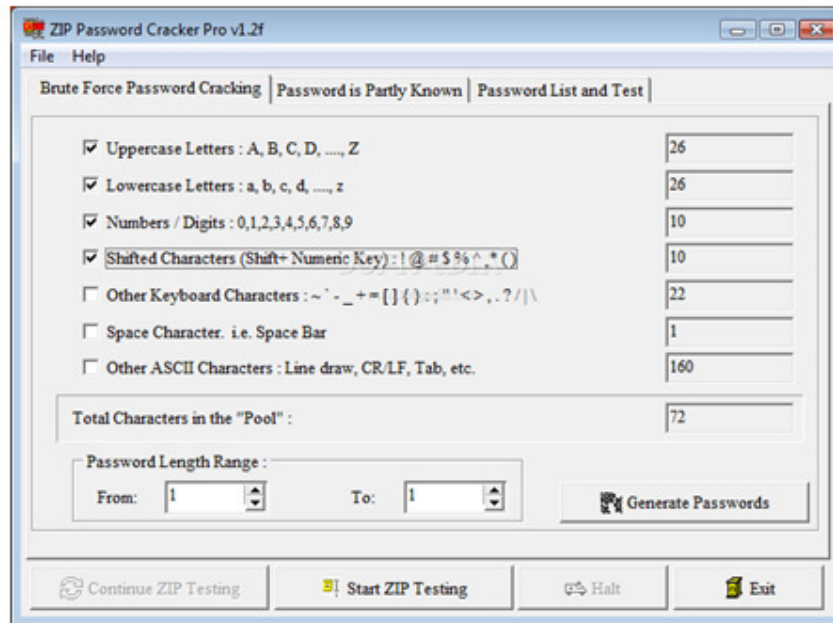
Password Attacks

These attacks are focused on cracking a victim's password so that the attacker may obtain access to a secured system. A username/password combination is typically the standard form of authentication on most systems. Though this type of account security is not necessarily weak by default, a user must follow good password procedures in order to stand a chance against a password attack (Konklin 412).

Brute-Force Attack

This type of attack is typically used as an end-all method to crack a difficult password. A **brute-force attack** is executed when an attacker tries to use all possible combinations of letters, numbers, and symbols to enter a correct password. Programs exist that help a hacker achieve this, such as Zip Password Cracker Pro, as seen in **Figure 2**. Any password can be cracked using the brute-force method, but it can take a very long time to finish. The longer and more intricate a password is, the longer it will take a computer to try all of the possible combinations (Konklin 413).

Figure 2: A Password Cracking Program



Source: *Zip Password*

Dictionary Attack

A **dictionary attack** takes place when an attacker utilizes a dictionary in an attempt to crack a password. Essentially, words from the dictionary are inputted into the password field to try to guess the password. Programs and tools exist that allow hackers to easily try various combinations of words in the dictionary against a user's password (Konklin 412). Because of the dictionary attack, it is recommended to use passwords that do not contain simple words that can be found in a dictionary.

Denial-of-Service Attacks

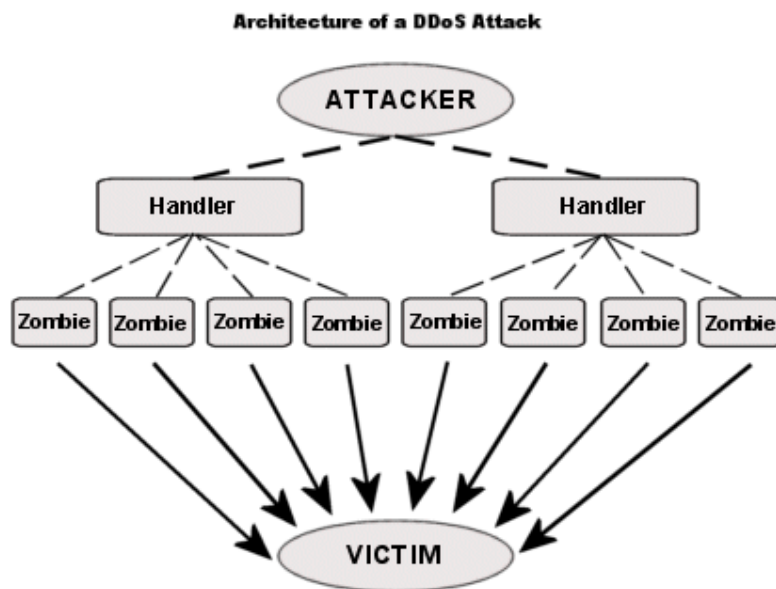
A **denial-of-service (DoS) attack** is a special form of cyber attack that focuses on the interruption of a network service. This is achieved when an attacker sends high volumes of traffic or data through the target network until the network becomes overloaded ("Denial-of-Service"). Think of a man juggling; he may be able to juggle quite well when using three or four balls, but if someone throws more balls into the fray and he tries to continue juggling with an increasing amount of balls, he may lose control and drop them all. This is essentially what happens when a network becomes overloaded.

Execution Methods

Typically, a DoS attack is carried out by one computer or one central location of computers. A popular sub-category of DoS attacks is **distributed denial-of-service (DDoS) attacks**. A DDoS attack varies from a regular DoS attack in that there are multiple computers involved.

The computers all work together by means of the Internet to send traffic to the target network ("Denial-of-Service"). **Figure 3** shows the basic construction of a DDoS attack, with a primary attacker accompanied by hijacked computers.

Figure 3: Architecture of a DDoS Attack



Source: *DDoSAttack*

Another term commonly associated with DoS attacks is "**botnet**". A botnet is a group of computers that an attacker has taken control of for nefarious purposes. Often, the true owner of a computer does not even realize that his/her computer has been compromised. The compromised computers can be referred to as "bots" or "zombies" because they are under an influence other than their own ("Denial-of-Service"). Using a botnet, an attacker has the computing power necessary to launch a

DDoS attack, making it easier to overpower a target network.

There are multiple ways to execute a DoS attack. Some of the different forms of execution include:

- **Teardrop** - sending irregularly shaped network data packets
- **Buffer Overflow** - flooding a server with an overwhelming amount data
- **Smurf** - tricking computers to reply to a fake request, causing much trafficz
- **Physical** - disrupting a physical connection, such as a cable or power source

The Physical execution method is important to take notice to because it can often be overlooked. An attacker does not necessarily have to use a computer to launch a DoS attack. A DoS attack can occur simply by cutting a physical cable at a network site ("Denial-of-Service"). That is why it is important to consider both physical security and cyber security.

It must also be accepted that a DoS attack can happen accidentally, perhaps by someone internally who was modifying the network configuration. As long as a network goes down, it is a form of denial-of-service.

History

DoS attacks first emerged in the late 1990s with the development of e-commerce, the buying and selling of products online ("Denial-of-Service"). Cyber criminals who wanted to bring down the e-commerce shopping websites used denial-of-service as their method of attack. By doing so, a shopping website could be unavailable to its customers for a lengthy amount of time. This not only upsets customers, but it also causes a loss in revenue and ability to function for the victim company.

In the early 2000s, the frequency of DoS attacks continued to increase. There was a three-week period in 2001 where over 13,000 DoS attacks were executed ("Denial-of-Service"). Keep in mind that these were only the ones that were reported; there are a plethora of attacks that companies wish not to report in order to protect their public image.

Specific Incidents

There are many recordings of DoS-related attacks, and it would be impossible to detail them all in this research. **Figure 4** provides a short variety of examples of specific incidents involving DoS attacks that were successful in interrupting network services.

Figure 4: Specific Incidents Involving DOS

Year	Victim	Attacker	Intent	Additional Info
2007	Estonia	Russia (assumed)	Threaten national security	Banks, media, and servers were greatly affected
2009	Twitter	Unknown hackers	Silence blogger Georgy Jakhaia, who speaks openly against Russian government	Facebook and LiveJournal were extremely slowed and almost lost service as well
2010	Master-Card	WikiLeaks	Punish Master-Card for not processing donations to WikiLeaks	Also took the Swedish prosecution authority offline due to a prior accusation

Data Source: "Denial-of-Service"

Goals for security

An information security policy documents executive management's direction on, and commitment to, information security. To be effective, you must communicate the security policy to everyone within your enterprise that handles your information or uses your systems.

An effective information security policy will...

- ☐ Include a statement of direction from executive management supporting the goals and principles of information security.
- ☐ Communicate the business risks associated with information security incidents and accidents.

- ☐ Document information security, responsibilities and the high-level principles personnel must observe.
- ☐ Specify key activities that must occur within the organization, such as carrying out security classifications and risk analyses, safeguarding important records and reporting suspected security weaknesses.
- ☐ Require information to be protected in terms of its requirements for availability, integrity and confidentiality.
- ☐ Emphasize the need for compliance with software licenses and other legal, regulatory and contractual obligations.
- ☐ Prohibit unauthorized or personal use of the organization's information and systems and the use of obscene, racist or otherwise offensive statements (for example, via e-mail or over the Internet).
- ☐ Document that disciplinary action will be taken against individuals who violate policy requirements.

Four goals of security

Mike Barwise

Most people who have gone beyond the mistaken assumption that anti-virus equals the totality of information security will have found that the market is full of niche products offering solutions to specific threats.

The majority of small- and medium-sized businesses and almost all home users find using such tools too expensive and complicated to implement, so a very high percentage of computer users remains seriously exposed.

But it is amazing what gains in security can be achieved virtually free of charge by simply tightening up on the way we manage our computer systems. The real basic goals of information security are

- Confidentiality
- Integrity
- Availability
- Non-repudiation. Accomplishing these is a management issue before it's a technical one, as they are essentially business objectives.

Confidentiality is about controlling access to files either in storage or in transit. This requires systems configuration or products (a technical job). But the critical definition of the parameters (who should be able to access what) is a business-related process.

Ensuring integrity is a matter of version control - making sure only the right people can change

documents. It also requires an audit trail of the changes, and a fallback position in case changes prove detrimental. This meshes with non-repudiation (the change record must include who as well as what and when).

Availability is the Cinderella of information security as it is rarely discussed. But however safe from hackers your information is, it is no use if you can't get at it when you need to. So you need to think about data back-ups, bandwidth and standby facilities, which many people still leave out of their security planning

4: E-commerce Security

What is e-commerce trading in products or services commercial transactions conducted electronically on the internet

Ecommerce allows consumers to electronically exchange goods and services with no barriers of time and distance.

Benefits of e-commerce include its round the clock availability the speed of access a wider selection of goods and wider accessibility and international reach

To ensure the security privacy and efficiency of e-commerce business should authenticate business transaction control access to resources such as WebPages for neither or selected users encrypt communications and implement security technologies such as the secure sockets layers .

There business transactions occur either business to business, business to customer, customer to customer or customer to business

B2B- Business to business or B2B refers to electronic commerce between business rather than between a business and a consumer.

B2B businesses often deal with hundreds or even thousands of other businesses either as customer or suppliers selling to distributors wholesalers selling to retailers

Business-to-Customer(B2C) – This is what most people think of when they hear e-commerce B2C Concepts of business selling to the general public through shopping cart software without needing any human interaction E.g. Amazon, flipcartetc.

Customer –to- Business (C2B) – In this scenario a consumer would post a project with a set budget online and companies bid on the project .The customer reviews the bid and selects the company. Eg. Enlace

Customer –to- Customer(C2C)- this type of e- commerce is made up of online carotids or forms cohune individuals can buy and sell their goods than too to system like PayPal on example of this would he e bay or etsy

Security features – While security features do not guarantee a secure system they are necessary to build a secure system.

Security feathers have four categories

1.Authentication- verifies who you say you are. It enforces that you are the only one allowed to logon to your internet banking account.

2.Authorization- allows only you to manipulate your resources in specific ways.

3.Encryption deals with information hiding. It ensure you cannot spy on others during Internet banking transactions.

4.Auditing – Keeps a record of operations. Merchants use auditing to prove that you bought a specific merchandise.

Computer Forensics

Overview

This paper will discuss the need for computer forensics to be practiced in an effective and legal way, outline basic technical issues, and point to references for further reading. It promotes the idea that the competent practice of computer forensics and awareness of applicable laws is essential for today's networked organizations.

This subject is important for managers who need to understand how computer forensics fits as a strategic element in overall organizational computer security. Network administrators and other computer security staff need to understand issues associated with computer forensics. Those who work in corporate governance, legal departments, or IT should find an overview of computer forensics in an organizational context useful.

What is Computer Forensics?

If you manage or administer information systems and networks, you should understand computer forensics. Forensics is the process of using scientific knowledge for collecting, analyzing, and presenting evidence to the courts. (The word *forensics* means “to bring to the court.”) Forensics deals primarily with the recovery and analysis of latent evidence. Latent evidence can take many forms, from fingerprints left on a window to DNA evidence recovered from blood stains to the files on a hard drive.

Because computer forensics is a new discipline, there is little standardization and consistency across the courts and industry. As a result, it is not yet recognized as a formal “scientific” discipline. *We define computer forensics as the discipline that combines elements of law and computer science to collect and analyze data from computer systems, networks, wireless communications, and storage devices in a way that is admissible as evidence in a court of law.*

Why is Computer Forensics Important?

Adding the ability to practice sound computer forensics will help you ensure the overall integrity and survivability of your network infrastructure. You can help your organization if you consider computer forensics as a new basic element in what is known as a “defense-in-depth”¹¹ “Defense in depth is designed on t

he principle that multiple layers of different types of protection from different vendors provide substantially better protection”

<<http://netsecurity.about.com/cs/generalsecurity/a/aa112103.htm>>.

approach to network and computer security. For instance, understanding the legal and technical aspects of computer forensics will help you capture vital information if your network is compromised and will help you prosecute the case if the intruder is caught.

Produced 2008 by US-CERT, a government organization. Updated 2008.

What happens if you ignore computer forensics or practice it badly? You risk destroying vital evidence or having forensic evidence ruled inadmissible in a court of law. Also, you or your organization may run afoul of new laws that mandate regulatory compliance and assign liability if certain types of data are not adequately protected. Recent legislation makes it possible to hold organizations liable in civil or criminal court if they fail to protect customer data.²

2 Laws such as the Health Insurance Portability and Accountability Act (HIPAA), Sarbanes-Oxley, California Act 1798, and others hold businesses liable for breaches in the security or integrity of computer networks.

Computer forensics is also important because it can save your organization money. Many managers are allocating a greater portion of their information technology budgets for computer and network security. International Data Corporation (IDC) reported that the market for intrusion-detection and vulnerability-assessment software will reach 1.45 billion dollars in 2006. In increasing numbers, organizations are deploying network security devices such as intrusion detection systems (IDS), firewalls, proxies, and the like, which all report on the security status of networks.

From a technical standpoint, the main goal of computer forensics is to identify, collect, preserve, and analyze data in a way that preserves the integrity of the evidence collected so it can be used effectively in a legal case.

What are some typical aspects of a computer forensics investigation? First, those who investigate computers have to understand the kind of potential evidence they are looking for in order to structure their search.³

3 For an overview of the types of crimes that involve a computer and how law enforcement aids investigation, see “How the FBI Investigates Computer Crime” at <
http://www.cert.org/tech_tips/FBI_investigates_crime.html
>.

Crimes involving a computer can range across the spectrum of criminal activity, from child pornography to theft of personal data to destruction of intellectual property. Second, the investigator must pick the appropriate tools to use. Files may have been deleted, damaged, or encrypted, and the investigator must be familiar with an array of methods and software to prevent further damage in the recovery process.

Two basic types of data are collected in computer forensics. *Persistent data* is the data that is stored on a local hard drive (or another medium) and is preserved when the computer is turned off. *Volatile data* is any data that is stored in memory, or exists in transit, that will be lost when the computer loses power or is turned off. Volatile data resides in registries, cache, and random access memory (RAM). Since volatile data is ephemeral, it is essential an investigator knows reliable ways to capture it.

System administrators and security personnel must also have a basic understanding of how routine computer and network administrative tasks can affect both the forensic process (the potential admissibility of evidence at court) and the subsequent ability to recover data that may be critical to the identification and analysis of a security incident.

Legal Aspects of Computer Forensics

Anyone overseeing network security must be aware of the legal implications of forensic activity. Security professionals need to consider their policy decisions and technical actions in the context of existing laws. For instance, you must have authorization before you monitor and collect information related to a computer intrusion. There are also legal ramifications to using security monitoring tools.

Computer forensics is a relatively new discipline to the courts and many of the existing laws used to prosecute computer-related crimes, legal precedents, and practices related to computer forensics are in a state of flux. New court rulings are issued that affect how computer forensics is applied. The best source of information in this area is the United States Department of Justice's Cyber Crime web site.⁴⁴ <http://www.cybercrime.gov>

The site lists recent court cases involving computer forensics and computer crime, and it has guides about how to introduce computer evidence in court and what standards apply. The important point for forensics investigators is that evidence must be collected in a way that is legally admissible in a court case.

Increasingly, laws are being passed that require organizations to safeguard the privacy of personal data. It is becoming necessary to prove that your organization is complying with computer security best practices. If there is an incident that affects critical data, for instance, the organization that has added a computer forensics capability to its arsenal will be able to show that it followed a sound security policy and potentially avoid lawsuits or regulatory audits.

There are three areas of law related to computer security that are important to know about. The first is found in the United States Constitution. The Fourth Amendment⁵⁵

A detailed analysis of issues surrounding the Fourth Amendment can be found on this web site:

<<http://caselaw.lp.findlaw.com/data/constitution/amendment04>
>.

allows for protection against unreasonable search and seizure, and the Fifth Amendment allows for protection against self-incrimination. Although the amendments were written before there were problems caused by people misusing computers, the principles in them apply to how computer forensics is practiced.

Second, anyone concerned with computer forensics must know how three U.S. Statutory laws⁶⁶

The text of these laws can be found at the U.S. Department of Justice web site <<http://www.usdoj.gov/criminal/cybercrime/cclaws.html>
>.

affect them:

- Wiretap Act (18 U.S.C. 2510-22)
- Pen Registers and Trap and Trace Devices Statute (18 U.S.C. 3121-27)
- Stored Wired and Electronic Communication Act (18 U.S.C. 2701-120)

Produced 2008 by US-CERT, a government organization. Updated 2008. 3

Violations of any one of these statutes during the practice of computer forensics could constitute a federal felony punishable by a fine and/or imprisonment. It is always advisable to consult your legal counsel if you are in doubt about the implications of any computer forensics action on behalf of your organization.

Third, the U.S. Federal rules of evidence about hearsay, authentication, reliability, and best evidence must be understood. In the U.S. there are two primary areas of legal governance affecting cyber security actions related to the collection of network data: (1) authority to monitor and collect the data and (2) the admissibility of the collection methods. Of the three areas above, the U.S. Constitution and U.S. Statutory Laws primarily govern the collection process, while the Federal Rules of Evidence deal mostly with admissibility.

If system administrators possess the technical skills and ability to preserve critical information related to a suspected security incident in a forensically sound manner and are aware of the legal issues related to forensics, they will be a great asset to their organization. Should an intrusion lead to a court case, the organization with computer forensics capability will be at a distinct advantage. For a more detailed discussion of these and related topics, see the document on which this paper is based, Nolan's *Forensics Guide to Incident Response for Technical Staff*, and other resources listed below.

An Introduction to Steganography & Its Uses

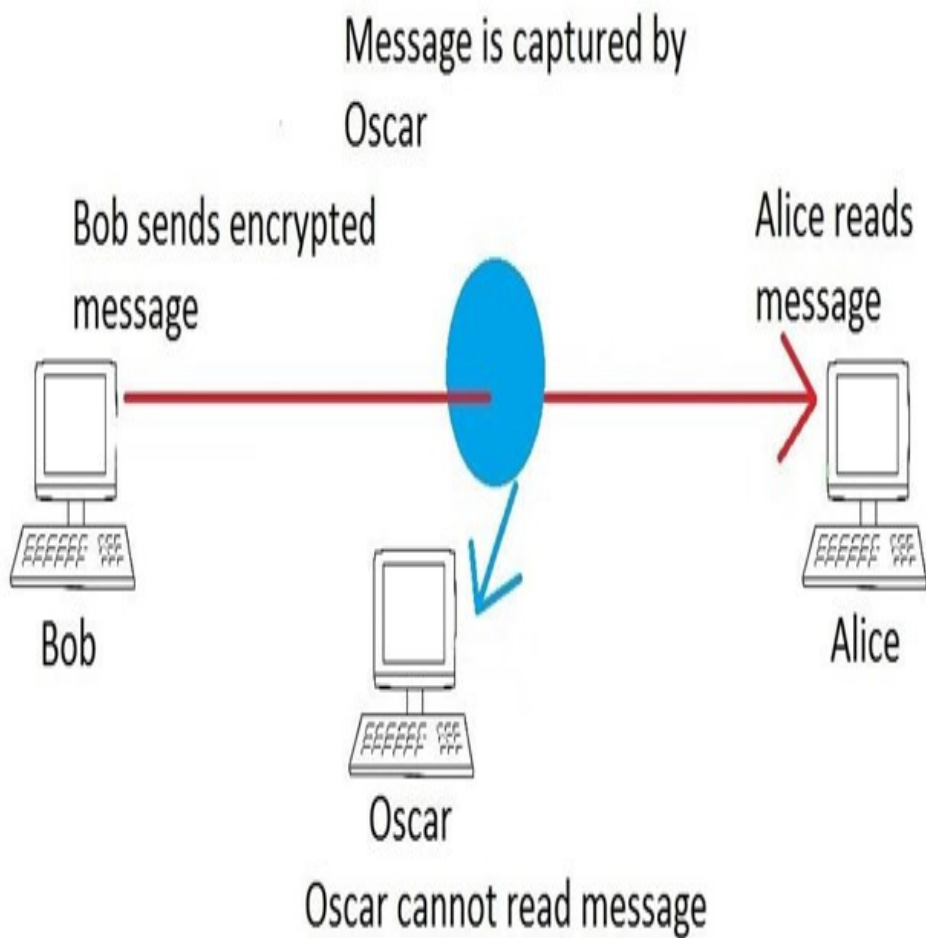
It has been a long while since I last came here to write an article. Graduate school keeps you busy. After I looked over what I had [written previously](#), I decided that I should introduce another fun topic from cryptography. In this case, steganography.

In this article, I will discuss what steganography is, why it is important, some theory involving steganography, and what it is used for.

What Is Steganography?

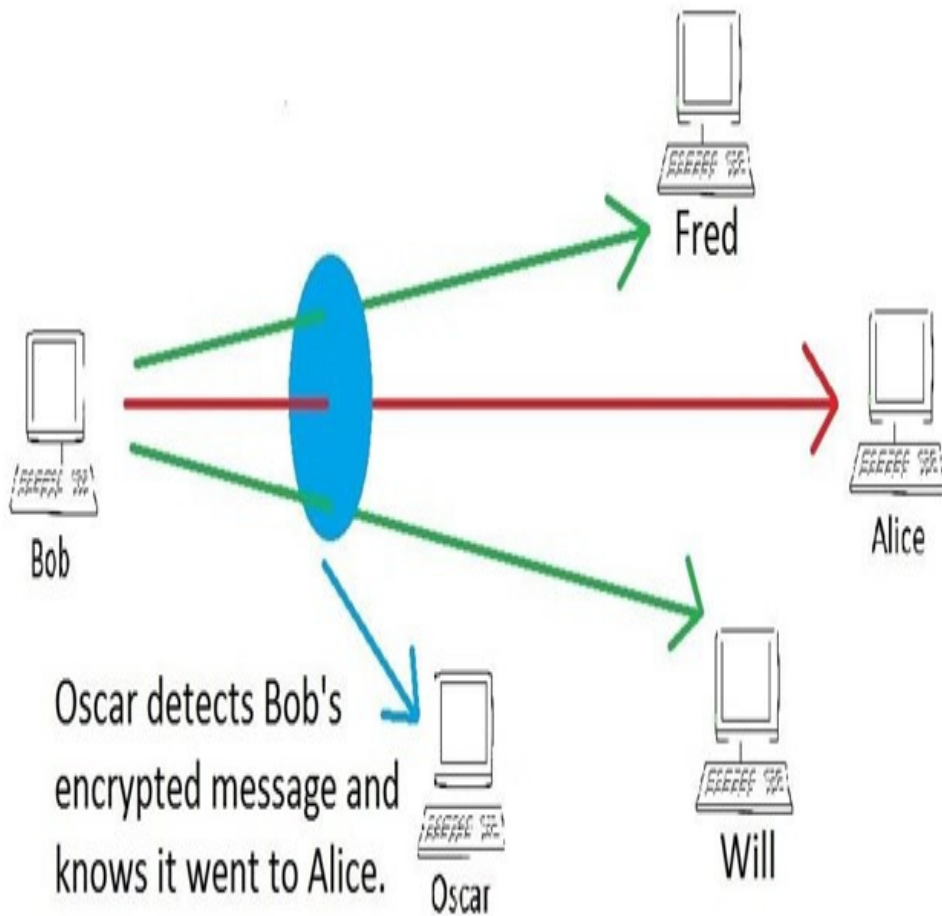
Steganography is the study of embedding and hiding messages in a medium called a *coverttext*. Steganography is related to cryptography and is just about as old. It was used by the Ancient Greeks to hide information about troop movements by tattooing the information on someone's head and then letting the person grow out their hair. Simply put, steganography is as old as dirt.

The basic idea behind cryptography is that you can keep a message a secret by encoding it so that no one can read it. If a good cryptographic cipher is used, it is likely that no one, not even a government entity, will be able to read it.

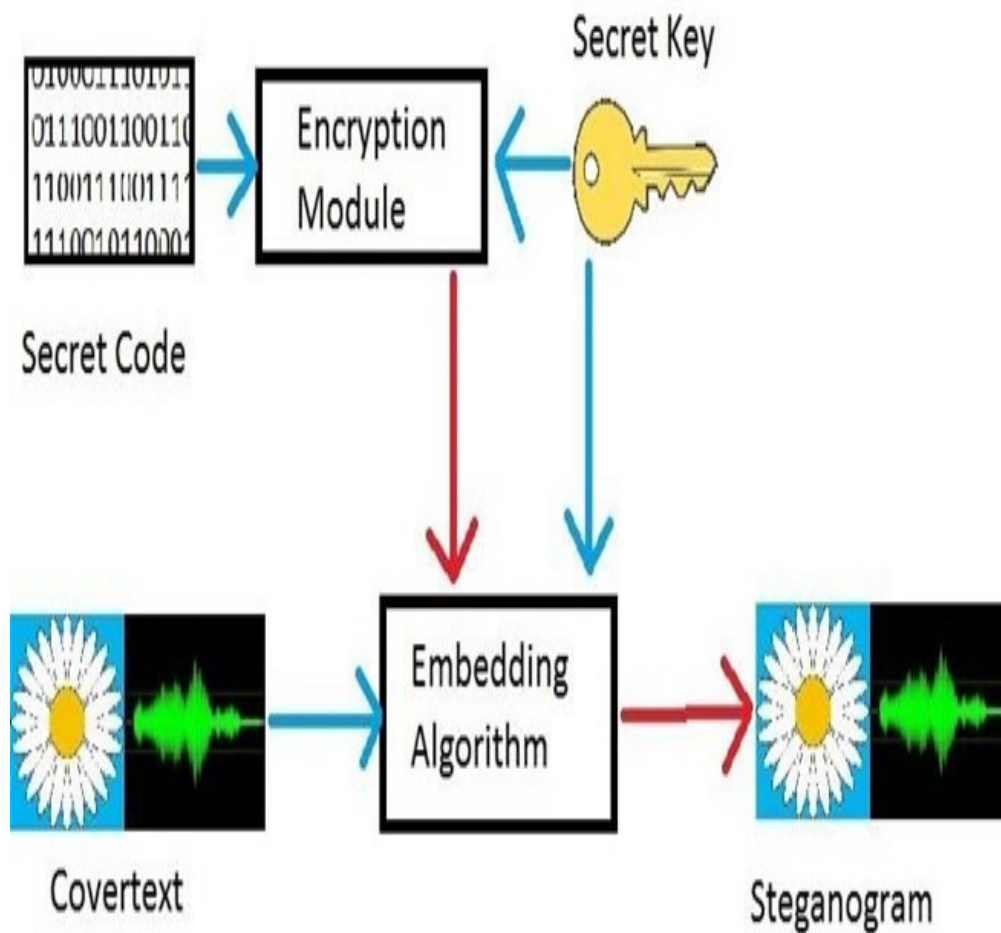


The picture above illustrates this point. However, sometimes merely communicating in secret can trip up alarms and make others suspicious. Therein lies the double edge of cryptography. While it may very well be unbreakable by all available standards, an encrypted message is easy to see and tag.

The simple fact is that an encrypted message does not resemble anything else but an encrypted message. Once a third party determines that you are communicating in secret, they may feel compelled to force you or the person you are communicating with to tell them what you are hiding.



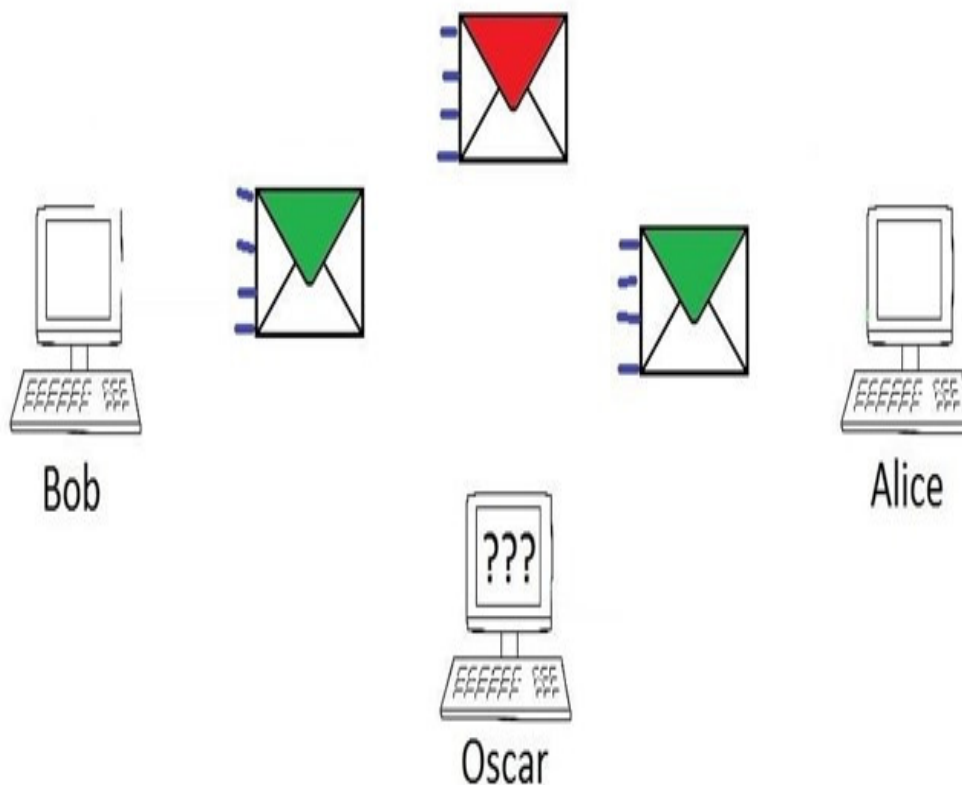
This is where steganography comes in. Unlike cryptography, the purpose of steganography is to hide a message. All steganography requires is a *covertext*, which is where data will be hidden, a *message* that is made up of data, an *algorithm* that decides how to hide the data, and frequently, a *key* that will be used to randomize the placement of the data and perhaps even encrypt it.



The above diagram depicts how a steganographic algorithm works during the embedding process. First the data that is being passed from one person to another is encrypted (not always, but this is highly suggested). Then the information is embedded into a covertex. This is done according to the embedding algorithm and a secret key that modulates the actions of the embedding process (the key is also not necessary, but highly suggested). This process outputs a steganogram that has the information hidden inside.

Security of a Steganographic Algorithm

Returning to the original problem, how do we know if we can communicate in secret? In this particular problem, what matters is not whether or not Oscar knows what we are saying. What constitutes a break is whether or not Oscar knows we are communicating in secret *at all*. Once he knows we are communicating in secret, he can take countermeasures such as rubber-hose cryptography or simply destroying the embedded data thus preventing us from communicating.



The problem ultimately reduces to whether or not Oscar can tell the difference between a normal message and an embedded message reliably. This is important to consider as Oscar does not have an infinite amount of manpower needed to interrogate everyone and widespread destruction of data in transit would grind information transfer to a halt.

So ultimately Oscar needs to be certain that he captures the largest number of offenders (or the largest chance to find one offender) while keeping the number of false alarms low.

This means that we can define a secure steganography algorithm. An algorithm is secure if Oscar cannot tell the difference between a normal message and a steganogram (computational indistinguishability). The research on this topic is rather new with most work on the topic being done in the last decade. I would suggest [this paper](#) if you wish to learn more on the topic of computational indistinguishability.

I am a big fan of practical definitions, so for this article, and any others I may write in the future, I will use this definition for secure system. *A steganographic system is secure if, and only if, the value to Oscar in detecting a given number of steganographic messages is exceeded by the costs associated with investigating them and the false alarms.*

This is a harder definition to imagine than my definition for [secure cryptography](#). For one, what is the value of finding a steganographic message? It is easy to put a price on much information traded

on the internet now, like credit card numbers or intellectual property, but it is harder to judge the value of knowing who is communicating with whom.

Nevertheless, this is still an intuitive definition because Oscar will not put the effort forward to uncover the identities of those who are communicating if it is not worth it.

Types of Steganography

The most commonly discussed steganography is embedded images. This is also the form that has the most research investigating it. While there are many types of algorithms, the three most common are LSB, DCT, and Append types. LSB stands for Least Significant Bit. It embeds data in the photo by replacing the least significant bit in a BMP type picture.

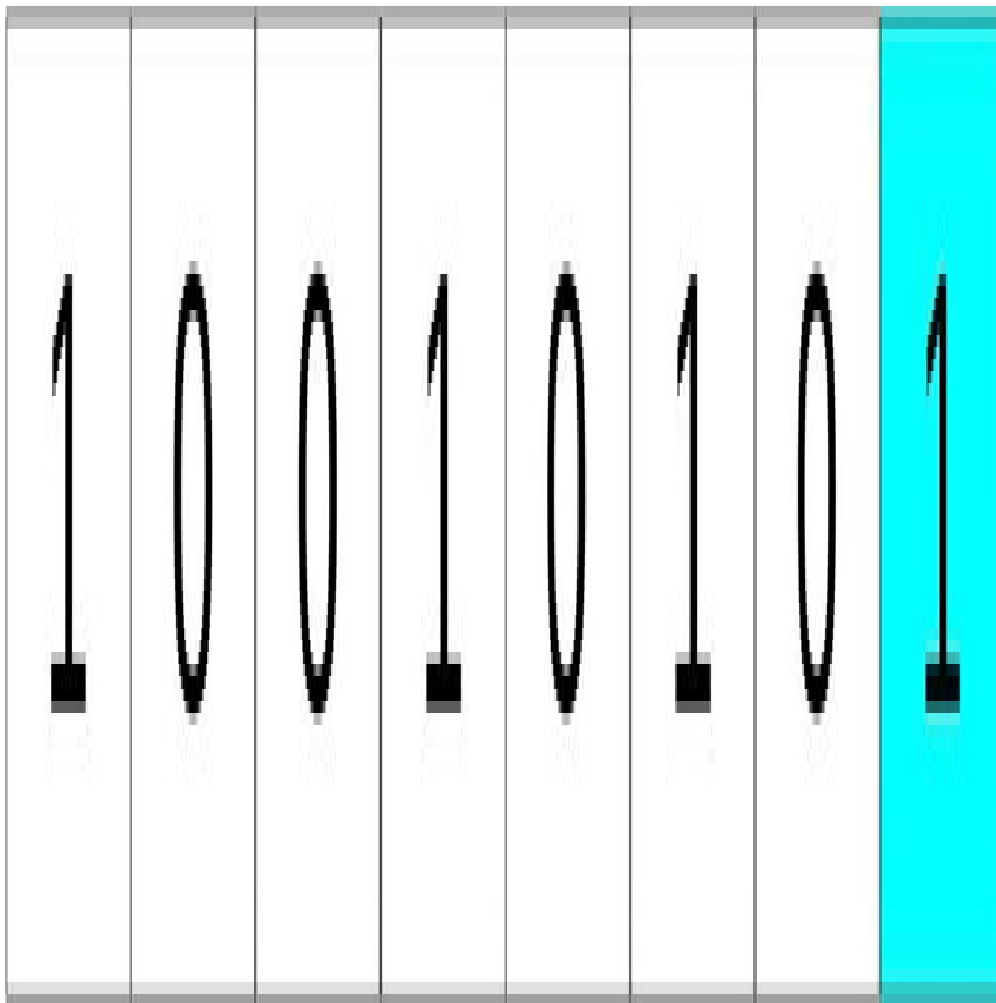


Image by Jimwilliams57/[Wikimedia Commons](#)

You can think of the least significant bit as the ones place. Because it has the smallest effect on the amount of a color, replacing this bit with a bit from the hidden data will have the smallest effect on the picture possible. The more bits replaced, the more bit "depth" available, and the larger the image, the more data that can be stored in the photo.

However, the more bits that are replaced, the more obvious the alterations will appear to both a statistical inspection and a visual inspection.

DCT stands for Discrete Cosine Transform. This works on many types of photo types. It works by calculating the "frequencies" of the image and then replacing some of them. DCT algorithms are more subtle in the way they manipulate photos and so are harder to detect. Note that larger transformations (due to more embedded data) will make the manipulations more obvious.

Just about the worst of these algorithms is the class of Append algorithms. Rather than hide the data in the photo by manipulating the picture, it instead appends the data to the end of the file as padding. In this manner, the data is hidden and never read by any photo displaying program. The good things about these algorithms are the simplicity of programming the algorithm and the fact that they are immune to visual inspection of the picture (the photos are identical so far as the photo is displayed).

However, these algorithms will change the size of the file. If the hidden data is large enough, the file size itself can be a dead giveaway. Further, the additional data appended to the end of the photo can be a dead giveaway to steganalysts looking for steganograms. If an Append algorithm must be used, definitely encrypt the data beforehand. If it is not encrypted first, a simple program that looks for text strings would be sufficient to find the files containing this data.

Now, while it is true that almost all research on this subject focuses on photos, there are algorithms that can hide data in sound files, executables, zip files, and even network communication. The last one is particularly interesting to those who desire to communicate secretly with ratted servers or even botnets.

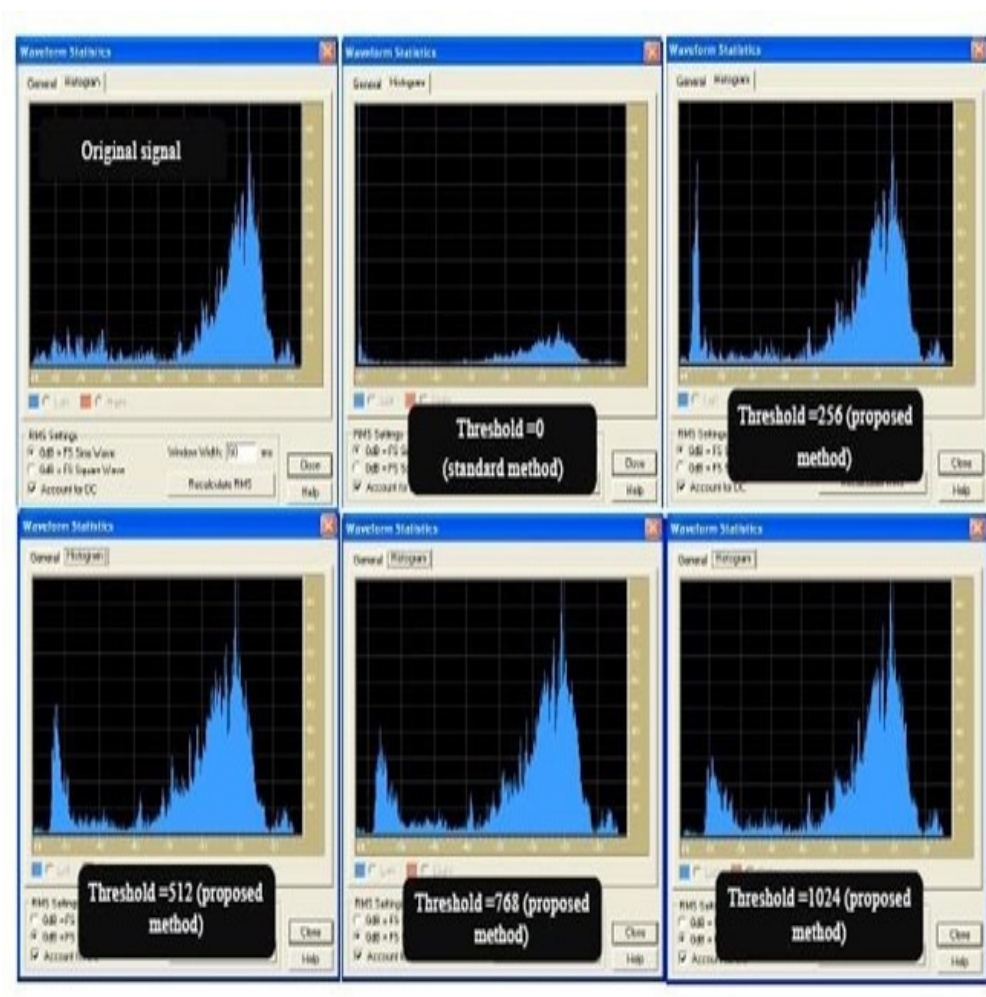


Image via [M. Ahmed, L. Mat Kiah, B.B. Zaidan, A.A. Zaidan](#)

Uses of Steganography

The uses of steganography are as varied as the uses of communication itself. Obviously you can use it to send secret messages to a friend, colleague, or co-conspirator. You can use it to transport sensitive data from point A to point B such that the transfer of the data is unknown.

As [this website](#) points out, it can also be used in network topologies. This is particularly useful for covert communication of botnets and other systems under a hackers control. It could also be used to further obfuscate the origination and endpoint of data because some procedural packets are simply very common, and frequently ignored. It can take a well trained malware analyst hours to weeks to find when and how a system was compromised from a packet dump. A well designed network steganographic program may be able to withstand greater tests of time.

MCQ & descriptive Questions

1. In computer security, means that computer system assets can be modified only by authorized parties.

- A) Confidentiality
- B) Integrity
- C) Availability
- D) Authenticity

Ans: B) Integrity

2. In computer security, means that the information in a computer system only be accessible for reading by authorized parties.

- A) Confidentiality
- B) Integrity
- C) Availability
- D) Authenticity

Ans:A) Confidentiality

3.The term e-commerce includes

- A) Electronic trading of Physical goods and intangibles such as information.
- B) The electronic provision of services such as after sales support or online legal advice
- C) All the steps involved in trade, such as on-line marketing ordering payment and support for delivery.
- D) All of the above.

Ans:D) All of the above.

4. Which of the following is the largest community in classification of e-commerce?

- A) Business to Business (B to B)
- B) Business to Consumer (B to C)

C) Business to Government (B to G)
 D) Government to Government (G to G)
 Ans: B) Business to Consumer (B to C)

5. Which of the following is not the example of business to consumer (B to C) e-commerce?

- A) Amazon.com
- B) e-bay.com
- C) dell.com
- D) lastminute.com

Ans: B) e-bay.com

6. Which of the following are the benefits of E-marketing?

- i) Speed ii) Reach and Penetration
- iii) Ease and Efficiency iv) Low Cost
- v) Targeted audience

- A) i, ii, iii and iv only
- B) ii, iii, iv and v only
- C) i, iii, iv and v only
- D) All i, ii, iii, iv and v

Ans: D) All i, ii, iii, iv and v

7. The types of Business to Business e-commerce are

- A) Direct selling and support to Business
- B) Industry portals
- C) Information sites about a industry
- D) All of the above

Ans: D) All of the above

8. Packet sniffers involve

- a) Active receiver
- b) Passive receiver
- c) Both of the mentioned
- d) None of the mentioned

Answer: b

Explanation: They do not inject packets into the channel.

- 9) Sniffers can be deployed in
a) Wired environment
b) WiFi
c) Ethernet LAN
d) All of the mentioned

Ans: b) WiFi

10. Which of the following are the solutions to network security?

- i) Encryption ii) Authentication
iii) Authorization iv) Non-repudiation
A) i, ii and iii only
B) ii, iii and iv only
C) i, iii and iv only
D) All i, ii, iii and iv

Ans:D) All i, ii, iii and iv

11. is to protect data and passwords.

- A) Encryption
B) Authentication
C) Authorization
D) Non-repudiation

Ans:A) Encryption

12. What is the solution for availability of data?

- A. Integrity
B. Encryption
C. Backup
D. None

Ans: C.Backup

13. Which method is used for Integrity of data?

- A. Encryption
B. Cryptography
C. Steganography
D.E-Commerce

Ans: B. Cryptography

14. The method is used for hiding information.

- A. Cryptography
- B. Steganography
- C. Integrity
- D. Confidentiality

Ans. B. Steganography

15. Computer forensics is also known as

- A. Cyber forensics
- B. E-commerce
- C. Cryptography
- D. Dictionary Attack

Ans: A. Cyber forensics

16. Dictionary attack is the type of attack.

- A. Passive
- B. Hijack
- C. Phishing
- D. Password

Ans.D. Password

17.Man-In-The-Middle Attack is the type of attack.

- A. Passive
- B. Active
- C. Password
- D. Phishing

Ans.B. Active

18..... is one of the goal for security.

- A. Encryption
- B. Backup
- C. Integrity
- D. Steganography

Ans.C. Integrity

=====

Module 1:

Chapter-3: Security Threats and Vulnerabilities

Contents:

1. Overview of Security threats
2. Weak / Strong Passwords and Password Cracking
3. Insecure Network connections
4. Malicious Code
5. Programming Bugs
6. Cyber crime and Cyber terrorism
7. Information Warfare and Surveillance

What is Threat?

A threat, in the context of computer security, refers to anything that has the potential to cause serious harm to a computer system. A threat is something that may or may not happen, but has the potential to cause serious damage. Threats can lead to attacks on computer systems, networks and more.

What is Vulnerability?

In computer security, vulnerability is a weakness which allows an attacker to reduce a system's information assurance. (i.e., insecure system)

Computer Threat:-

In computer security a **threat** is a possible danger that might exploit a vulnerability to breach security and thus cause possible harm.

A threat can be either "intentional" (i.e., intelligent; e.g., an individual cracker or a criminal organization) or "accidental" (e.g., the possibility of a computer malfunctioning, or the possibility of a natural disaster such as an earthquake, a fire, or a tornado) or otherwise a circumstance, capability, action, or event.

Here are many types of computer security threats in this world. Some are pretty harmful while some

are totally harmless although annoying. There are also some which does not do any damage to your computer, but has the capability to empty the numbers in your bank account.

The types of computer security threats:

1. Trojan. Trojan is one of the most complicated threats among all. Most of the popular banking threats come from the Trojan family such as Zeus and SpyEye. It has the ability to hide itself from antivirus detection and steal important banking data to compromise your bank account. If the Trojan is really powerful, it can take over your entire security system as well. As a result, a Trojan can cause many types of damage starting from your own computer to your online account.

2. Virus. Looking at the technology 10 years back, Virus is something really popular. It is a malicious program where it replicates itself and aim to only destroy a computer. The ultimate goal of a virus is to ensure that the victim's computer will never be able to operate properly or even at all. It is not so popular today because Malware today is designed to earn money over destruction. As a result, Virus is only available for people who want to use it for some sort of revenge purpose.

3. Worms. One of the most harmless threats where it is program designed only to spread. It does not alter your system to cause you to have a nightmare with your computer, but it can spread from one computer to another computer within a network or even the internet. The computer security risk here is, it will use up your computer hard disk space due to the replication and took up most of your bandwidth due to the spread.

4. Spyware. Is a Malware which is designed to spy on the victim's computer? If you are infected with it, probably your daily activity or certain activity will be spied by the spyware and it will find itself a way to contact the host of this malware. Mostly, the use of this spyware is to know what your daily activity is so that the attacker can make use of your information. Such as if you browse on sex toys for a week every day, the attacker will try to come out with a sex toy scam to cheat on your money.

5. Scareware. Scareware is something that plant into your system and immediately inform you that you have hundreds of infections which you don't have. The idea here is to trick you into purchasing a bogus anti-malware where it claims to remove those threats. It is all about cheating your money but the approach is a little different here because it scares you so that you will buy.

6. Keylogger. Something that keeps a record of every keystroke you made on your keyboard. Keylogger is a very powerful threat to steal people's login credential such as username and password. It is also usually a sub-function of a powerful Trojan.

7. Adware. Is a form of threat where your computer will start popping out a lot of advertisement. It can be from non-adult materials to adult materials because any ads will make the host some money. It is not really harmful threat but can be pretty annoying.

8. Phishing. A fake website which is designed to look almost like the actual website is a form of phishing attack. The idea of this attack is to trick the user into entering their username and password into the fake login form which serves the purpose of stealing the identity of the victim. Every form sent out from the phishing site will not go to the actual server, but the attacker controlled server.

9. Bluesnarfing. Bluesnarfing is all about having an unauthorized access to a specific mobile phones, laptop, or PDA via Bluetooth connection. By having such unauthorized access, personal

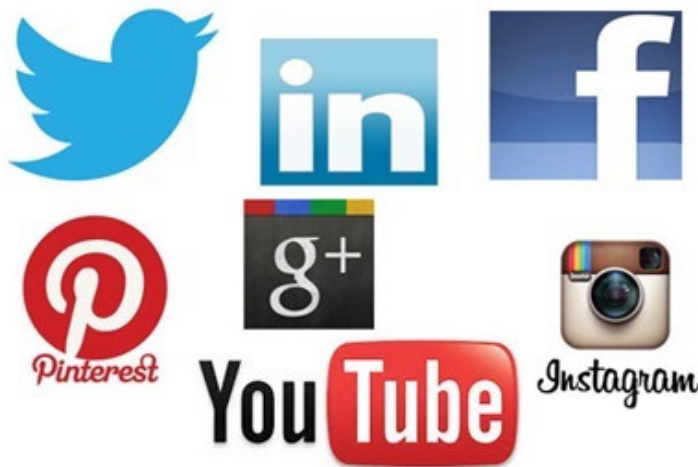
stuff such as photos, calendar, contacts and SMS will all be revealed and probably even stolen.

10. DDoS. One of the most famous thing done by Anonymous, which is to send millions of traffic to a single server to cause the system to down with certain security feature disable so that they can do their data stealing. This kind of trick which is to send a lot of traffic to a machine is known as Distributed Denial of Service, also known as DDoS.

11. Social Engineering: Tricking computer users into revealing computer security **or** private information, e.g. passwords, email addresses, etc, by exploiting the natural tendency of a person to trust and/or by exploiting a person's emotional response.

What is password?

A **password** is a word or string of characters used for user authentication to prove identity or access approval to gain access to a resource (example: an access code is a type of password), which should be kept secret from those not allowed access.



Why are passwords needed?

Passwords are used for *authentication*

Authentication can be thought of as the act of linking yourself to your electronic identity within the system you are connecting to

Your password is used to verify to the system that you are the legitimate owner of the user/account identifier

Commonly referred to as “logging in”

There are number of methods out their used by hackers to [hack](#) your account or get your personal information. Today in this post I will share with you guys 6 most commonly used method to crack password and their countermeasures. You must check out this article to be safe and to prevent your online accounts from hacking.

Weak password:-

Weak password are based on common dictionary words

Including dictionary words that have been altered:

- Reversed (e.g., “terces”)
- Mixed case (e.g., SeCreT)
- Character/Symbol replacement (e.g., “\$ecret”)
- Words with vowels removed (e.g., “scrt”)
- based on common names
- based on user/account identifier
- short (under 6 characters)
- based on keyboard patterns (e.g., “qwerty”)
- composed of single symbol type (e.g., all characters)

Strong password:-

-contain at least *one of each* of the following:

Digit (0...9)

Letter (a...Z)

Punctuation symbol (e.g.)

Control character (e.g., ^s, Ctrl-s)

-are based on a verse (e.g., passphrase) from an obscure work where

The password is formed from the characters in the verse

e.g., “ypyiy” derived from the title of this module

Sometimes referred to as a *virtual password*

-are easily remembered by you but very difficult (preferably impossible) for others to guess

Password cracking:-

Password cracking is the process of recovering passwords from data that have been stored in or transmitted by a computer system. A common approach (brute-force attack) is to repeatedly try guesses for the password.

Password Cracking Techniques:

1. Brute Force Attack



Any password can be cracked using Brute-force attack. Brute-force attacks try every possible combination of numbers, letters and special characters until the right password is match. Brute-force attacks can take very long time depending upon the complexity of the password. The cracking time is determined by the speed of computer and complexity of the password.

Countermeasure: Use long and complex passwords. Try to use combination of upper and lowercase letters along with numbers. Brute-force attack will take hundreds or even thousands of years to crack such complex and long passwords.

Example: Passwords like "**iloveu**" or "**password**" can be cracked easily whereas computer will take years to crack passwords like "**aN34iL00**"

2. Social Engineering

Social engineering is process of manipulating someone to trust you and get information from them. For example, if the hacker was trying to get the password of a co-workers or friends computer, he could call him pretending to be from the IT department and simply ask for his login details. Sometime hackers call the victim pretending to be from bank and ask for their credit cards details. Social Engineering can be used to get someone password, to get bank credentials or any personal information.

Countermeasure: If someone tries to get your personal or bank details ask them few questions. Make sure the person calling you is legit. Never ever give your credit card details on phone.

3. Rats and Keyloggers



In keylogging or RATing the hacker sends keylogger or rat to the victim. This allows hacker to monitor everything victim does on his computer. Every keystroke is logged including passwords. Moreover hacker can even control the victim's computer.

Countermeasure: Never login to your bank account from cyber cafe or someone else computer. If it's important use on-screen or virtual keyboard while typing the login. Use latest anti-virus software and keep them updated. Check out below article to know more about Rats and Keyloggers.

4. Phishing



Phishing is the easiest and popular hacking method used by hackers to get someone account details. In Phishing attack hacker send fake page of real website like facebook, Gmail to victim. When someone login through that fake page his details is send to the hacker. These fake pages can be easily created and hosted on free web-hosting sites.

Countermeasure: Phishing attacks are very easy to avoid. The URL of this phishing pages are different from the real one. For example URL of phishing page of facebook might look like facbbook.com (As you can see there are two "b"). Always make sure that websites URL is correct. Check out below article to know more about phishing.

5. Rainbow Table

A Rainbow table is a huge pre-computed list of hashes for every possible combination of characters. A password hash is a password that has gone through a mathematical algorithm such as md5 and is transformed into something which is not recognizable. A hash is a one way encryption so once a password is hashed there is no way to get the original string from the hashed string. A very commonly used hashing algorithm to store passwords in website databases is **MD5**. It is almost similar to dictionary attack, the only difference is, in rainbow tables attack hashed characters are used as passwords whereas in dictionary attack normal characters are used as passwords.

Example: 'hello' in md5 is 5d41402abc4b2a76b9719d911017c592 and zero length string ("") is d41d8cd98f00b204e9800998ecf8427e

Countermeasure: Make sure you choose password that is long and complex. Creating tables for long and complex password takes a very long time and a lot of resources

6. Guessing



This seems silly but this can easily help you to get someone's password within seconds. If hacker knows you, he can use information he knows about you to guess your password. Hacker can also use combination of Social Engineering and Guessing to acquire your password.

Countermeasure: Don't use your name, surname, phone number or birth date as your password. Try to avoid creating password that relates to you. Create complex and long password with combination of letters and numbers

- **Unsecure Network connections :**

Let's look at what an unsecured network is. Generally you can call a network "unsecure" if there are no password or login credentials needed to access it. You just get on and surf the internet. These types of networks can still be found in many places, but in recent years the trend has been towards security.

There are generally two types of WiFi networks you can access: ad-hoc networks and traditional access point networks. Ad-hoc networks connect devices directly to one another, while traditional networks connect devices to a central router. So, for example, you can connect two laptops or your laptop and your phone together without the need for a router or any other hardware. This would create an ad-hoc network. This is different from a traditional access point network where each device connects to a router.

So that “free public WiFi” [network you encounter at the airport](#) is actually an ad-hoc network that was probably started as a prank long ago but still persists to this day. Basically, when you try to connect to this network, you are actually connecting to another computer. And when you connect to this computer, your computer will then also be set up to broadcast the “free public WiFi” network to other devices around you, essentially allowing access to all your private data to anyone within range. Bad idea!

This is just one specific scenario of why you shouldn’t connect to an unknown network. Now, let’s dig into a few more serious reasons:

Why You Shouldn’t Connect to Unsecure Networks

Say you’re sitting in a coffee shop and decide you want to check your Facebook page and your email to kill some time. You scan the available networks and see one that’s open and unsecured. You connect and start surfing. Coffee and free WiFi, what could be better, right? Wrong! A hacker is also fond of coffee shops and he is located within range of the router you connected to. He’s waiting for one or more people to connect to the network so he can start a man in the middle attack. Within a few minutes, he could gain access to all your passwords, including bank accounts, emails, and anything else.

- **Malicious code:**

Malicious code is code causing damage to a computer or system. It is code not easily or solely controlled through the use of anti-virus tools. Malicious code can either activate itself or be like a virus requiring a user to perform an action, such as clicking on something or opening an email attachment.

- **Programming Bugs :**

A software **bug** is an error, flaw, failure, or fault in a computer **program** or system that causes it to produce an incorrect or unexpected result, or to behave in unintended ways.

- **Cyber crime:**

Cyber crime encompasses any criminal act dealing with **computers** and **networks** (called **hacking**). Additionally, cyber crime also includes traditional crimes conducted through the **Internet**. For example; hate crimes, telemarketing and Internet fraud, identity theft, and credit card account thefts are considered to be cyber crimes when the illegal activities are committed through the use of a computer and the Internet

The growing list of cybercrimes includes crimes that have been made possible by computers, such as network intrusions and the dissemination of computer viruses, as well as computer-based variations of existing crimes, such as identity theft, stalking, bullying and terrorism.

There are a number of controversial issues surrounding cybercrime. Opinions differ, for example, as to whether some widespread activities (such as file sharing) should be classified as criminal acts. Also Fraud

Example:

1) Identify Theft:

Some criminals use the Internet to break into victims' online financial accounts, taking passwords, money and sensitive information. Others create online centres for trafficking stolen identity information. With more and more people conducting business online and using the Internet to pay bills, the number of identity theft victims has risen. People that use birthdays, their children's names and pet names as passwords are typically more at risk for identity theft.

2) Storing Illegal Information

Criminals and paedophiles often use the Internet to obtain and transfer illegal images, such as child pornography. Even storing or saving these types of images on a computer is illegal. Other criminals use their computer databases to store illegal information, including confidential intellectual property.

3) Computer Viruses

Computer hackers are digital age criminals that can bring down large infrastructures with a single keystroke emitting a computer virus. These types of viruses are macro or binary. Macro viruses attack a specific program, while binary viruses attack data or attach to program files. Hacking into a business's intranet and uploading viruses to the code are examples of these types of crimes. Private Citizens are targets of computer viruses when visiting websites with encrypted viruses or opening emails infected with viruses. One of the most famous computer viruses is the Trojan virus.

4) Fraud

In the digital age, many criminals easily commit fraud against unsuspecting victims by misrepresenting the facts. For example, an employee intentionally inputs false information into the company database or intranet. Or consider the "Nigerian prince email," where an online predator attempts to steal money from targeted consumers by gaining access to a shared bank account

- **Cyber terrorism:**

Cyber terrorism is the use of Internet attacks in terrorist activities, including acts of deliberate, large-scale disruption of computer networks, especially of personal computers attached to the Internet, by the means of tools such as computer viruses.

- **Information Warfare:**

Many people today are talking about the impact of information technology on the world. They are discussing how business, the economy, education, and even personal relationships are being affected by the onset of the information age. It should come as no surprise, then, that people are also talking about how technology is impacting the way we engage in one of our oldest traditions - war. The term "information warfare" has been in use for a number of years now, intended to represent whatever warfare is becoming in the information-centric 21st century. Unfortunately, though, many people use this term without really knowing what it means.

The Information Warfare Monitor (IWM) was an advanced research activity tracking the emergence of [cyberspace](#) as a strategic domain. It closed January 2012. It was a public-private venture between two Canadian institutions: [The SecDev Group](#), an operational think tank based in [Ottawa](#) (Canada), and the [Citizen Lab](#) at the [Munk School of Global Affairs, University of Toronto](#). The Principal Investigators and co-founders of the Information Warfare Monitor are

[Rafal Rohozinski](#) (The Secdev Group) and [Ronald Deibert](#) (Citizen Lab). The Information Warfare Monitor is part of the Citizen Lab's network of advanced research projects

Activities

The Information Warfare Monitor engages in three primary activities

Case studies. The Information Warfare Monitor designs and carries out active [case study](#) research. These are self-generated activities consistent with the IWM's mission. It employs a rigorous and multidisciplinary approach to all case studies blending qualitative, technical, and quantitative methods. As a general rule, its investigations consist of at least two components:

Field-based investigations. The IWM engages in qualitative research among affected target audiences and employ techniques that include interviews, long-term *in situ* interaction with partners, and extensive technical data collection involving system monitoring, network reconnaissance, and interrogation. Its field-based teams are supported by senior analysts and regional specialists, including social scientists, computer security professionals, policy experts, and linguists, who provide additional contextual support and substantive back-up.

Technical scouting and laboratory analysis. Data collected in the field is analyzed using a variety of advanced data fusion and visualization methods. Leads developed on the basis of infield activities are pursued through "[technical scouting](#)," including computer network investigations, and the resulting data and analysis is shared with infield teams and partners for verification and for generating additional entry points for follow-on investigations.

Open source trend analysis -- The IWM collects [open source](#) information from the press and other sources tracking global trends in [cyberspace](#). These are published on its public website.

Preventing from Attack and Threats

- Recovering from Viruses, Worms, and Trojan Horses
- Avoiding Social Engineering and Networking Attacks
- Avoiding the Pitfalls of Online Trading
- Using Caution with USB Drives
- Securing Wireless Networks

Preventing from Email and communication

- Using Caution with Email Attachments
- Reducing Spam

- Using Caution With Digital Signatures
- Using Instant Messaging and Chat Rooms Safely
- Staying safe on social Network Sites

Use Safe Browsing

- Evaluating Your Web Browser's Security Settings
- Shopping Safely Online
- Web Site Certificates
- Bluetooth Technology
- Reviewing End-User License Agreements

Privacy Control

- Protecting Your Privacy
- Effectively Erasing Files
- Supplementing Passwords

Tips for securing the system attack

- Install and Use Anti-Virus Programs
- Use Care When Reading Email with Attachments
- Install and Use a Firewall Program
- Make Backups of Important Files and Folders
- Use Strong Passwords
- Use Care When Downloading and Installing
- Install and Use a Hardware Firewall
- Install and Use a File Encryption Program and Access Controls
- Safeguard your Data
- Real-World Warnings keep you safe online.
- Keeping Children Safe Online

• MCQ & descriptive Questions

Chap-3 Security Threats & Vulnerabilities

1. Threat can lead to attacks on computer systems----- and more.

- A] Network B] Hub C] Host D] code
2. Vulnerability is a which allows an attacker to reduce a system's information assurance.
- A] Softness B] Weakness C] Preakness D] Attack
3. Threat can be either 'International' or -----
- A] Natural B] Individual C] Accidental D] Capable
4. Most of the popular banking threats come from the ----- family.
- A] Worms B] Spyware C] Shareware D] Trojan
5. Key logger is very powerful threat to ---- peoples login credential such as username & password.
- A] Steal B] Avoid C] return D] open
6. A----- website which is designed to look almost like the actual website is form of phishing attack.
- A] Real B] Fake C] Local D] Global
7. Bluesnarfing is all about having an unauthorized access to a specific ----- phones, laptops or a PDA. Via Bluetooth connection.
- A] Network B] Car C] Mobile D] Printer
8. Passwords are used for -----
- A] Access B] Searching C] linking D] authentication
9. There are ----- types of passwords.
- A] Two B] three C] Four D] Five
10. Cyber Crime encompasses any criminal act dealing with computer and -----
- A] Printer B] Network C] Man D] Technology
11. Cyber terrorism is the use of ----- attacks in terrorist activities.
- A] terrorist B] hackers C] Internet D] Crackers
12. IWM Stands for –
- A] Information Website Monitor B] Infrastructure Website Monitor
C] Information Web Manipulator D] The information Warfare Monitor
13. The IWM collects ----- information from the press and other sources tracking global trends in.
- A] Open source B] Close Source C] First Source D] Last Source

14. Privacy Control Protecting -----.

A] Your Security B] Your Privacy

15. For securing the system make backups of important ----- & Folders.

A] Files B] Data C] Reports D] All above

Answer key:- Q-1)A Q-2)B Q-3)C Q-4)D Q-5)A Q-6)B Q-7)C Q-8)D
Q-9)A Q-10)B Q-11)C Q-12)D Q-13)A Q-14)B Q-15)A

Descriptive questions:-

1)what is threat?

Q-2)What is vulnerabilities?

Q-3)Explain different techniques of password cracking?

Q-4)What is cyber crime?

Q-5)Explain cyber terrorism?

Q-6)What is password?Explain weak password and strong password.

Q-7)Explain different ways how security provided to the system?

=====

Modul-1

Chapter-4

Cryptography / Encryption

○ Content : -

- 1) Introduction to Cryptography / Encryption**
- 2) Digital Signature**
- 3) Public key infrastructure**
- 4) Applications of Cryptography**
- 5) Tools and techniques of cryptography**

From the dawn of civilisation, to the highly networked societies that we live in today — communication has always been an integral part of our existence. What started as simple sign-communication centuries ago has evolved into many forms of communication today — the Internet being just one such example. Methods of communication today include:

- 1) Radio communication
- 2) Telephonic communication
- 3) Network communication
- 4) Mobile communication

All these methods and means of communication have played an important role in our lives, but in the past few years, network communication, especially over the Internet, has emerged as one of the most powerful methods of communication —with an overwhelming impact on our lives.

Such rapid advances in communications technology have also given rise to security threats to individuals and organizations. In the last few years, various measures and services have been developed to counter these threats. All categories of such measures and services, however, have certain fundamental requirements, which include :

1) **Confidentiality**, which is the process of keeping information private and secret so that only the intended recipient is able to understand the information. For example, if Alice has to send a message to Bob, then Bob only (and no other person except for Bob) should be able to read or understand the message.

2) **Authentication**, which is the process of providing proof of identity of the sender to the recipient, so that the recipient can be assured that the person sending the information is who and what he or she claims to be. For example, when Bob receives a message from Alice, then he should be able to establish the identity of Alice and know that the message was indeed sent by Alice.

3) **Integrity**, which is the method to ensure that information is not tampered with during its transit or its storage on the network. Any unauthorized person should not be able to tamper with the information or change the information during transit. For example, when Alice sends a message to Bob, then the contents of the message should not be altered with and should remain the same as what Alice has sent.

4) **Non-repudiation**, which is the method to ensure that information cannot be disowned. Once the non-repudiation process is in place, the sender cannot deny being the originator of the data. For example, when Alice sends a message to Bob, then she should not be able to deny later that she sent the message.

Before we look at the various mechanisms that provide these security services, let us look at the various types of security attacks that can be faced by an organization:

- **Interruption:** In an attack where one or more of the systems of the organization become unusable due to attacks by unauthorized users. This leads to systems being unavailable for use. Figure 1-1 displays the process of interruption.
- **Interception:** An unauthorized individual intercepts the message content and changes it or uses it for malicious purposes. After this type of attack, the message does not remain

confidential; for example, if the contents of message that Alice sends to Bob are read or altered during its transmission of message by a hacker or an interceptor. In this situation, Bob cannot consider such a message to be a confidential one. Figure 1-2 displays the process of interception.

- **Modification:** The content of the message is modified by a third party. This attack affects the integrity of the message.

From securing sensitive military information to securing personal messages, you often would be confronted with the need of masking information to protect it. One of the most important methods that help provide security to messages in transit is *cryptography*. It helps overcome the security issues as described above, involved in the delivery of messages over any communication channel. This chapter provides an overview of cryptography and popular cryptographic techniques.

The Basics of Cryptography

Cryptography is the science of protecting data, which provides means and methods of converting data into unreadable form, so that The data cannot be accessed for unauthorized use.

- The content of the data frames is hidden.
- The authenticity of the data can be established.
- The undetected modification of the data is avoided.
- The data cannot be disowned by the originator of the message.

Cryptography is one of the technological means to provide security to data being transmitted on information and communications systems. Cryptography is especially useful in the cases of financial and personal data, irrespective of the fact that the data is being transmitted over a medium or is stored on a storage device. It provides a powerful means of verifying the authenticity of data and identifying the culprit, if the confidentiality and integrity of the data is violated. Because of the development of electronic commerce, cryptographic techniques are extremely critical to the development and use of defense information systems and communications networks.

History of Cryptography

As already discussed, the messages were first encrypted in ancient Egypt as a result of hieroglyphics. The Egyptians encrypted messages by simply replacing the original picture with another picture. This method of encryption was known as substitution cipher. In this method, each letter of the cleartext message was replaced by some other letter, which results in an encrypted message or ciphertext.

For example, the message

WELCOME TO THE WORLD OF CRYPTOGRAPHY

can be encrypted by using substitution cipher as

XFMDPNF UP UIF XPSME PG DSZQUPHSBQIZ

In the preceding example, each letter of the plaintext message has been replaced with the next letter in the alphabet. This type of substitution is also known as Caesar cipher. Caesar cipher

is an example of shift cipher because it involves shifting each letter of the plaintext message by some number of spaces to obtain the ciphertext.

For example, if you shift the letters by 5, you get the following combination of plaintext and ciphertext letters:

Plaintext A B C D E F G H I J K L M N O P Q R S T U V W X Y Z
Ciphertext F G H I J K L M N O P Q R S T U V W X Y Z A B C D E

However, simple substitution ciphers are not a very reliable type and can easily be broken down. In such a case, an alternative way is to use multiple alphabets instead of one alphabet. This type of a cipher, which involves multiple cipher alphabets, is known as a *polyalphabetic substitution cipher*. An example of the polyalphabetic substitution cipher is the Vigenere cipher. With the recent advances in mathematical techniques, there has been an acceleration in the development of newer methods of encryption. Today, cryptography has emerged so powerful that it is considered rather impossible to break some ciphers.

Cryptography has now become an industry standard for providing information security, trust, controlling access to resources, and electronic transactions. Its use is no longer limited to just securing sensitive military information. In fact, cryptography is now recognized as one of the major components of the security policy of an organization.

Before moving further with cryptography, let us first look at a few terms that are commonly associated with cryptography:

- **Plaintext:** Is the message that has to be transmitted to the recipient. It is also commonly referred to as *cleartext*.
- **Encryption:** Is the process of changing the content of a message in a manner such that it hides the actual message.
- **Ciphertext:** Is the output that is generated after encrypting the plain text.
- **Decryption:** Is the reverse of encryption and is the process of retrieving the original message from its encrypted form. This process converts ciphertext to plaintext.
- **Hash algorithm:** Is an algorithm that converts text string into a string of fixed length.
- **Key:** Is a word, number, or phrase that is used to encrypt the cleartext. In computer-based cryptography, any text, key word, or phrase is converted to a very large number by applying a hash algorithm on it. The large number, referred to as a key, is then used for encryption and decryption.
- **Cipher:** Is a hash algorithm that translates plaintext into an intermediate form called ciphertext, in which the original message is in an unreadable form.
- **Cryptanalysis:** Is the science of breaking codes and ciphers.

Before looking at the details of various cryptographic techniques, let us now look at the steps involved in the conventional encryption model:

1. A sender wants to send a *Hello* message to a recipient.
2. The original message, also called plaintext, is converted to random bits known as ciphertext by using a key and an algorithm. The algorithm being used can produce a different output each time it is used, based on

the value of the key.

3. The ciphertext is transmitted over the transmission medium.

4. At the recipient end, the ciphertext is converted back to the original text using the same algorithm and key that were used to encrypt the message.

Having looked at an overview of cryptography, let us now look at the various cryptography techniques available. For the purpose of classification, the techniques are categorized on the basis of the number of keys that are used. The two main cryptography techniques are

- **Single key cryptography:** This cryptography technique is based on a single key. It is also known as symmetric key or private key or secret key encryption.
- **Public key cryptography:** This cryptography technique is based on a combination of two keys—secret key and public key. It is also known as asymmetric encryption.
-

Let us look at each of these methods in detail.

Single Key Cryptography

The process of encryption and decryption of information by using a single key is known as secret key cryptography or *symmetric key cryptography*. In symmetric key cryptography, the same key is used to encrypt as well as decrypt the data. The main problem with symmetric key algorithms is that the sender and the receiver have to agree on a common key. A secure channel is also required between the sender and the receiver to exchange the secret key. Here's an example that illustrates the process of single key cryptography. Alice wants to send a "For Your Eyes" message to Bob and wants to ensure that only Bob is able to read the message. To secure the transmission, Alice generates a secret key, encrypts the message with this key, and sends the message to Bob.

Now, to read the encrypted message, Bob would need the secret key that has been generated by Alice. Alice can give the secret key to Bob in person or send the key to Bob by any other means available. If Alice sends the key to Bob in person, it could be time-consuming depending on the physical distance between the two of them or other circumstances such as Bob's availability. After Bob receives the secret key, he can decrypt the message to retrieve the original message. Many secret key algorithms were developed on the basis of the concept of secret key cryptography. The most widely used secret key algorithms include Data Encryption Standard (DES)

- Triple-DES (3DES)
- International Data Encryption Algorithm (IDEA)
- RC4
- CAST-128
- Advanced Encryption Standard (AES)

Let us consider these algorithms in detail in the following sections.

DATA ENCRYPTION STANDARD (DES)

DES, which is an acronym for the Data Encryption Standard, is the common name for the Federal Information Processing Standard (FIPS) 46-3. It describes the *Data Encryption Algorithm* (DEA). DEA is also defined in the ANSI standard X3.92. The DES algorithm is one of the most widely used encryption algorithms in the world. The Data Encryption Standard

(DES) algorithm was developed by the IBM team in the 1970s and was adopted by National Institute of Standards and Technology (NIST) for commercial applications. DES is still surrounded by controversy. This controversy was originally fueled by the following facts: The key length used by this algorithm was reduced to 56 bits by the U.S. government, although the original design called for a key length of 128 bits, leading to a compromise on security. Although the algorithm for DES was published, the rationale for the design was never published. DES became widely available to the U.S. public and to approved users in other countries. However, DES was excluded by the U.S. government from protection of any of its own classified information.

TRIPLE DATA ENCRYPTION STANDARD (3DES)

Triple-DES is a minor variation of DES. Although, three times slower than DES, it can be much more secure, if used properly. In today's scenario, Triple-DES is implemented more widely than DES. This is because DES is easy to break with the help of advanced technology that is widely available today. On the other hand, 3DES has proved to be an extremely reliable solution because of the longer key length that it uses. This extended length of key plays an important role in eliminating many of the shortcut attacks that can be used to reduce the amount of time it takes to break DES. You can increase the effective key length of your cryptographic system by using the Triple Pass DES through the process known as EDE (Encrypt, Decrypt, and Encrypt). When you use triple pass DES, it first encrypts the plaintext data with a 56-bit key. The ciphertext so obtained is then decrypted by using a different key. When you decrypt ciphertext with some different key it gives some garbage. Finally, you encrypt the garbage with the first key. This process of using triple pass DES for encryption, decryption, and again encryption is commonly referred to as EDE.

INTERNATIONAL DATA ENCRYPTION ALGORITHM (IDEA)

The International Data Encryption Algorithm (IDEA) is a symmetric block cipher developed by Xuejia Lai and James Massey of the Swiss Federal Institute of technology. It uses a 128-bit key to encrypt data in blocks of 64 bits. This is why it is referred to as a block cipher method. IDEA is designed to facilitate both software and hardware implementation. There are major factors that make IDEA a strong algorithm.

The key length is long enough to prevent comprehensive key searches. IDEA uses a key length of 128 bits, which makes it very secure. The ciphertext is not easily decipherable from the plaintext and the key. IDEA effectively masks the statistics of how the ciphertext depends on the statistics of the plaintext. IDEA was developed to provide a high level of security with ease of implementation. Due to its strength and reliability IDEA is now used worldwide in many banking and industry applications.

ADVANCED ENCRYPTION STANDARD (AES)

With an estimated growth rate of two times every 18 months, computational power is growing in leaps and bounds. This has made Data Encryption Standard (DES) more and more insecure and vulnerable to malicious attacks. As a result, DES, which was the Federal Information Processing Standard (FIPS) until recently, has slowly become redundant. The National Institute of Standards and Technology (NIST) realized this situation and recognized the need for another standard that would be more secure than the DES. However, since DES is a federal standard, it is used widely by many organizations, particularly those in the financial

industry. Advanced Encryption Standard (AES) emerged as a powerful replacement of DES during a competition held by NIST. The competition was organized to develop a substitute of existing DES. The following algorithms reached the final round of the competition to become AES:

- **MARS:** An algorithm developed by IBM.
- **RC6:** An algorithm developed by Ron Rivest of RSA Labs, the creator of the widely used RC4 algorithm.
- **Twofish:** An algorithm from Counterpane Internet Security, Inc. This design was highly suited for large microprocessors and smart card microprocessors.
- **Serpent:** An algorithm designed by Ross Anderson, Eli Biham, and Lars Knudsen.
- **Rijndael:** An algorithm designed by Daemen and Rijmen.

PROBLEMS IN SYMMETRIC CRYPTOGRAPHY

The major problem with symmetric cryptography is that the process of transferring keys to the recipient is prone to security risks. Transferring the secret key over the Internet either in an e-mail message or through simple IRC services is insecure. Verbally communicating the key over a phone line runs the risk of eavesdropping. Similarly, snail mail runs the risk of possible interception. The security risks that are involved in secret key cryptography have been overcome to a large extent in another method of cryptography called public key cryptography. Public key cryptography uses a key pair instead of just one secret key. Of this key pair, one key, known as the private key, is always kept secret by the key holder. This private key is not transferred to anyone and is stored securely by the holder of the key and thus

public key cryptography eliminates the need for transferring the private key. Let us take an example where Alice wants to send an encrypted message to Bob. If she is using symmetric key encryption, then both Alice and Bob need to first establish a secret key. Only after this secret key has been established, can they both communicate. However, if Alice uses public key encryption, she can send an encrypted message to Bob without first transmitting a secret key. This not only solves the problem of key distribution but also makes the process of key management a lot simpler. In addition to this, public key cryptography also provides data integrity, authentication, and non-repudiation. Public key encryption can also be used for creating digital signatures, which are used for user authentication. Let us now discuss public key cryptography in detail.

PUBLIC KEY CRYPTOGRAPHY :

The approach called *asymmetric cryptography* evolved to address the security issues posed by symmetric cryptography. This method solves the problem of secret key cryptography by using two keys instead of a single key. Asymmetric cryptography uses a pair of keys. In this process, one key is used for encryption, and the other key is used for decryption. This process is known as asymmetric cryptography because both the keys are required to complete the process. These two keys are collectively known as the *key pair*. In asymmetric cryptography, one of the keys is freely distributable. This key is called the *public key* and is used for encryption. Hence, this method of encryption is also called public key encryption. The second key is the secret or private key and is used for decryption. The private key is not distributable. This key, like its name suggests, is private for every communicating entity. In public key cryptography, the data that is encrypted with the public key can only be decrypted with the corresponding private key. Conversely, data encrypted with the private key can only be decrypted with the corresponding

public key. Due to this asymmetry, public key cryptography is known as asymmetric cryptography.

HOW DOES PUBLIC KEY CRYPTOGRAPHY WORK?

Let's see how this works out in practice. Consider an example, where Alice wishes to send an encrypted file to Bob. In this situation, Bob would obtain a key pair, retain the private key, and distribute the public key. Alice, therefore, has a copy of Bob's public key. Alice then encrypts the file using Bob's public key and sends the encrypted file to Bob. Since the key pairs are complementary, only Bob's private key can decrypt this file. If someone else intercepts the file, they will be unable to decrypt the file, because only Bob's private key can be used for the decryption. Figure 1-8 explains the process of public key cryptography. This method very clearly indicates that the data you send to a user can only be encrypted by the public key. Similarly, the decryption can be done only by the private key, which is supplied by the recipient of the data. So, there is very little possibility of the data in transit being accessed or tampered by any other person. Therefore, messages can be exchanged securely. The sender and receiver do not need to share a key, as required for symmetric encryption. All communications involve only public keys, and no private key is ever transmitted or shared. The above mechanism also brings out the point that every recipient will have a unique key that he will use to decrypt the data that has been encrypted by its counterpart public key. Diffie and Hellman first discussed the process of asymmetric cryptography. One of the most common implementations of this process is the RSA algorithm.

Combining Techniques: Symmetric and Asymmetric Encryption

The disadvantage of using public key encryption is that it is a slow process because key lengths are large (1024 bits to 4094 bits). When you compare both processes, secret key encryption is significantly faster as the key length is less (40 bits to 256 bits). On the other hand, there is a problem in transferring the key in secret key encryption. Both these techniques can be used together to provide a better method of encryption. This way you can make use of the combined advantages and overcome the disadvantages.

The steps in data transaction in a combined technique are:

1. Encrypt your file by using a symmetric encryption.
2. Use asymmetric encryption to encrypt only this key using the recipient's public key. Now send the encrypted key to the recipient. The recipient, at his end, can now decrypt the key using his/her private key.
3. Next, send the actual encrypted data. The encrypted data can be decrypted using the key that was encrypted by using the public key from the asymmetric key pair.

The combined technique of encryption is used widely. It is basically used for Secure Shell (SSH), which is used to secure communications between a client and the server and PGP (Pretty Good Privacy) for sending messages. Above all, it is the heart of Secure Sockets Layer (SSL), which is used widely by Web browsers and Web servers to maintain a secure communication channel with each other.

APPLICATIONS OF CRYPTOGRAPHY : -

By now, you would have understood various cryptography techniques and their advantages and disadvantages. Let us now look at the implementation of cryptography to provide basic security features, which are, confidentiality, integrity, authentication, and non-repudiation. All these security features can be provided by using any one of the following methods:

- Message encryption
- Message Authentication Code (MAC)
- Hash functions

Let us discuss each of these implementations in detail.

❖ **MESSAGE ENCRYPTION : -**

There are multiple variations of message encryption. Messages can be encrypted either by using secret key encryption or by using public key encryption. Let us look at both the methods in detail.

USING SECRET KEY ENCRYPTION TO PROVIDE CONFIDENTIALITY AND AUTHENTICATION

Conventional encryption methods serve the purpose of authentication, integrity, and confidentiality. Let us look at an example, where Alice wants to send a message to Bob. Only Alice and Bob know the secret key, and no other party knows about the secret key. If Alice sends a message using the secret key to Bob, then Bob knows that the message is coming from Alice, as only Bob and Alice know the secret key.

Once the ciphertext reaches Bob, he decrypts the message using the secret key and generates the original plaintext. If Bob recovers the plaintext by using his secret key, this means that the data has not been tampered with during transmission. If Bob is unable to recover the data, this means that someone else might have used the secret key and altered the contents of the message. If the contents of the message are altered then Bob will not be able to decrypt the message. Hence, the conventional encryption gives both confidentiality and authenticity to messages. However, this method does not provide information about the integrity of data.

USING SECRET KEY ENCRYPTION FOR CONFIDENTIALITY, AUTHENTICATION, AND INTEGRITY

Now let's take an example, where Bob receives a ciphertext from Alice and he decrypts it. Bob can decrypt any ciphertext and produce an output, which will be a plaintext. However, he will get a meaningful output only when Alice has sent the message. Otherwise, the plaintext generated by Bob will be a meaningless sequence of bits. Hence, there must be some automated process at Bob's end to verify that the plaintext he has recovered is a legitimate message and has come from Alice. If the original plaintext is in a clear message in plain English then determination is easier, because it will generate a meaningless sequence that makes it easier to detect the legitimacy of the message. But if the original message is some binary object file or a digitized image, then it may be difficult to detect the integrity of the message.

To overcome this problem, one solution is to append an error detecting code to the original message, known as *frame check sequence* (FCS). So now if Alice wants to send a message M to Bob, Alice uses a function FN, which produces an output, FCS. Next, Alice will append this output FCS to the original message M. Then, the entire message along with the FCS will be encrypted using the secret key and will be sent to Bob. Bob will decrypt the entire message with the secret key and will get the message M, and the appended output FCS. Now Bob will put the

Message M to the same function, which Alice had used to generate FCS, and produce the FCS. He will compare this FCS with the appended FCS, which has come with the message. If both are the same, then the message is considered legitimate. This method provides both integrity as well as authenticity.

❖ **HASH FUNCTION : -**

A hash function is a variation of the message authentication code. A *hash function*, H , is a conversion method that takes an input m , which is the message, and returns a fixed-size string, which is called the *hash value* h (that is, $h = H(m)$) or message digest. This output is fixed in size and is irreversible, which means that the original content can never be recovered. The hash function output could be *weakly collision free*, which means that there is a very rare chance that a similar output could be produced by another message. The output could also be *strongly collision free*, which means that a similar output can never be produced by another message. Hash functions are normally used to provide the digital fingerprints of files to ensure that the content of the file has not been altered in transit. There are various ways how hash functions can be used in communication between two individuals. Let us take an example to explain this communication process. Alice wants to send a message to Bob; Alice will append the hash value of the message with the message and encrypt the message with the secret key. This will provide authenticity, because only Alice and Bob know about the secret key, and encryption is used to provide confidentiality to the message. Alice will encrypt the message digest or the hash value by using her private key. This will generate Alice's digital signature, because only Alice can provide the encrypted hash value.

❖ **DIGITAL SIGNATURE : -**

Any process of authentication protects two parties against a third party. However, this process does not protect the parties against each other. This means that in situations where there isn't complete trust between the sender and the recipient, something more than authentication is required. This problem can be solved using a digital signature. A digital signature is analogous to a handwritten signature and verifies the author, date, and time of signature. The signature should also be able to authenticate the content at the time of the signature. The main requirements of a digital signature are:

- ❖ It is unique to the sender.
- ❖ It should be recognizable and verifiable.

There are a variety of approaches for digital signatures, which fall broadly into two categories—*direct* and *arbitrated*.

Direct Digital Signatures

A direct digital signature can be formed by encrypting the entire message with the sender's private key or by encrypting a hash value of the message with the sender's private key. Figure 1-20 explains the process of creating digital signatures. The output is called a digital signature and is attached to the message. To verify the signature, the recipient does a computation involving the message, the signature, and the sender's public key. If the result conforms, the signature is considered to be authentic. Otherwise, the signature is considered

either to be a fake or the message has been tampered with. This is because the computed value is based on the signature and the contents of the message. Any change in the values of the digital signature or the contents of the message results in a mismatch between the computed value and the value that is received. This indicates that either the signatures have been faked or the message contents have been modified.

Further encrypting the entire message plus the digital signature can provide confidentiality. It is important to add the digital signature to the message and then to encrypt the entire message. Rather than encrypting the message first, the digital signature must be calculated and added to the signature. If the latter approach is taken, then a third party needs to access the decryption method to read the message. Otherwise, only plaintext and the digital signature can be kept for future dispute resolutions. This direct digital signature scheme has a single drawback—the entire scheme depends on the validity of the sender's private key. If the sender disowns the responsibility that he has sent the message and claims that private key is lost or compromised then somebody must have forged the signature.

Arbitrated Digital Signature

Arbitrated digital signature scheme is used to overcome the problem of nonrepudiation encountered in a direct digital signature. In this scheme, every signed message from the sender, which has been sent to the recipient, first goes to an arbitrator who checks the signature about its origin and content. The message is then dated and sent to the recipient. The presence of the arbitrator solves the problem of sender disowning the signature. For example, when Alice sends a digitally signed message to Bob, an arbitrator first validates Alice's signature. After the signature has been validated, the message is then sent to Bob along with the date of validation and notice that the signature does belong to Alice.

How Does a Digital Signature Work?

The manner in which a digital signature works is quite simple. Let's suppose that you want to send important documents to your business partner, who is out-of-town. After you send the documents, you need to assure your partner that the documents have not been modified and are not different from the ones that you sent, and that you actually own them. To ensure the authenticity of the documents that you are sending in an e-mail message, you need to get a hash for your document and then encrypt the hash by using the private key from the key pair that you have obtained from an authority. So where's your digital signature? The hash that you encrypted by using the key is your digital signature. In this way, the hash function is converted to a digital signature and an e-mail that you can send to the receiver. Each time that you create a digital signature for a message, your digital signature will be different because a different hash has been created each time. Now let's look at the recipient's side. The message reaches your business partner. How does he verify that it is a valid and authentic document? Your business partner will first create a hash for the message. Then he will decrypt the message hash that you sent. How will he do it? He will use the public key to decrypt it. Finally, he needs to match the hash you sent with the hash that was created at his end. If the two match, it is proof that your message is a valid one. There are several standard algorithms that have been developed for creating digital signatures. One of them is Digital Signature Standard (DSS) developed by the U.S. National

Security Agency (NSA) in 1994. It has been used to generate digital signatures for electronic documents.

Chapter – 4

Cryptography / Encryption

MCQ & descriptive Questions

- 1) Due to attack of unauthorized users one or more systems of organization become unusable is a security attack.
a) interruption b) interception c) fabrication d) modification
- 2) The measures have been developed to save data from threats are confidentiality, integrity &
a) modification b) fabrication c) non-repudiation d) none of above
- 3) Third party person inserts a fake message into original message by posing as a valid user is security attack.
a) modification b) fabrication c) non-repudiation d) none of above
- 4) Cryptography is a science of protecting data which provides method of converting data into form
a) readable b) unreadable c) non-recoverable d) none of above
- 5) Messages were first encrypted in an ancient
a) India b) China c) Egypt d) Saudi Arabia
- 6) is a message that has to be transmitted into ciphertext.
a) hash b) ciphertext c) plaintext d) key
- 7) is a process of changing plaintext into ciphertext.
a) Cryptography b) Encryption c) Decryption d) Cryptanalysis.
- 8) is a output after the process of encryption.
a) hash b) ciphertext c) plaintext d) key
- 9) is a process of changing ciphertext into plaintext.
a) Cryptography b) Encryption c) Decryption d) Cryptanalysis.
- 10) is a word, number or phrase used to encryption or decryption,
a) hash b) ciphertext c) plaintext d) key
- 11) In key cryptography technique single key is used.
a) single b) double c) triple d) none of above.
- 12) A key pair is used in key cryptography.
a) single b) public c) combined d) hybrid

- 13) Public and private both keys are used so it is called as key cryptography.
 a) symmetric b) asymmetric c) multi-symmetric d) non of above
- 14) Public key length is from bit to bit.
 a) 40 b) 1024 c) 4094 d) 256
- 15) Secret key length is from. bit to bit.
 a) 40 b) 1024 c) 4094 d) 256
- 16) is the one of application of cryptography.
 a) Message coding b) Message encryption c) Message decoding d) None of above
- 17) In Message encryption along with message an error detection code is attached is
 a) MCS b) MCA c) MAC d) CAM
- 18) If message is in then it is difficult to verify the message.
 a) digitized image b) plain English c) plain Hindi d) code
- 19) is a science of breaking codes or ciphers.
 a) Cryptography b) Encryption c) Decryption d) Cryptanalysis.
- 20) is a hash algorithm that translates plaintext into ciphertext.
 a) key b) hash c) cipher d) none of above
- 21) is a process that takes input of message & returns fixed-size-string.
 a) hash b) hash value c) hash function d) hash digest
- 22) After applying hash function on message we get
 a) hash b) hash value c) hash function d) hash digest
- 23) is obtained by encrypting hash value with sender's private key.
 a) Digital signature b) Original signature c) Image signature d) none of above.
- 24) is a mediator which verifies signature about origin and content.
 a) Egyptian b) American c) Arbitrator d) Non of above
- 25) digital signature is one of the type of digital signature.
 a) Direct b) Indirect c) Unidirect d) Non of above
- =====

Module-2 :

Security Management

Chapter 1: Security Management Practices

Contents:

- ➔ Overview of the Security Management
- ➔ Information Classification Process
- ➔ Security Policy
- ➔ Risk Management
- ➔ Security Procedure and Guidelines
- ➔ Business Continuity and Disaster Recovery
- ➔ Ethics and Best Practices

DEFINITION

The use of the term “company” is in reverence to the following organization: (Insert Organization Name).

INTRODUCTION

This Cyber Security Policy is a formal set of rules by which those people who are given access to company technology and information assets must abide.

The Cyber Security Policy serves several purposes. The main purpose is to inform company users: employees, contractors and other authorized users of their obligatory requirements for protecting the technology and information assets of the company. The Cyber Security Policy describes the technology and information assets that we must protect and identifies many of the threats to those assets.

The Cyber Security Policy also describes the user’s responsibilities and privileges. What is considered acceptable use? What are the rules regarding Internet access? The policy answers these questions, describes user limitations and informs users there will be penalties for violation of the policy. This document also contains procedures for responding to incidents that threaten the security of the company computer systems and network.

WHAT ARE WE PROTECTING

It is the obligation of all users of the company systems to protect the technology and information assets of the company. This information must be protected from unauthorized access, theft and destruction. The technology and information assets of the company are made up of the following components:

- Computer hardware, CPU, disc, Email, web, application servers, PC systems, application software, system software, etc.
- System Software including: operating systems, database management systems, and backup and restore software, communications protocols, and so forth.
- Application Software: used by the various departments within the company. This includes custom written software applications, and commercial off the shelf software packages.
- Communications Network hardware and software including: routers, routing tables, hubs, modems, multiplexers, switches, firewalls, private lines, and associated network management software and tools.

Classification of Information

User information found in computer system files and databases shall be classified as either confidential or non-confidential. The company shall classify the information controlled by them. The (company designee) is required to review and approve the classification of the information and determine the

appropriate level of security to best protect it. Furthermore, the (company designee) shall classify information controlled by units not administered by a (company designee).

Classification of Computer Systems

Security Level	Description	Example
RED	This system contains confidential information – information that cannot be revealed to personnel outside of the company. Even within the company, access to this information is provided on a “need to know” basis. The system provides mission-critical services vital to the operation of the business. Failure of this system may have life threatening consequences and/or an adverse financial impact on the business of the company.	Server containing confidential data and other department information on databases. Network routers and firewalls containing confidential routing tables and security information.
GREEN	This system does not contain confidential information or perform critical services, but it provides the ability to access RED systems through the network.	User department PCs used to access Server and application(s). Management workstations used by systems and network administrators.
WHITE	This system is not externally accessible. It is on an isolated LAN segment, unable to access RED or GREEN systems. It does not contain sensitive information or perform critical services.	A test system used by system designers and programmers to develop new computer systems.
BLACK	This system is externally accessible. It is isolated from RED or GREEN systems by a firewall. While it performs important services, it does not contain confidential information.	A public Web server with non-sensitive information.

Local Area Network (LAN) Classifications

A LAN will be classified by the systems directly connected to it. For example, if a LAN contains just one RED system and all network users will be subject to the same restrictions as RED systems users. A LAN will assume the Security Classification of the highest level systems attached to it.

DEFINITIONS

Externally accessible to public. The system may be accessed via the Internet by persons outside of the company without a logon id or password. The system may be accessed via dial-up connection without providing a logon id or password. It is possible to “ping” the system from the Internet. The system may or may not be behind a firewall. A public Web Server is an example of this type of system.

Non-Public, Externally accessible. Users of the system must have a valid logon id and password. The system must have at least one level of firewall protection between its network and the Internet. The system may be accessed via the Internet or the private Intranet. A private FTP server used to exchange files with business partners is an example of this type of system.

Internally accessible only. Users of the system must have a valid logon id and password. The system must have at least two levels of firewall protection between its network and the Internet. The system is not visible to Internet users. It may have a private Internet (non-translated) address and it does not respond to a “ping” from the Internet. A private intranet Web Server is an example of this type of system.

Chief Information Officer. The Director of the Department of Information Technology (IT) shall serve as the Chief Information Officer.

Security Administrator. An employee of IT shall be designated as the Security Administrator for the company.

Threats to Security

Employees

One of the biggest security threats is employees. They may do damage to your systems either through incompetence or on purpose. You have to layer your security to compensate for that as well. You mitigate this by doing the following.

- ✓ Only give out appropriate rights to systems. Limit access to only business hours.
- ✓ Don't share accounts to access systems. Never share your login information with co-workers.
- ✓ When employees are separated or disciplined, you remove or limit access to systems.
- ✓ Advanced – Keep detailed system logs on all computer activity.
- ✓ Physically secure computer assets, so that only staff with appropriate need can access.

Amateur Hackers and Vandals.

These people are the most common type of attackers on the Internet. The probability of attack is extremely high and there is also likely to be a large number of attacks. These are usually crimes of

opportunity. These amateur hackers are scanning the Internet and looking for well known security holes that have not been plugged. Web servers and electronic mail are their favorite targets. Once they find a weakness they will exploit it to plant viruses, Trojan horses, or use the resources of your system for their own means. If they do not find an obvious weakness they are likely to move on to an easier target.

Criminal Hackers and Saboteurs.

The probability of this type of attack is low, but not entirely unlikely given the amount of sensitive information contained in databases. The skill of these attackers is medium to high as they are likely to be trained in the use of the latest hacker tools. The attacks are well planned and are based on any weaknesses discovered that will allow a foothold into the network.

User Responsibilities

This section establishes usage policy for the computer systems, networks and information resources of the office. It pertains to all employees and contractors who use the computer systems, networks, and information resources as business partners, and individuals who are granted access to the network for the business purposes of the company.

Acceptable Use

User accounts on company computer systems are to be used only for business of the company and not to be used for personal activities. Unauthorized use of the system may be in violation of the law, constitutes theft and can be punishable by law. Therefore, unauthorized use of the company computing system and facilities may constitute grounds for either civil or criminal prosecution.

Users are personally responsible for protecting all confidential information used and/or stored on their accounts. This includes their logon IDs and passwords. Furthermore they are prohibited from making unauthorized copies of such confidential information and/or distributing it to unauthorized persons outside of the company.

Users shall not purposely engage in activity with the intent to: harass other users; degrade the performance of the system; divert system resources to their own use; or gain access to company systems for which they do not have authorization.

Users shall not attach unauthorized devices on their PCs or workstations, unless they have received specific authorization from the employees' manager and/or the company IT designee.

Users shall not download unauthorized software from the Internet onto their PCs or workstations.

Users are required to report any weaknesses in the company computer security, any incidents of misuse or violation of this policy to their immediate supervisor.

Use of the Internet

The company will provide Internet access to employees and contractors who are connected to the internal network *and* who has a business need for this access. Employees and contractors must obtain permission from their supervisor and file a request with the Security Administrator.

The Internet is a business tool for the company. It is to be used for business-related purposes such as: communicating via electronic mail with suppliers and business partners, obtaining useful business information and relevant technical and business topics.

The Internet service may not be used for transmitting, retrieving or storing any communications of a discriminatory or harassing nature or which are derogatory to any individual or group, obscene or pornographic, or defamatory or threatening in nature for “chain letters” or any other purpose which is illegal or for personal gain.

User Classification

All users are expected to have knowledge of these security policies and are required to report violations to the Security Administrator. Furthermore, all users must conform to the Acceptable Use Policy defined in this document. The company has established the following user groups and defined the access privileges and responsibilities:

User Category	Privileges & Responsibilities
Department Users (Employees)	Access to application and databases as required for job function. (RED and/or GREEN cleared)
System Administrators	Access to computer systems, routers, hubs, and other infrastructure technology required for job function. Access to confidential information on a “need to know” basis only.
Security Administrator	Highest level of security clearance. Allowed access to all computer systems, databases, firewalls, and network devices as required for job function.
Systems Analyst/Programmer	Access to applications and databases as required for specific job function. Not authorized to access routers, firewalls, or other network devices.
Contractors/Consultants	Access to applications and databases as required for specific job functions. Access to routers and firewall only if required for job function. Knowledge of security policies. Access to company information and systems must be approved in writing by the company director/CEO.
Other Agencies and Business Partners	Access allowed to selected applications only when contract or inter-agency access agreement is in place or required by applicable laws.
General Public	Access is limited to applications running on public Web servers. The general public will not be allowed to access confidential information.

Monitoring Use of Computer Systems

The company has the right and capability to monitor electronic information created and/or communicated by persons using company computer systems and networks, including e-mail messages and usage of the Internet. It is not the company policy or intent to continuously monitor all computer usage by employees or other users of the company computer systems and network. However, users of the systems should be aware that the company may monitor usage, including, but not limited to, patterns of usage of the Internet (e.g. site accessed, on-line length, time of day access), and employees’ electronic files and messages to

the extent necessary to ensure that the Internet and other electronic communications are being used in compliance with the law and with company policy.

Access Control

A fundamental component of our Cyber Security Policy is controlling access to the critical information resources that require protection from unauthorized disclosure or modification. The fundamental meaning of access control is that permissions are assigned to individuals or systems that are authorized to access specific resources. Access controls exist at various layers of the system, including the network. Access control is implemented by logon ID and password. At the application and database level, other access control methods can be implemented to further restrict access. The application and database systems can limit the number of applications and databases available to users based on their job requirements.

User System and Network Access – Normal User Identification

All users will be required to have a unique logon ID and password for access to systems. The user's password should be kept confidential and MUST NOT be shared with management & supervisory personnel and/or any other employee whatsoever. All users must comply with the following rules regarding the creation and maintenance of passwords:

- Password must not be found in any English or foreign dictionary. That is, do not use any common name, noun, verb, adverb, or adjective. These can be easily cracked using standard "hacker tools".
- Passwords should not be posted on or near computer terminals or otherwise be readily accessible in the area of the terminal.
- Password must be changed every (# of days).
- User accounts will be frozen after (# of days) failed logon attempts.
- Logon IDs and passwords will be suspended after (# of days) days without use.

Users are not allowed to access password files on any network infrastructure component. Password files on servers will be monitored for access by unauthorized users. Copying, reading, deleting or modifying a password file on any computer system is prohibited.

Users will not be allowed to logon as a System Administrator. Users who need this level of access to production systems must request a Special Access account as outlined elsewhere in this document.

Employee Logon IDs and passwords will be deactivated as soon as possible if the employee is terminated, fired, suspended, placed on leave, or otherwise leaves the employment of the company office.

Supervisors / Managers shall immediately and directly contact the company IT Manager to report change in employee status that requires terminating or modifying employee logon access privileges.

Employees who forget their password must call the IT department to get a new password assigned to their account. The employee must identify himself/herself by (e.g. employee number) to the IT department.

Employees will be responsible for all transactions occurring during Logon sessions initiated by use of the employee's password and ID. Employees shall not logon to a computer and then allow another individual to use the computer or otherwise share access to the computer systems.

System Administrator Access

System Administrators, network administrators, and security administrators will have (type of access) access to host systems, routers, hubs, and firewalls as required to fulfill the duties of their job.

All system administrator passwords will be **DELETED** immediately after any employee who has access to such passwords is terminated, fired, or otherwise leaves the employment of the company.

Special Access

Special access accounts are provided to individuals requiring temporary system administrator privileges in order to perform their job. These accounts are monitored by the company and require the permission of the user's company IT Manager. Monitoring of the special access accounts is done by entering the users into a specific area and periodically generating reports to management. The reports will show who currently has a special access account, for what reason, and when it will expire. Special accounts will expire in (X # of) days and will not be automatically renewed without written permission.

Connecting to Third-Party Networks

This policy is established to ensure a secure method of connectivity provided between the company and all third-party companies and other entities required to electronically exchange information with company.

"Third-party" refers to vendors, consultants and business partners doing business with company, and other partners that have a need to exchange information with the company. Third-party network connections are to be used only by the employees of the third-party, only for the business purposes of the company. The third-party company will ensure that only authorized users will be allowed to access information on the company network. The third-party will not allow Internet traffic or other private network traffic to flow into the network. A third-party network connection is defined as one of the following connectivity options:

- A network connection will terminate on a (to be specified) and the third-party will be subject to standard company authentication rules.

This policy applies to all third-party connection requests and any existing third-party connections. In cases where the existing third-party network connections do not meet the requirements outlined in this document, they will be re-designed as needed.

All requests for third-party connections must be made by submitting a written request and be approved by the company.

Connecting Devices to the Network

Only authorized devices may be connected to the company network(s). Authorized devices include PCs and workstations owned by company that comply with the configuration guidelines of the company. Other authorized devices include network infrastructure devices used for network management and monitoring.

Users shall not attach to the network: non-company computers that are not authorized, owned and/or controlled by company. Users are specifically prohibited from attaching (specify) to the company network.

NOTE: Users are not authorized to attach any device that would alter the topology characteristics of the Network or any unauthorized storage devices, e.g. thumb drives and writable CD's.

Remote Access

Only authorized persons may remotely access the company network. Remote access is provided to those employees, contractors and business partners of the company that have a legitimate business need to exchange information, copy files or programs, or access computer applications. Authorized connection can be remote PC to the network or a remote network to company network connection. The only acceptable method of remotely connecting into the internal network is using a secure ID.

Unauthorized Remote Access

The attachment of (e.g. hubs) to a user's PC or workstation that is connected to the company LAN is not allowed without the written permission of the company. Additionally, users may not install personal software designed to provide remote control of the PC or workstation. This type of remote access bypasses the authorized highly secure methods of remote access and poses a threat to the security of the entire network.

Penalty for Security Violation

The company takes the issue of security seriously. Those people who use the technology and information resources of company must be aware that they can be disciplined if they violate this policy. **Upon violation of this policy, an employee of company may be subject to discipline up to and including discharge.** The specific discipline imposed will be determined by a case-by-case basis, taking into consideration the nature and severity of the violation of the Cyber Security Policy, prior violations of the policy committed by the individual, state and federal laws and all other relevant information. Discipline which may be taken against an employee shall be administrated in accordance with any appropriate rules or policies and the company Policy Manual.

In a case where the accused person is not an employee of company the matter shall be submitted to the (company designee). The (company designee) may refer the information to law enforcement agencies and/or prosecutors for consideration as to whether criminal charges should be filed against the alleged violator(s).

Security Incident Handling Procedures

This section provides some policy guidelines and procedures for handling security incidents. The term "security incident" is defined as any irregular or adverse event that threatens the security, integrity, or availability of the information resources on any part of the company network. Some examples of security incidents are:

- Illegal access of a company computer system. For example, a hacker logs onto a production server and copies the password file.
- Damage to a company computer system or network caused by illegal access. Releasing a virus or worm would be an example.
- Denial of service attack against a company web server. For example, a hacker initiates a flood of packets against a Web server designed to cause the system to crash.
- Malicious use of system resources to launch an attack against other computer outside of the company network. For example, the system administrator notices a connection to an unknown network and a strange process accumulating a lot of server time.

Employees, who believe their terminal or computer systems have been subjected to a security incident, or has otherwise been improperly accessed or used, should report the situation to their (company designee) immediately. The employee shall not turn off the computer or delete suspicious files. Leaving the

computer in the condition it was in when the security incident was discovered will assist in identifying the source of the problem and in determining the steps that should be taken to remedy the problem.

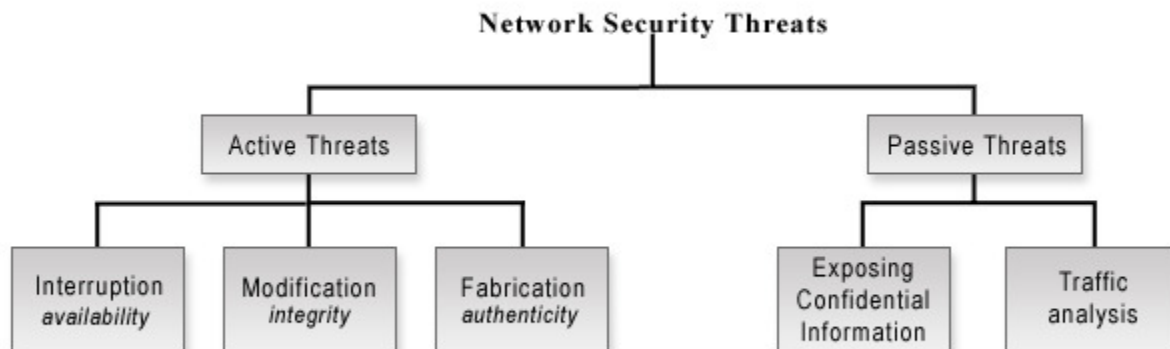
Overview of Security Management:

Security is concerned with ensuring legitimate use, maintaining confidentiality, data integrity, and auditing in the network. Security Management involves identifying the assets, threats, vulnerabilities, and taking protective measures, which if not done may lead to unintended use of computing systems.

Network management applications are increasing in size and complexity to address a broad segment of heterogeneous computing environments. The complexity of network infrastructure demands a highly scalable application providing end-to-end solution that goes beyond the basic network management needs. With these, the following are the three important aspects of information security that are to be taken care from the security service point of view:

- **Security Attack** - Any action that comprises the security information owned by an organization.
- **Security Mechanism** - A mechanism that is designed to detect, prevent, or recover from a security attack.
- **Security Service** - A service that enhances the security of the data processing systems and the information transfers in the network.

Thus, the services are intended to counter security attacks, and they make use of one or more security mechanisms to provide the service. In general, Security threats can be classified as shown below :



What does Security Services Offer ?

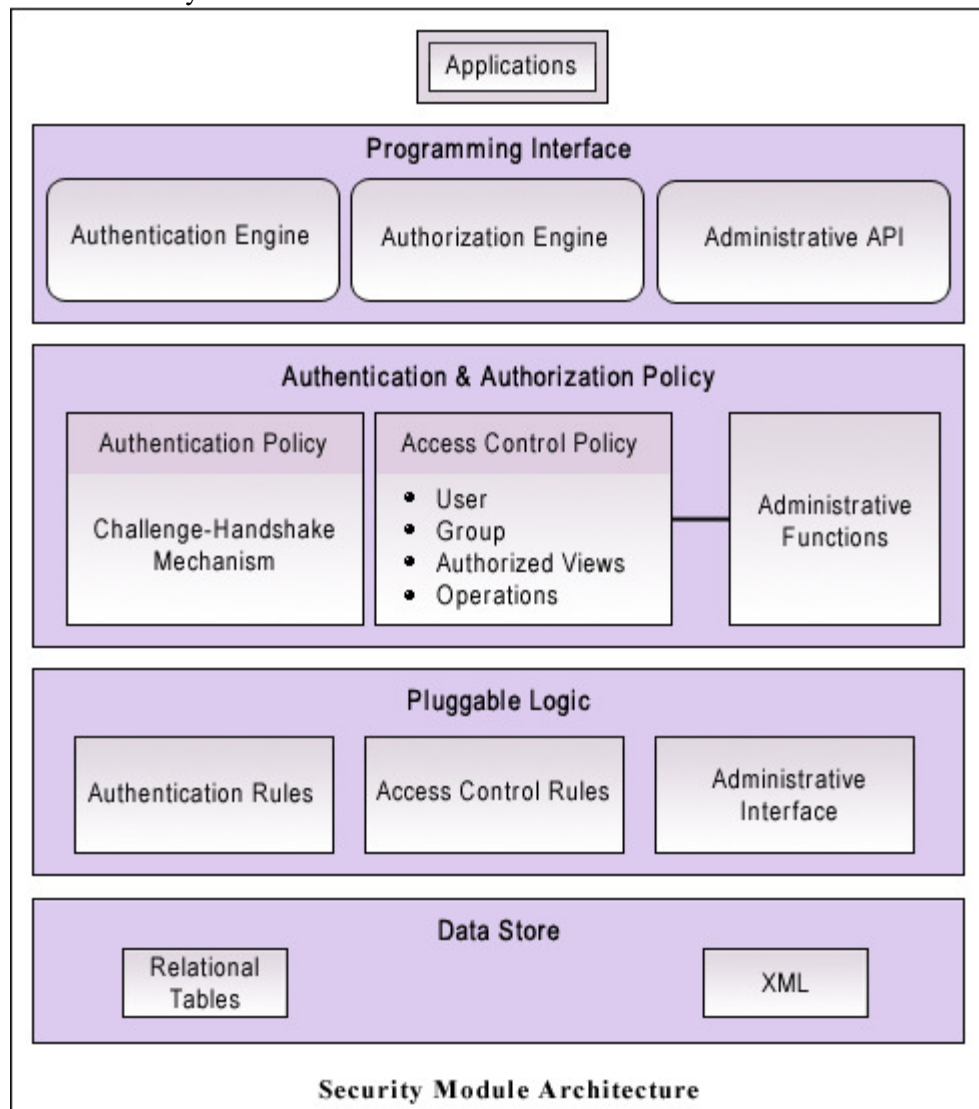
WebNMS provides Security Management as an out-of-the-box service, designed with the above objectives in mind. Since the security logic is completely separate from the management application's business logic, the Web NMS platform provides an environment where other applications can seamlessly integrate into the platform to utilize the security services.

Components of Security Framework

Security Module provides a framework that consists of the following :

- Authentication
- Access Control
- AuthorizationAdmin
- Cryptography
- Audit

- Pluggable Logic
- Security Data Store



The other management services such as Configuration, Provisioning, Data Collection, Event Correlation, etc. use the security services as part of their functions.

Authentication Policy

With the applications built on the Web NMS platform being user centric, the authentication mechanism is used to verify the credentials before allowing access to the platform. Authentication Policy provided includes a Challenge-Handshake mechanism where the credentials of the user is verified using a 3-way handshake. The passwords are never sent across to the authentication module; rather a one-way-hash (called key) is used. This provides protection against playback attack using an incrementally changing identifier and a variable challenge value.

Access Control

The applications built with Web NMS platform model their own object based on the entity they deal with. Support for user-groups provides a mechanism to collectively associate access rights to a set of users.

Also, it is not sufficient to just tie up the access rights of a user with the operation performed. Hence, it becomes necessary to have a framework where the permissions are associated with the subsets of objects concerned with the application. This in turn gives a fine-grained access control.

The Authorization policy is designed with "Fine-Grained Access Control" as the focus. With vast number of users using the application, it becomes necessary that each one works within the allowed space. Considering the complexity of applications, the Access Control Policy should have the flexibility to define access rights of a user to operate on subset of objects that the applications work with. WebNMS Security Service achieves this by defining a set of Authorized Views called Scopes. These Authorized Scopes consists of set of properties associated with the user operations. Thus, managed object properties such as network, Ip address, node, type etc can be used in authorized views to control the access of the users to a specific type of devices within a given Ip range in a specified network alone.

AuthorizationAdmin

Once the authorization level is well defined then assigning operations and achieving the respective fine-grained access becomes simple with the available set of security oriented administrative functions. The AuthorizationAdmin module takes care of security administrative operations like maintaining user profile, associating views with groups, setting permissions to perform operations, adding new operations, and there by defining scopes for custom view.

Cryptography

To maintain a secured channel in network communication and to secure the storage of sensitive information like passwords it becomes necessary to adopt a mechanism, which is secured by itself, and withstand the security attacks. Keeping these objectives in mind WebNMS Security Management supports cryptogram support to ensure a secured data communication. This is achieved with the help of RSA Data Security Algorithm for cryptography. Here the original message (plain text) is encrypted with a public key and in the receiver end the encrypted plain text also called as cipher text is decrypted with the private key that is only known by the receiver alone and thus ensuring a foolproof communication mechanism.

Audit

In this world of inter networking where hundreds and thousands of users access the network, it becomes essential to audit the details of network users activities. This in turn provides an Intrusion Detection Control mechanism where the user operations need to be logged in as per convenience. This aspect of security service is very well taken care by the Audit Service, where the user as well as the network manager can view and have the copy of the audit trails of the NMS users, including the time and status of operation performed by the users. This enables the network administrator to take necessary steps when an unauthorized execution is attempted by any user.

Pluggable Logic

The rules for authentication and authorization can easily be extended/modified. As security requirements of the application can change, it is important that the authorization rules be extendable. The rules could be related with the logic used in verifying permissions when multiple groups and scopes are involved. The associated permission can be extended to allow or disallow access based on the applications needs. Thus the user can write his own implementation class for the authentication and authorization services and make it pluggable to suit his own environment.

Security Data Store

The Web NMS platform can be deployed in various environments. It becomes necessary to support different data store for storing the security information, depending on the requirements. Security module provides the ability to plug in the security service with existing/any other data store. This adds to the various deployment options available with WebNMS platform. Different data store like Relational Database, XML, LDAP, NDS etc can be integrated seamlessly. Security Module provides Administrative

interfaces to configure the data store. The administrative functions are based on the authentication and authorization policy.

WebNMS being a highly customizable product comes with a rich set of APIs to overlook the security tasks.

Security Policies

This page provides a list of computer security policies that may help organizations define their enterprise security controls. Set security policies must be communicated, enforced, and audited to be effective. Security policies may include:

1. Password policy * - Defines minimum and maximum length of passwords, password complexity, how often it must be changed.
2. Network login policy - May be defined by the password policy. Defines how many bad login attempts over what specific amount of time will cause an account to be locked. This may be included in the password policy.
3. Remote access policy * - Specifies how remote users can connect to the main organizational network and the requirements for each of their systems before they are allowed to connect. This will specify the anti-virus program remote users must use, how often it must be updated, what personal firewalls they are required to run, and other protection against spyware or other malware. Also defines how users can connect remotely such as dial up or VPN. It will specify how the dial up will work such as whether the system will call the remote user back, and the authentication method. If using VPN, the VPN protocols used will be defined. Methods to deal with attacks should be considered in the design of the VPN system.
4. Internet connection policy * - Specifies how users are allowed to connect to the internet and provides for IT department approval of all connections to the internet or other private network. Requires all connections such as connections by modems or wireless media to a private network or the internet be approved by the IT department and what is typically required for approval such as the operation of a firewall to protect the connection. Also defines how the network will be protected to prevent users from going to malicious web sites. Defines whether user activity on the network will be logged and to what extent. Specifies what system will be used to prevent unauthorized viewing of sites and what system will log internet usage activity. Defines whether a proxy server will be used for user internet access.
5. Approved Application policy * - Defines applications which are approved to operate on computer systems inside or connected to the organizational network.
6. Asset control policy * - Defines how assets such as computers are tracked. This policy will allow the locations and users of all assets to be tracked. This policy will define a property move procedure. This policy will define what must be done when a piece of property is moved from one building to another or one location to another. It will define who signs off on the movement of the property. This will allow the database to be updated so the location of all computer equipment is known. This policy will help network administrators protect the network since they will know what user and computer is at what station in the case of a worm infecting the network. This policy must also cover the fact that data on the computer being moved between secure facilities may be sensitive and must be encrypted during the move.
7. Equipment and media disposal policy - May be incorporated into the asset control policy. Ensures that electronic equipment or media to be disposed of does not contain any kind of harmful data that may be accessible by third parties.
8. Media use and re-use policy - May be incorporated into the asset control policy. Defines the types of data that may be stored on removable media and whether that media may be removed from a physically secure facility and under what conditions it would be permitted.
9. Mobile computer policy * - Defines the network security requirements for all mobile computers which will be used on the network, who is allowed to own them, what firewall they must run, what programs may be run on them, how the system will be protected

- against malware, how often the system must be updated, and more. Also defines what data may be stored on them and whether the data must be encrypted in case of theft.
10. -Computer Training policy - This policy defines the minimum training for users on the network to make them aware of basic computer threats to protect both themselves and the network. This policy especially applies to employees with access to sensitive or regulated data.
 11. IT Resource acceptable use policy - Defines how users may use IT computer resources. Available at:
http://www.sans.org/resources/policies/Acceptable_Use_Policy.pdf
http://www.sans.org/resources/policies/Acceptable_Use_Policy.doc
 12. Wireless Use Policy * - Defines whether wireless will be used on the network, what protocols can be used, and how it will be kept secure from unauthorized access including allowing only specific computers to connect.
 13. Information security policy available at
http://www.sans.org/resources/policies/Information_Sensitivity_Policy.pdf
http://www.sans.org/resources/policies/Information_Sensitivity_Policy.doc
<http://www.sans.org/resources/policies/>
 14. Anti-virus and malware policy * (data protection plan) - Defines anti-virus policy on every computer including how often a virus scan is done, how often updates are done. Defines what programs will be used to detect, prevent, and remove malware programs. It may define what types of files attachments are blocked at the mail server and what anti-virus program will be run on the mail server. It may specify whether an anti-spam firewall will be used to provide additional protection to the mail server. It may also specify how files can enter the trusted network and how these files will be checked for hostile or unwanted content. For example it may specify that files sent to the enterprise from outside the trusted network be scanned for viruses by a specific program.
 15. System update policy * - How often systems and applications are checked for security updates and whose responsibility it is to do them. How the updates for client computers and servers will be done. Will an update service be used?
 16. User privilege policy * - Defines what privileges various users are allowed to have, specifically defining what groups of users have privileges to install computer programs on their or other systems. Defines the users who have access to and control of sensitive or regulated data. Also may define internet access to specific sites for some users or other ways they may or may not use their computer systems.
 17. - Application implementation policy - Defines how major computer to computer applications will be implemented on the network to protect both the data used in the application and the rest of the computer network. Defines who will be involved, and who will sign off on the project plan.
 18. - System lockdown policy (baseline host/device security) - Defines what kind of lockdown process will be used on what types of systems. May include:
 1. Services not to be installed or run due to excessive vulnerability such as Windows messenger or Windows File and Print Sharing.
 2. Recommendation to limit the number of services run on a server.
 3. Recommendation to operate host intrusion detection on all servers or specific high risk or high impact servers.
 4. Policy to make it difficult for an attacker to access password files on any system.
 19. - Server Monitoring Policy - Provides for monitoring servers for file space and performance issues to prevent system failure or loss of service.
 20. - IT Equipment Purchase and Failure Prevention Policy - Defines technologies to be used in specific areas of functionality to reduce the chance of any serious disruption of service.

21. Incident response plan * - Defines the response to a security incident such as a virus, network intrusion, abuse of a computer system or other situations.
22. - Intrusion detection policy - Defines what devices will be used on the network to detect any suspicious activity or intrusion. Defines what should be logged and the details of the logs.

Additional Policies and security areas to cover include:

1. Emergency Contact Plan - Provides an emergency contact plan defining where emergency contact information is stored, the people to contact based on the emergency type, and how employees will learn about closings.
2. Tracking of applications and operating systems for licensing purposes.
3. - File backup and restore policy - Defines what computers, equipment, and software will be used to perform file backups and what files and systems will be backed up by which devices.
4. Disaster recovery * - Ensures that data won't be lost.
5. Network documentation policy * - Defines the level of network documentation required such as documentation of which switch ports connect to what rooms and computers. Defines who will have access to read it and who will have access to change it. Defines where documentation will be stored.
6. Server documentation policy * - Defines the level of server documentation required such as documentation of server services and configuration. Defines who will have access to read it and who will have access to change it. Defines where documentation will be stored.
7. - Network Scanning Policy - Describes what type of network scanning that can be done, who is allowed to perform network scans, and under what conditions. May specify what procedure will be followed when performing different types of network scans. The procedure or policy may define who is to be notified when network scans are done and for which type of scans they will be notified.
8. - Network Risk evaluation - Evaluate threats to the network to determine where to improve defences.
9. Computer and printer naming policy
10. IP address assignment policy - Defines how IP addresses are assigned, who assigns them, how IP use is tracked, the file IP information is stored in, and who has the ability to read or change the file.
11. Physical Security
12. Diligence in hiring employees
13. Perimeter security - How maintained. Who is responsible for it? How changes to perimeter security devices are managed? How changes are requested and approved. Who has access to perimeter devices.
14. Information protection - Provides guidelines to users and administrators about the storage, transmission, and protection of sensitive information. Defines information sensitivity levels. Goal to ensure information is protected properly. Defines who has access to information. Defines how to store and transmit sensitive information at various levels. Defines what systems sensitive information can be stored on. Where information can be printed. Removal of sensitive information, scrub hard drive, shred paper, degaussing.

Other Security Concerns

1. Automatic logoff of inactive sessions after some period of time.
2. Logging and audit controls - Must log activity in systems with sensitive information

Risk Management:

Introduction

Risk Management is simply to look at what could go wrong - and then decide on ways to prevent - or minimize - these potential problems. It encompasses three processes – risk assessment, risk mitigation and evaluation.

We all carry out informal risk management numerous times in the course of a day without even realizing it. Every time we cross a street, we stop to weigh the risk of rushing in front of oncoming traffic, waiting for the light to change, using the crosswalk, etc. Our ability to analyze the consequences of each decision is risk assessment. What we decide to do after performing that quick analysis is risk mitigation based on proper early training and our experience of crossing a road. We may decide to wait for the traffic light and use the cross walk which greatly reduces the potential risk, we may follow someone else across the street allowing them to make the decision for us, or we may simply choose not to cross the street. These decisions are a result of our risk assessment of the situation. If you make it across the street you remember what worked. If anything went wrong such as a honked horn or brakes squealing, you should evaluate if another choice would have been better.

Below are important definitions for terms that are used in this Guide.

Risk: The probability of suffering harm or loss. It refers to an action, event or a natural occurrence that could cause an undesirable outcome, resulting in a negative impact or consequence.

Risk Assessment: The process of identifying *threats* to *information* or *information systems*, determining the likelihood of occurrence of the *threat*, and identifying *system vulnerabilities* that could be exploited by the *threat*.

Risk Management: The process of taking actions to assess *risks* and avoid or reduce *risk* to acceptable levels.

As a manager the issues of risk assessment may seem difficult and the right decisions for risk management challenging; but the principles remain the same. It is your responsibility to make the best decision based on the information at hand. A well-structured risk management methodology, when used effectively, can help.

The Steps in Risk Management are

1. Risk Assessment

- A. Classify information
- B. Identify threats
- C. Identify vulnerabilities
- D. Analyze risk to information assets
- E. Summarize and communicate risk

2. Risk Mitigation

- A. Identify options
- B. Choose an option
- C. Implement
 - Accept the risk
 - Transfer the risk
 - Limit the risk: put control in place
 - Avoid the risk

3. Evaluation

Small businesses and agencies maintain information that is confidential and integral to the operation of their organization. Information is any representation of facts, concepts or instructions created, stored (in temporary or permanent form), filed, produced or reproduced, regardless of the form or media. This may include, but is not limited to the *data* contained in reports, files, folders, memoranda, statements, examinations, transcripts, images, and communications whether electronic or hard copy. For example, a computer in a business office may contain client social security numbers, financial records, health records and other personal, private, or sensitive information (PPSI).

An employee's decision to leave his computer unprotected for even a short time opens the risk to unauthorized physical access. Or, the organization's decision not to have a firewall or antivirus software installed to protect it leaves the computer at risk to someone who gains unauthorized access through the

Internet. The management of these risks may be as simple as requiring employees to lock the computer every time they step away, installing anti virus, or the installation of firewalls.

1. Risk Assessment

Risk assessment is the first phase in the risk management process. Risk is assessed by identifying threats and vulnerabilities, and then determining the likelihood and impact for each risk.

It is important to designate an individual or a team, who understands the organization's mission, to periodically assess and manage information security risk. The designated individual will work with others from the organization to understand the business program component of information assets, the technology involved, and the impact as well as the costs of managing the risk.

1a. Classify Information

Before an organization can assess the risk it must first classify the information assets in the organization. Classification is the designation given to information from a defined category on the basis of its sensitivity. Information assets include all categories of *information* (automated and non-automated), including (but not limited to) *data* contained in records, files, and databases. Information assets usually include: public records mission-critical systems, customer interfaces, internal tools, source code, and confidential records. The organization is responsible for protecting the confidentiality, integrity and availability of the information assets. The value of an asset will be determined by the information owner - an individual or a group of individuals responsible for making classification and control decisions regarding use of information, especially PPSI.

An information asset can mean many different things depending on what the organization is trying to accomplish; therefore, it is important to identify each information asset. Information may be stored onsite or offsite, on hard drives, CDs and tapes. It is best to create a list of all information assets and classify each asset (e.g., confidential, restricted, public information). The classification of the information should be included on the information itself and on a central list. Policies and procedures regarding the classification of documents should be in place so all employees are aware and educated about them. A reference for information classification and control can be found in the references section at the end of this document.

1b. Identify Threats

A threat is a force, organization or person, which seeks to gain access to, or compromise, *information*. By looking at the nature of the *threat*, its capability and resources, one can assess it, and then determine the likelihood of occurrence, as in *risk assessment*. A *threat* can be assessed in terms of the probability of an attack.

There are many types of information security threats, some examples are listed below:

- Internal (e.g., malicious or unaware employees);
- Mobile (e.g., attackers who steal remote systems which, in turn, provide access to information);
- Physical (e.g., attackers who steal computers or enter server rooms, file cabinets, or offices);
- Natural (e.g., fire, floods, and earthquakes resulting in electrical outages, equipment and hardware failures);
- Network (e.g., attackers who try to compromise systems exposed on a public network or try to spoof or imitate remote systems);
- Social (e.g., attackers who try to fool employees into revealing information through phishing);
- Malicious (e.g., viruses, worms, and Trojan horses, code that may damage, reveal, or capture information).

It is important to be aware of threats to your organization's information in order to prevent compromise to that information's confidentiality, integrity and availability. Information security threats must be identified at as many levels as possible.

1c. Identify Vulnerabilities

Vulnerabilities must be identified. Vulnerabilities are weaknesses, in a *system* or facility holding *information*, which can be exploited to gain access or violate *system integrity*. *Vulnerabilities* can be assessed in terms of the means by which the attack would be successful, such as,

- Tapes lost during transfer to a storage facility (availability issue).
- Information read by an unauthorized individual(s) (confidentiality issue).
- Software and hardware not maintained at current patch levels allow unauthorized access via the Internet resulting in a breach of confidential information (confidentiality, integrity and/or availability issues).
- Unintentional loss of data via theft resulting in identity theft (confidentiality issue).
- Accidental or intentional deletion or modification of information (availability and integrity issues).
- Unsecured computers and portable devices such as blackberries, laptops, or USB devices (confidentiality, integrity and availability issues).

1d. Analyze Risk to Information Assets

There are inherent risks involved in containing and transferring information. Information is subject to intentional and unintentional actions by other people or systems. If information is confidential, there may be unauthorized people who want to see it, such as competitors or disgruntled or curious employees. People may try to break into the devices containing the information or try to intercept the information during transfer. People may also receive confidential information unknowingly and completely by accident. Furthermore, information systems can be maliciously or accidentally damaged. Information security breaches like these can seriously hurt an organization.

Risk for a given asset can be provided in the most general form using the following equation:

$\text{Risk} = (\text{Probability of a threat occurring against an asset}) \times (\text{Value of asset})$

In other words, the higher the likelihood of a threat occurring and affecting an asset and the higher the value of that asset, the higher the risk. If a threat has little or no chance of occurring, or if the asset has no value, the risk is either very low or zero. Since information assets within an organization most likely hold some level of value, risk management will involve reducing the likelihood of threats from occurring².

1e. Select a Method

In order to quantify risk in some fashion, an organization will need to develop a method of measuring risk so that this information can be communicated with others. There are many methodologies to pick from; each organization will need to determine which is best. Ultimately, the organization will need to understand its information security risks.

1f. Summarize and Communicate Risk

Risk has to be measured for each information asset, and for the organization as a whole, and then communicated so decisions can be made to manage the risk.

2. Risk Mitigation

Risk Mitigation is the process of taking actions to eliminate or reduce the probability of compromising the confidentiality, integrity, and availability of valued information assets to acceptable levels. There are three steps to risk mitigation: identify, choose and implement options.

2a. Identify Options

It is up to the organization to mitigate risks so that assets are protected. Once the risk to information assets has been measured, a decision must be made about how to mitigate that risk. There are four options available for mitigating risk:

1. *pt* the risk
2. *sfer* the risk
3. *t* the risk
4. *d* the risk

Accept the Risk

An organization may choose to simply accept risk under these scenarios:

- The risk is considered low (e.g., the value of an asset is low and the probability of threats affecting the asset are acceptable).
- The cost of accepting the risk is found to be lower than the cost of transferring or limiting the risk.

If the cost of accepting the risk is high or more than the cost of transfer or limiting it, then the organization should not accept the risk. The organization should then look at transferring or limiting the risk³.

Transfer the Risk

When the risk is transferred, the risk is shared with a third party in part or in whole. This is typically seen in the use of insurance. Third party insurance organizations, for a fee, agree to accept the risk and compensate the information owner for the full damage of a particular risk⁴. This is appropriate for hardware or when the recoup value is received if the asset is destroyed or where an organization wants to limit liability. In some cases, transferring risk may not be available. In other cases, the risk may be too high and too costly to insure.

An everyday example of transferring risk is with car insurance. Through the use of insurance, the car owner is transferring the risk of vehicle loss due to an accident to the insurance company.

Another example can be seen with third party web site hosting. If an organization utilizes a third party vendor to host their website they are transferring some of the risk to the vendor. The vendor is responsible for the availability and integrity of the information supplied by the organization to be posted. Vendor contracts and agreements should list the roles and responsibilities of the vendor.

Limit the Risk

When a risk is high for a particular asset, and the risk cannot be transferred (i.e., not practical or cost-effective), then the risk should be limited in part or in full. The process includes identifying the most probable threats to a given asset and identifying, researching, or developing an acceptable control to that threat.

In the case of limiting risks such as a virus infection, spam and unauthorized Internet access, the organization may decide to order the purchase of software for all computer devices to reduce the impact of those risks. Limiting risk will mean controlling access to the network, by installing antivirus, spamware and a firewall where none exists. Training employees, interns and contractors to be aware of information security will also help reduce the risks.

In some cases, limiting the risk can be fast, inexpensive and sometimes free. Information systems suppliers may provide free security patches and may even provide mechanisms that perform automatic updates to these systems. Applying security updates or bug fixes may simply involve the time and skills of the internal staff. Keeping software updated is a critical defense to recently discovered vulnerabilities.

In other cases, limiting risk can be very expensive. For example, if buildings housing computers that contain vital information are at risk to natural disasters, the organization may have to consider moving to a different location or providing redundancy by adding buildings.

There may be different levels of controls that can be applied to one threat that may only reduce the risk to an acceptable level to the organization. There may be certain aspects of a threat that can be reduced by implementing controls and some other aspects that may be covered by transferring the risk. Taking the example of the development of a new building – costs may be incurred to purchase new, redundant hardware while insurance may be purchased to cover the building itself. When processes are identified to incorporate threats, this may involve restructuring the process and re-training the people involved⁵.

Avoid the Risk

Risk avoidance is natural for some of us; but for others risk taking is part of the thrill of life. When it comes to your responsibility as a manager you have to know when it is appropriate to avoid the risk altogether. There is no universal answer to when risk avoidance will be appropriate because every circumstance is different. Risk avoidance may be used to protect those assets which are at high risk. Some examples of this option include:

- ding a facility outside a flood zone
- ping computers systems with confidential information or PPSI on them disconnected from the Internet

2b. Choose an Option

Once the organization has identified the various options for mitigating risk, one must be selected. The team or individual designated to handle risk management will need to work with the appropriate individuals and make a recommendation to management. Keep in mind the decision will need to be reviewed whenever the information asset changes since the classification of the information asset may change or the threats and risks change.

2c. Implement the Option

Implementing the option involves putting into action the choice that has been made for mitigating the risk. As previously defined, the possible actions are to accept the risk, transfer the risk, limit the risk, or avoid the risk. Each information asset now has an assigned risk and the option for mitigating the risk has been chosen. Implementing the chosen option will result in certain procedures being followed and/or new controls put in place. Limiting the risk by putting a control in place will be the most commonly chosen option to protect your information assets and systems. Continual monitoring and regular updating is part of the implementation to keep the risk at an acceptable level.

Consider for example, the organization's operating system. Vulnerabilities are continually being discovered and exploited in operating systems. You can limit the risk by performing updates to patch your system. You can accomplish this by scheduling automatic updates. Additionally, most application software currently marketed has some mechanism to keep it updated to current levels. These updates are primarily distributed for security and functionality.

Antivirus software is another way to limit the risk to your computer and information assets. It is one thing to install the antivirus software but to continually limit the risk to your machine you must maintain the software and update it frequently. This would involve the purchase of a subscription to the service to receive daily updates, scheduling the daily updates, and the scheduling of frequent and regular scans of your computer.

3. *Evaluation*

A designated team or individual should follow through to ensure that the option chosen to mitigate the risk for each identified information asset has been implemented. At a minimum, an annual review must also be performed to ensure that the controls put in place are still functional and viable to protect a given information asset.

A technical security review would consist of reviewing the *controls* built into a system or application to ensure they still perform as designed and are in compliance with documented security policies and

procedures. It would also include reviewing security patches to ensure they have been installed and are operational, reviewing security rules such as access control lists for currency, testing of firewall rules, etc. This type of testing includes intrusion and/or penetration testing of controls.

The evaluation step in the Risk Management process consists of two components

The review itself and recording of the review.

3a. Review and Record

After implementation, you must evaluate what was done through the classifying the assets, selecting an option and implementing the actions taken. It is time to record and document lessons learned. A group should be organized including the original team to discuss and evaluate the process and document any issues and lessons learned.

3b. Tools to Help with the Process

Also important is the use of tools, auditing, and policies. Tools such as dedicated risk management systems can be used to assess risk. Some tools can also help limit risk for the long term. Auditing allows the organization over time to identify the possible threats and risks and implement future risk assessment and management. Policies enable an organization to define how to prevent the exploitation of information assets and discipline those people who compromise the information. Policies, whether procedural-based or system based, should be used to minimize risk.

What are Policies, Standards, Guidelines and Procedures?

Posted by [PJ](#) on 2/03/09 • Categorized as [Policy & Compliance](#)



What are Policies, Standards, Guidelines and Procedures?

In order to protect information, businesses need to implement rules and controls around the protection of information and the systems that store and process this information. This is commonly achieved through the implementation of information security policies, standards, guidelines and procedures. However, what exactly are these? This article will explain what information security policies, standards, guidelines and procedures are, the differences between each and how they fit together to form an information security policy framework.

Policies

An information security policy consists of **high level statements** relating to the protection of information across the business and should be produced by senior management.

The policy outlines security roles and responsibilities, defines the scope of information to be protected, and provides a high level description of the controls that must be in place to protect information. In addition, it should make references to the standards and guidelines that support it. Businesses may have a single encompassing policy, or several specific policies that target different areas, such as an email policy or acceptable use policy. From a legal and compliance perspective, an information security policy is often viewed as a commitment from senior management to protect information. A documented policy is frequently a requirement to satisfy regulations or laws, such as those relating to privacy and finance. It should be viewed as a business mandate and must be driven from the top (i.e. senior management) downwards in order to be effective.

Standards

Standards consist of specific **low level mandatory controls** that help enforce and support the information security policy.

Standards help to ensure security consistency across the business and usually contain security controls relating to the implementation of specific technology, hardware or software. For example, a password standard may set out rules for password complexity and a Windows standard may set out the rules for hardening Windows clients.

Guidelines

Guidelines consist of **recommended, non-mandatory controls** that help support standards or serve as a reference when no applicable standard is in place.

Guidelines should be viewed as best practices that are not usually requirements, but are strongly recommended. They could consist of additional recommended controls that support a standard, or help fill in the gaps where no specific standard applies. For example, a standard may require passwords to be 8 characters or more and a supporting guideline may state that it is best practice to also ensure the password expires after 30 days. In another example, a standard may require specific technical controls for accessing the internet securely and a separate guideline may outline the best practices for using the internet and managing your online presence.

Procedures

Procedures consist of **step by step instructions** to assist workers in implementing the various policies, standards and guidelines.

Whilst the policies, standards and guidelines consist of the controls that should be in place, a procedure gets down to specifics, explaining how to implement these controls in a step by step fashion. For example, a procedure could be written to explain how to install Windows securely, detailing each step that needs to be taken to harden/secure the operating system so that it satisfies the applicable policy, standards and guidelines.

The Information Security Policy Framework

Each document listed above has a different target audience within the business and therefore, should never be combined into one document. Instead there should be several documents, that together form the

concept of an information security policy framework. This framework is illustrated in the diagram above, with each level of the framework supporting the levels above it.

In order to help cement this concept, let's use an example to illustrate how all of these different framework pieces fit together.

- A *policy* may state all business information must be adequately protected when being transferred.
- A supporting data transfer *standard* builds upon this, requiring that all sensitive information be encrypted using a specific encryption type and that all transfers are logged.
- A supporting *guideline* explains the best practices for recording sensitive data transfers and provides templates for the logging of these transfers.
- A *procedure* provides step by step instructions for performing encrypted data transfers and ensures compliance with the associated policy, standards and guidelines.

BCP vs DRP

Business Continuity Plan versus Disaster Recovery Plan

When people start on the journey to develop plans to deal with a major event they are confronted by two different terms - Business Continuity Plan and Disaster Recovery Plan. There is quite a difference between these two plans and it is important that an organisation clearly understands what sort of planning it requires.



Business Continuity Plan (BCP)

Business Continuity Planning is best described as the processes and procedures that are carried out by an organisation to ensure that essential business functions continue to operate during and after a disaster. By having a BCP, organisations seek to protect their mission critical services and give themselves their best chance of survival. This type of planning enables them to re-establish services to a fully functional level as quickly and smoothly as possible. BCPs generally cover most or all of an organisation's critical business processes and operations.

Conceptually the thinking for the test of if it is a Business Continuity Plan is; *"if we lost this building how would we recommence our business?"*

Disaster Recovery Plan (DRP)

As part of the business continuity process an organisation will normally develop a series of DRPs. These are more technical plans that are developed for specific groups within an organisation to allow them to recover a particular business application. The most well known example of a DRP is the Information Technology (IT) DRP.

The typical test for a DR Plan for IT would be; *"if we lost our IT services how would recover them?"*

IT DR plans only deliver technology services to the desk of employees. It is then up to the business units to have plans for the subsequent functions.

A mistake often made by organisations is that *'we have an IT DR Plan, we are all ok'*. That is not the case. You need to have a Business Continuity Plan in place for critical personnel, key business processes, recovery of vital records, critical suppliers identification, contacting of key vendors and clients etc.

It is critical that an organisation clearly defines what sort of plan it is working on. It is one of the first questions that we will ask as it defines the approach that needs to be taken and the processes required.

We are very familiar with both types of plans, we know the process and profiles and can consult and assist your organisation.

Ethics and Best Practices:

Practice cyberethics

Ethics are principles or standards of human conduct. Cyberethics is a code of behavior on the Internet.

Based on common sense and good judgment, cyberethics also includes obeying laws that apply to online behavior. When you practice cyberethics, you are more likely to have a safer and enjoyable Internet experience.

Here are a few suggestions:

- **DO use the Internet to communicate and interact with other people.** Email and instant messaging make it easy to stay in touch with friends and family members, communicate with work colleagues, and share ideas and information with people across town or halfway around the world. Participating in Internet forums and social networking sites are also great ways to engage with people online.
- **DON'T be a cyberbully.** Treat people online the way you would if you were talking to them face-to-face. Be considerate and respectful. Don't be rude or mean, don't use bad language, and don't make threats or attempt to humiliate other people. When you type, make sure your Caps Lock key is off or people might think that you're screaming.
- **DO report cyberbullying.** Keep a record of every comment you receive from a cyberbully; contact the cyberbully one time only and tell him to stop bothering you. If behavior doesn't change, then report the bully to the proper authorities.
- **DON'T encourage cyberbullies.** If someone you encounter online insults you or says something threatening, just ignore them. Engaging or arguing with cyberbullies might encourage even worse behavior. If you refuse to respond, there is a good chance they will move on and stop bothering you. If a cyberbully harrasses you through email or instant messaging, you can also use the built-in filters to prevent further contact.
- **DO use the Internet for research and information.** The Internet is like the world's largest library, packed full of information on every conceivable subject, from ancient history to current events, from math and science to art and anthropology. The information you find online can help you to manage your life, to improve your work, and to make important decisions with greater confidence.
- **DON'T use copyrighted information as your own.** The Internet has such a wealth of information that it can be tempting to copy and reuse information you find online. Presenting information from the Internet as your own work is not only dishonest, it could be illegal. If the material is copyrighted, then by law it belongs to someone else. If you use it without permission or appropriate attribution, you might be violating copyright laws.
- **DO enjoy music, videos and games on the Internet.** There are many websites where you can sample new music, watch movies and other videos, or play and learn about computer games.

- **DON'T download or share copyrighted information.** If you download and distribute copyrighted music, videos, games or other materials over the Internet without proper payment or permission, you are stealing.
- **DO shop, bank and pay bills online.** The Internet makes it easy and convenient to manage many tasks online-which can save time and money.
- **DON'T share personal information too easily.** Be careful about the type and amount of information you share with people online. Beware especially of people you don't know or questionable websites that might not be secure. Revealing personal information can make you a target for online criminals or cyberbullies. To help ensure you're on a secure site, check to see if the URL begins with https (the "s" stands for "secure"). Also, look for a [green address bar](#) or a security certificate-represented by an icon such as an unopened lock-somewhere in the browser window. Double-click the certificate to make sure the name on the web address matches the certificate.
- **DO use the Internet to expand your social and business networks.** Social and business networking sites can help you locate old friends and make new ones, create and maintain valuable professional contacts, and build your online reputation.
- **DON'T lie.** When you're interacting with people online, be honest, and never pretend to be someone else. If someone asks you a question that makes you uncomfortable or asks you to reveal too much personal information, just don't answer.

MCQ & Deceptive Questions

Multiple Choice Questions:

1. Which of the following are basic attributes of Vulnerabilities.
 - a) Faults
 - b) Severity
 - c) Authentication
 - d) Tactic Consequence
 - e) All of the above

Answer=e)
2. Out of the following which is an Anti-Virus?
 - a. McAfee
 - b. QuickHeal
 - c. Avast
 - d. All of the above

Answer=d)
3. Operating system is an _____ between a user and a computer.
 - a) Firewall
 - b) Interface
 - c) Application program

d) None of the above

Answer=b)

4. Patch may do the following things

a) Fix a software bug and upgrades the software

b) Install new drivers

c) Address new security vulnerabilities

d) Address software stability issues

e) All of the above.

Answer=e)

5.Name given by Microsoft Windows operating system patches are

a) MS-patches

b) Both a) and c)

c) Service Packs

d) None of the above

Answer=c)

6.Which of the below is an operating system?

a)Android

b) ios

c)Mac OS

d) All the above

Answer=d)

7. A set of process is deadlock when each is in the blocked state because it is waiting for a another resource that is allocate to one of the other

a) Statement is true

b) Statement is false

c) Both

d) All of the above

Answer=a)

8.Which of the following can be a cause of the deadlock?

a) Circular waits

b) No preemption

c) Mutual exclusions

d) All

Answer=d)

9.Type of operating systems are

a) Single user

b) Multiuser

c) Both

d) None

Answer=c)

10. _____ is a firewall

- a) Zone labs
- b) Trojans
- c) Spyware
- d) None of the above

Answer=a)

11. _____ is a hardware firewalls

- a) Cisco Sells
- b) Trojans
- c) Spyware
- d) None of the above

Answer=a)

12. Programs that exploit the Vulnerabilities in computer system are referred as _____

- a) Malware
- b) Firewall
- c) Anti-Viruses
- d) None of the above

Answer=a)

13. IDS stands for _____

- a) Intrusion Definition system
- b) Interface Definition system
- c) Intrusion Detection system
- d) All of the

Answer =c)

14. Updates of the anti-virus is not an important task to protect your operating system

- a) True
- b) False
- c) Both
- d) All

Answer= a)

15. Means of authentication can be through

- a) Password and PIN
- b) Static Biometrics
- c) Dynamic Biometrics
- d) All

Answer=d)

16. Viruses, Worms, Trojans and spyware are the type of _____

- a) Malware
- b) Firewall

- c) Anti-Viruses
- d) None of the above

Answer=a)

17. Zone alarm is a type of _____

- a) Malware
- b) Firewall
- c) Anti-Viruses
- d) None of the above

Answer=b)

18. Which is a firewall for Windows

- a) NetBarrier
- b) Iptables
- c) winroute
- d) All

Answer=d)

19. TCP/IP is a _____

- a) Malware
- b) Protocol
- c) Anti-Viruses
- d) None of the above

Answer=b)

20. In "Windows 7" 7 signifies

- a) 2007
- b) 7
- c) Both
- d) All of the above

Answer=a)

=====

Modul-2

Chapter 2: Security Laws and Standard

INTELLECTUAL PROPERTY RIGHTS (IPR)

WHAT IS AN IPR?

Intellectual Property Rights are legal rights, which result from intellectual activity in industrial, scientific, literary & artistic fields. These rights Safeguard creators and other producers of intellectual goods & services by granting them certain time-limited rights to control their use. Protected IP rights like other property can be a matter of trade, which can be owned, sold or bought. These are intangible and non-exhausted consumption.

TYPES/TOOLS OF IPRs:

- a. Patents.
- b. Trademarks.
- c. Copyrights and related rights.
- d. Geographical Indications.
- e. Industrial Designs.
- f. Trade Secrets.
- g. Layout Design for Integrated Circuits.
- h. Protection of New Plant Variety.

a. Patent

A patent is an exclusive right granted for an invention, which is a product or a process that provides a new way of doing something, or offers a new technical solution to a problem. It provides protection for the invention to the owner of the patent. The protection is granted for a limited period, i.e 20 years. Patent protection means that the invention cannot be commercially made, used, distributed or sold

Chapter 2 : Security Laws and Standards

the owner no longer holds exclusive rights to the invention, which becomes available to commercial exploitation by others.

All patent owners are obliged, in return for patent protection, to publicly disclose information on their invention in order to enrich the total body of technical knowledge in the world. Such an ever-increasing body of public knowledge promotes further creativity and innovation in others. In this way, patents provide not only protection for the owner but valuable information and inspiration for future generations of researchers and inventors.

General Principles governing the Patent System in India and further details can be viewed at DIP&P website at <http://ipindia.nic.in/ipr/patent/patents.htm>

b. Trademarks:

A trademark is a distinctive sign that identifies certain goods or services as those produced or provided by a specific person or enterprise. It may be one or a combination of words, letters, and numerals. They may consist of drawings, symbols, three-dimensional signs such as the shape and packaging of goods, audible signs such as music or vocal sounds, fragrances, or colours used as distinguishing features. It provides protection to the owner of the mark by ensuring the exclusive right to use it to identify goods or services, or to authorize another to use it in return for payment.

It helps consumers identify and purchase a product or service because its nature and quality, indicated by its unique trademark, meets their needs.

Registration of trademark is prima facie proof of its ownership giving statutory right to the proprietor. Trademark rights may be held in perpetuity. The initial term of registration is for 10 years; thereafter it may be renewed from time to time.

General Principles governing the Trademarks System in India and further without the patent owner's consent. A patent owner has the right to decide who may - details can be viewed at DIP&P website at http://ipindia.nic.in/tmr_new/default.htm or may not - use the patented invention for the period in which the invention is

- c. **Copyrights and related rights:** may give permission to, or license, other parties to use the invention. Copyright is a legal right that gives the creator the right to control the use of their work. The kinds of works covered by copyright include literary works, musical compositions, films, and other artistic works. Once a patent expires, the protection ends, and the work enters the public domain, that is, it is available to everyone. Copyrights, patents, and other intellectual property rights are designed to encourage innovation by giving creators a temporary monopoly over their work. The kinds of works covered by copyright include literary works, musical compositions, films, and other artistic works. Once a patent expires, the protection ends, and the work enters the public domain, that is, it is available to everyone. Copyrights, patents, and other intellectual property rights are designed to encourage innovation by giving creators a temporary monopoly over their work.

paintings, drawings, photographs and sculpture; architecture; and advertisements, maps and technical drawings. Copyright subsists in a work by virtue of creation; hence it's not mandatory to register. However, registering a copyright provides evidence that copyright subsists in the work & creator is the owner of the work.

Creators often sell the rights to their works to individuals or companies best able to market the works in return for payment. These payments are often made dependent on the actual use of the work, and are then referred to as royalties. These economic rights have a time limit, (other than photographs) is for life of author plus sixty years after creator's death.

General Principles governing the Copyrights and related rights System in India and further details can be viewed at website of Copyright Office website at <http://copyright.gov.in/>

d. Geographical Indications (GI):

GI are signs used on goods that have a specific geographical origin and possess qualities or a reputation that are due to that place of origin. Agricultural products typically have qualities that derive from their place of production and are influenced by specific local factors, such as climate and soil. They may also highlight specific qualities of a product, which are due to human factors that can be found in the place of origin of the products, such as specific manufacturing skills and traditions.

A geographical indication points to a specific place or region of production that determines the characteristic qualities of the product that originates therein. It is important that the product derives its qualities and reputation from that place. Place of origin may be a village or town, a region or a country.

It is an exclusive right given to a particular community hence the benefits of its registration are shared by the all members of the community. Recently the GIs of goods like Chanderi Sarees, Kullu Shawls, Wet Grinders etc have been registered. Keeping in view the large diversity of traditional products spread all over the country, the registration under GI will be very important in future growth of the tribes / communities / skilled artisans associated in developing such products.

General Principles governing the Geographical Indication System in India and further details can be viewed at website of Geographical Indication Registry, website at <http://ipindia.nic.in/girindia/>

e. Industrial Designs:

Industrial designs refer to creative activity, which result in the ornamental or formal appearance of a product, and design right refers to a novel or original design that is accorded to the proprietor of a validly registered design. Industrial designs are an element of intellectual property. Under the TRIPS Agreement, minimum standards of protection of industrial designs have been provided for. As a developing country, India has already amended its national legislation to provide for these minimal standards.

The essential purpose of design law is to promote and protect the design element of industrial production. It is also intended to promote innovative activity in the field of industries. The existing legislation on industrial designs in India is contained in the New Designs Act, 2000 and this Act will serve its purpose well in the rapid changes in technology and international developments. India has also achieved a mature status in the field of industrial designs and in view of globalization of the economy, the present legislation is aligned with the changed technical and commercial scenario and made to conform to international trends in design administration.

This replacement Act is also aimed to enact a more detailed classification of design to conform to the international system and to take care of the proliferation of design related activities in various fields.

General Principles governing the Industrial Design System in India and further details can be viewed at DIP&P website link at <http://ipindia.nic.in/ipr/design/designs.htm>

f. Trade Secrets:

It may be confidential business information that provides an enterprise a competitive edge may be considered a trade secret. Usually these are manufacturing or industrial secrets and commercial secrets. These include sales methods, distribution methods, consumer profiles, advertising strategies, lists of suppliers and clients, and

manufacturing processes. Contrary to patents, trade secrets are protected without registration.

A trade secret can be protected for an unlimited period of time but a substantial element of secrecy must exist, so that, except by the use of improper means, there would be difficulty in acquiring the information. Considering the vast availability of traditional knowledge in the country the protection under this will be very crucial in reaping benefits from such type of knowledge. The Trades secret, traditional knowledge are also interlinked / associated with the geographical indications.

g. Layout Design for Integrated Circuits:

Semiconductor Integrated Circuit means a product having transistors and other circuitry elements, which are inseparably formed on a semiconductor material or an insulating material or inside the semiconductor material and designed to perform an electronic circuitry function.

The aim of the Semiconductor Integrated Circuits Layout-Design Act 2000 is to provide protection of Intellectual Property Right (IPR) in the area of Semiconductor Integrated Circuit Layout Designs and for matters connected therewith or incidental thereto. The main focus of SICLD Act is to provide for routes and mechanism for protection of IPR in Chip Layout Designs created and matters related to it. The SICLD Act empowers the registered proprietor of the layout-design an inherent right to use the layout-design, commercially exploit it and obtain relief in respect of any infringement. The initial term of registration is for 10 years; thereafter it may be renewed from time to time. Department of Information Technology Ministry of Communications and Information Technology is the administrative ministry looking after its registration and other matters.

General Principles governing the Layout Design for Integrated Circuits System in India and further details can be viewed at DIT website link at <http://mit.gov.in/default.aspx?id=322>

h. Protection of New Plant Variety:

The objective of this act is to recognize the role of farmers as cultivators and conservers and the contribution of traditional, rural and tribal communities to the country's agro biodiversity by rewarding them for their contribution and to stimulate

investment for R & D for the development new plant varieties to facilitate the growth of the seed industry.

The Plant Variety Protection and Farmers Rights act 2001 was enacted in India to protect the New Plant Variety; the act has come into force on 30.10.2005 through Authority. Initially 12 crop species have been identified for regt. i.e. Rice, Wheat, Maize, Sorghum, Pearl millet, Chickpea, Green gram, Black gram, Lentil, Kidney bean etc. India has opted for sui- generic system instead of patents for protecting new plant variety. Department Agriculture and Cooperation is the administrative ministry looking after its registration and other matters.

General Principles governing the Protection of New Plant Variety System in India and further details can be viewed at Protection of Plant Varieties and Farmers' Rights Authority, India (PPV&FR) website link at <http://www.plantauthority.gov.in/>
Security Assurance, IPR and Cyber Law MCQs

Scheme For “Building Awareness On Intellectual Property Rights (IPR)” For Micro, Small And Medium Enterprises (MSMEs) Under National Manufacturing Competitiveness Programme (NMCP) Questions

The objective of the scheme is to enhance awareness of MSME about Intellectual Property Rights (IPRs) to take measure for the protecting their ideas and business strategies. Effective utilisation of IPR tools by MSMEs would also assist them in technology upgradation and enhancing competitiveness.

These initiatives are proposed to be developed through Public-Private Partnership (PPP) mode to encourage economically sustainable models for overall development of MSMEs. Under this programme financial assistance will be provided for taking up the identified initiatives. Eligible applicants/beneficiaries will have to contribute minimum 10% of the GoI financial support for availing assistance under the scheme.

The detail guidelines, eligibility criteria, funding pattern and prescribed format etc. are available on <http://www.dcsmse.gov.in/schemes/Guidelines-UK.pdf>

Related Links: Multiple Choice Questions

www.wipo.int

<http://www.tifac.org.in/do/pfc/pfc.htm>

MCQ

1. The collection, storage, and dissemination of information about individuals is included in the ethical category of:
- a. accuracy.
 - b. privacy.
 - c. accessibility.
 - d. property.

Answer: Privacy

2. A piece of information that allows a Web site to record one's comings and goings is called:
- a. a browser.
 - b. a cookie.
 - c. a worm.
 - d. a macro virus.

Answer: Cookies

3. All of the following are examples of intellectual property protections **EXCEPT**:
- a. copyrights.
 - b. patents.
 - c. contracts.
 - d. trademarks.

Answer: Contracts

4. A copyright gives the owner all of the following rights **EXCEPT**:
- a. the right to copy the work.
 - b. the right to print the work as a book.
 - c. the right to publish the work on the Internet.
 - d. the right to privacy.

Answer: right to privacy

5. A document that grants the holder exclusive rights on an invention for a fixed number of years is:
- a. a trademark.
 - b. a patent.
 - c. a copyright.
 - d. a brandmark.

Answer: Patents

6. A government's attempt to control the material broadcasted on the Internet is called:
- a. censorship.
 - b. privacy infringement.
 - c. free speech.
 - d. spamming.

Answer: Censorship

7. E-commerce is the commercial transaction of services in a/an _____
- a. mechanical format.
 - b. electronic format
 - c. paper
 - d. None of the above

Answer: Electronic Format

8. _____ is a generic term which refers to all the legal and regulator aspects of Internet and the World Wide Web

- a. Cyber law
- b. Cyber dyne
- c. Cyber café
- d. electronic law

Answer : Cyber Law

9. _____ is a process of authentication of an electronic record
- a. Digital Signature Certificate
 - b. Digital key
 - c. Analog signature
 - d. key certificate

Answer : Digital signature certificate

10. In computer security, means that computer system assets can be modified only by authorized parties.

- A) Confidentiality
- B) Integrity
- C) Availability
- D) Authenticity

Answer : Integrity

11. In computer security, means that the information in a computer system only be accessible for reading by authorized parties.

- A) Confidentiality
- B) Integrity
- C) Availability
- D) Authenticity

Answer : Confidentiality

12. Which of the following is independent malicious program that need not any host program?

- A) Trap doors
- B) Trojan horse
- C) Virus
- D) Worm

Answer : Worm

13. Personal computers use number of chips mounted on a main circuit board. What is the common name for such boards?

- A) Daughter board
- B) Mother board

C) Father board

D) Bread board

Answer: Mother board

14. Which of the following is not component of information assurance system?

a. Confidentiality

b. IPR

c. Integrity

d. Utility

Answer : IPR

15. What is the difference between Data Integrity and Data Security?

a. Limiting physical access to computer systems; assigning passwords to users.

b. Consistent, accurate and reliable data; protection of data from unauthorized access.

c. Encryption; Audit trails

d. Distributing work to preserve integrity; installing system passwords

Answer : B

16. Registration of Patent provides security to invention for

a. 10 years

b. 20 years

c. 30 years

d. 50 years

17. Which of the following is not threat

a. Virus

b. Hacker

c. Hard disk failure

d. Operating system

Answer : Operating system

18. Legal rights related to creator of artistic and literary field is known as

a. Trade marks

b. Trade Secrets

c. Copyrights and related rights

d. patent

Answer : Copyrights and related rights

19. Trademarks can be protected for

- a. 10 years
- b. 20 years
- c. 30 years
- d. Unlimited time

Answer : Unlimited time

20. Legal rights related to invention are called as

- a. Patent
- b. Utility
- c. Trade secrets
- d. Trade Marks

Answer : Patent

Modul-3

Module 3: Information & Network Security

Chapter 1: Access Control & Intrusion Detection

1. Overview of Identification and Authorization
2. Overview of IDS
3. Intrusion Detection System and Intrusion Prevention Systems

OVERVIEW OF INTRUSION DETECTION SYSTEM

An intrusion is defined, by Heady as any set of actions that attempt to compromise the integrity, confidentiality, or availability of a resource [Intrusion could be in many forms such as:

1. Unauthorized personnel trying to gain access to the resources in a system or network.
2. Malicious programs that spoil the system resources, degrades the system performance and manipulates the system data.

3. Authorized personnel trying to gain additional privileges or access to confidential information, thus compromising the system's security policy.

Internet has changed the face of communication and computation. It is a highway to a lot of useful information.

As internet has been illustrating an exponential growth, concurrently, so have computer attacks and cyber crimes by exploiting vulnerabilities in the system. It is reported in that, during the period of 1991-1996, information theft rose

by 250% and 99% of all major companies reported one incident of major security breach and 10 billion dollars were lost in the US due to telecom and computer related frauds. Even if any computer system is very secure, the abuse of the privileges by authorized users is still an issue of threat. Moreover, a transaction logging mechanism; generally referred to as audit collection; is the need of the hour. It helps to understand and assess the damage caused by an intrusion. The automation of this audit collection is referred to as Intrusion detection system.

Intrusion detection system (IDS) monitors all the system activities in order to detect the intrusion. It searches for security violation incidents, recognizes unauthorized accesses, identifies information leakages and intervention of malicious programs.

IDS play a role as a reactive agent rather than a proactive agent in the security landscape of the system, whose primary job is to inform the system administrator in the event of an intrusion. A deeper understanding of computer attacks is required to identify intrusion and security threats. A typical computer attack can be generalized into a five step approach.

Reconnaissance: The attacker collects high level information of the system.

Scanning: Using the information collected in the previous step, the attacker identifies potential vulnerabilities in the

system and collects detailed information about the network such as network topology, ports used and firewall rules.

Gaining Access: There are two ways to gain access to the system depending upon the legitimacy of the user. An authorized user exploits the loop holes in the operating system or other applications running in the system. An illegitimate user makes use of the network to attach to the system. DoS (Denial of Service) is one such example in which the web server is bombarded with multiple requests simultaneously that it eventually crashes.

Maintaining Access: The attacker has access to the system and tries to extract information from the system and retain control

Covering Tracks: In order to exercise continuous control over the system, the attacker modifies system logs and

other relevant information to ensure that there is no trace of contravention in the security system.

Attack Types

1. Scanning Attack

Scanning attacks can be used to assimilate information about the system being attacked. Using scanning techniques, the attacker can gain topology information, types of network traffic allowed through a firewall, active hosts on a network, OS and kernel of hosts on a network, server software running, version numbers of software, etc... Using this information, the attacker may launch attacks aimed at more specific exploits. The above was gathered by launching a stealth SYN scan. This scan is called stealth because it never actually completes TCP connections. This technique is often referred to as half open scanning, because the attacker does not open a full TCP connection. The attacker sends a SYN packet, as though you he were opening up a real TCP

connection. If the attacker receives a SYN/ACK, this indicates the port is listening. If no response is received, the attacker may assume that the port is closed

2. Denial of Service Attack

There are two main types of denial of service (DoS) attacks: flooding and flaw exploitations. Flooding attacks can often simply implement. For example, one can launch a DoS attack by just using the ping command. This will result in sending the victim an overwhelming number of ping packets. If the attacker has access to greater bandwidth than the victim, this will easily and quickly overwhelm the victim. As another example, a SYN flood attack sends a flood of TCP/SYN packets with a forged source address to a victim. This will cause the victim to open half open TCP connections - the victim will send a TCPSYN/ACK packet and wait for an ACK in response. Since the ACK never comes, the victim eventually will exhaust available resources waiting for ACKs from a nonexistent host.

3. Penetration Attack

Penetration attacks contain all attacks which give the unauthorized attacker the ability to gain access to system resources, privileges, or data. One common way for this to happen is by exploiting a software flaw. This attack would be considered a penetration attack. Being able to arbitrarily execute code as root easily gives an attacker to whatever system resource imaginable. In addition, this could allow the user to launch other types of attack on this system, or even attack other systems from the compromised system.

Taxonomy

Intrusion detection system can be broadly classified based on two parameters as shown

- (a) Analysis method used to identify intrusion, which is classified into Misuse IDS and Anomaly IDS.
- (b) Source of data that is used in the analysis method, which is classified into Host, based IDS and Network based IDS

1. Misuse IDS

Misuse based IDS is a very prominent system and is widely used in industries. Most of the organizations that develop anti-virus solutions base their design methodology on Misuse IDS. The system is constructed based on the signature of all-known attacks. Rules and signatures define abnormal and unsafe behavior. It analyzes the traffic flow over a network and matches against known signatures.

Once a known signature is encountered the IDS triggers an alarm. With the advancement in latest technologies, the number of signatures also increase. This demands for constant upgrade and modification of new attack signatures

from the vendors and paying more to vendors for their support .

The advantages of this model are easy creation of attack signature databases, faster and easier implementation of IDS and minimal usage of the system resources. The main weakness of the traditional and established rule

based techniques is that rule based detection is highly dependent on the audit results. This one-to-one correspondence between rules and audit records makes the system inflexible. For example, given a particular penetration scenario, the audit results may vary in the sequences of events. This results in variations in the detection outcome. This may lead to large number of false positives and in some cases, false negatives too.

Another limitation includes the inability to predict an mishap and take preemptive action. The rule-based technique only helps in prevention of an intrusion when the details and patterns of it are available.

Rules are framed when a set of administrators are interviewed, different observed penetrations are recorded, rules are set to those penetration scenarios based on the expected outcomes from the analysis of audit records. Therefore, updating of rules is expensive in terms of time and money.

2. Anomaly IDS

Anomaly IDS is built by studying the behavior of the system over a period of time in order to construct activity

profiles that represent normal use of the system. The anomaly IDS computes the similarity of the traffic in the

system with the profiles to detect intrusions. The biggest advantage of this model is that new attacks can

be identified by the system as it will be a deviation from normal behavior.

The drawbacks of this model are summarized based on

(a) There is no defined process or model available to select the threshold value against which the profile is compared.

(b) They are computationally expensive because the profiles have to be constantly updated and compared against.

(c) User behaviors generally vary with time and hence the model must provide a provision to revise and update it.

3. Host Based IDS

When the source of data for IDS comes from a single host (System), then it is classified as Host based IDS. They are generally used to monitor user activity and useful to track intrusions caused when an authorized user tries to access confidential information.

4. Network Based IDS

The source of data for these type of IDS is obtained by listening to all nodes in a network. Attacks from illegitimate user can be identified using a network based IDS.

Commercial IDSs are always a combination of the two types mentioned above. The possible kinds of IDS are host based misuse IDS, network based misuse IDS, host based anomaly IDS and network based anomaly IDS. However, with greater interest and research in this field, new models are being developed such as Network Security monitor, IDS using autonomous agents and many others .

Key Functionalities and Metrics

The Key functionalities of an IDS can be divided into 4 parts

Key functionalities of an IDS

(1) Data Collection: This module captures the real time data in the system and passes it as an input to the IDS. The kind of data that is written to a file for analysis depends on the type of IDS which is explained in above In case of network based IDS, data packets in transit are collected and in host based IDS, details such as disk usage, system process, call stack etc are logged.

(2) Feature Selection: Large amount of data is available in the network and a subset of it is usually analyzed for intrusion. For example, the Internet Protocol (IP) address of the source and target system, protocol type, header length and size could be studied for possible intrusion.

(3) Analysis: This module defines the method that is used to analyze data. One method is use of rule based IDS where the incoming traffic is checked against pre-defined signature or pattern. Another method is use of anomaly based IDS where the system behavior is studied and mathematical models are employed.

(4) Action: This module defines how the system must react to possible attacks in the system. It can either inform the system administrator with all the required data through email/alarm icons or it can play an active part in the system

by dropping packets so that it does not enter the system or closing ports.

Two important measures, that help to evaluate the effectiveness of an intrusion detection system, are false positive errors and false negative errors . A false positive error is one that is classified as intrusion by the IDS when it

is a normal expected user behavior. A false negative error is one when the IDS fails to raise an alarm in the event of an intrusion since it classifies the user behavior as legitimate.

ANALYSIS

1. Traffic Data

We used two-way traffic traces provided by the Umass Trace Repository . The traces were measured at the Umass Internet gateway router. The UMass campus is connected to the Internet through Verio, a commercial ISP, and Internet . Both of these connections are Gigabit Ethernet links. In particular, we used the “Gateway Link 3 Trace” that was measured every morning from 9:30 to 10:30 from July 16, 2004 to July 22, 2004. All of these data are manually labeled, but we did not use the labels with the proposed method.

2. Effectiveness of the Time-Periodical Packet Sampling

First, we confirmed our conjecture that the time-periodically sampled traffic would contain normal packets with higher ratio than the original traffic before sampling. For comparison, the mixing ratio of the anomalous packets to the original traffic and randomly sampled traffic of which the sampling rate per packet is p . The mixing ratio of anomaly packets to the time-based sampled traffic is much smaller than that to the original traffic before sampling, whereas the mixing ratio of anomaly packets to the randomly sampled traffic is almost identical to that to the original traffic before sampling. This result indicates that the time-periodical packet sampling is useful for extracting normal packets from the unlabeled original traffic which may include anomalous traffic. However, we have to remember that the time-periodically sampled traffic

might be biased towards a specific aspect of normal traffic. Therefore, we investigated the performance of baseline distributions that were trained with time-periodically sampled traffic data. e numbers of normal behaviors incorrectly identified as anomalies (FP: False Positive) and missed anomalies (FN: False Negative) regarding TCP SYN packets for the baseline distributions trained with different types of traffic data, i.e., normal traffic data, original traffic data before sampling, 10 sets of time-periodically sampled traffic data, and 10 sets of randomly sampled traffic data

3.Effectiveness of Ensemble Anomaly Detection

This indicates that the unsupervised ensemble method can avoid the worst performance of the individual baseline distributions for the time-periodically sampled traffic. In addition, the resulting performance for the time-periodically sampled traffic is nearly identical to when the baseline distribution is trained by using the normal traffic data. Note that the unsupervised ensemble anomaly detection is effective even when the baseline distribution is trained by using randomly sampled traffic data. However, the resulting performance for the randomly sampled traffic is nearly identical to when the baseline distribution is trained with the original traffic data. Therefore, we still cannot provide any justification for using randomly sampled traffic data to train the baseline distributions.

INTRUSION DETECTION AND PREVENTION PRINCIPLES

Intrusion detection is the process of monitoring the events occurring in a computer system or network and analyzing them for signs of possible *incidents*, which are violations or imminent threats of violation of computer security policies, acceptable use policies, or standard security practices. Incidents have many causes, such as malware (e.g., worms, spyware), attackers gaining unauthorized access to systems from the Internet, and authorized users of systems who misuse their privileges or attempt to gain additional privileges for which they are not authorized. Although many incidents are malicious in nature, many others are not; for example, a person might mistype the address of a computer and accidentally attempt to connect to a different system without authorization.

An *intrusion detection system* (IDS) is software that automates the intrusion detection process. An *intrusion prevention system* (IPS) is software that has all the capabilities of an intrusion detection system and can also attempt to stop possible incidents. This section provides an overview of IDS and IPS technologies as a foundation for the rest of the publication. It first explains how IDS and IPS technologies can be used. Next, it describes the key functions that IDS and IPS technologies perform and the detection methodologies that they use. Finally, it provides an overview of the major classes of IDS and IPS technologies.

IDS and IPS technologies offer many of the same capabilities, and administrators can usually disable prevention features in IPS products, causing them to function as IDSs. Accordingly, for brevity the term *intrusion detection and prevention systems* (IDPS) is used throughout the rest of this guide to refer to both IDS and IPS technologies.² Any exceptions are specifically noted.

2 This term is used for the purposes of this publication. It has not been widely used in the security community, and the reason for using it in this publication is strictly brevity, not to replace the well-established “IDS” and “IPS” terms.

3 If the IDPS had successfully prevented the attack, security administrators still might want to be notified of the attack. This is particularly important if the target has a known vulnerability that the attack could have exploited. Attackers could potentially use a different attack for the same vulnerability that the IDPS might not recognize.

4 A detailed discussion of incident response is outside the scope of this guide. For guidance on establishing an effective incident response capability,

1. Uses of IDPS Technologies

IDPSs are primarily focused on identifying possible incidents. For example, an IDPS could detect when an attacker has successfully compromised a system by exploiting a vulnerability in the system. The IDPS could then report the incident to security administrators, who could quickly initiate incident response actions to minimize the damage caused by the incident.³ The IDPS could also log information that could be used by the incident handlers.⁴ Many IDPSs can also be configured to recognize violations of security policies. For example, some IDPSs can be configured with firewall ruleset-like settings, allowing them to identify network traffic that violates the organization’s security or acceptable use policies. Also, some IDPSs can monitor file transfers and identify ones that might be suspicious, such as copying a large database onto a user’s laptop.

Many IDPSs can also identify reconnaissance activity, which may indicate that an attack is imminent. For example, some attack tools and forms of malware, particularly worms, perform reconnaissance activities such as host and port scans to identify targets for subsequent attacks. An IDPS might be able to block reconnaissance and notify security administrators, who can take actions if needed to alter other security controls to prevent related incidents. Because reconnaissance activity is so frequent on the Internet, reconnaissance detection is often performed primarily on protected internal networks.

2- 1 GUIDE TO INTRUSION DETECTION AND PREVENTION SYSTEMS (IDPS) In addition to identifying incidents and supporting incident response efforts, organizations have found other uses for IDPSs, including the following:

□ **Identifying security policy problems.** An IDPS can provide some degree of quality control for security policy implementation, such as duplicating firewall rulesets and alerting when it sees network traffic that should have been blocked by the firewall but was not because of a firewall configuration error.

□ **Documenting the existing threat to an organization.** IDPSs log information about the threats that they detect. Understanding the frequency and characteristics of attacks against an organization’s computing resources is helpful in identifying the appropriate security measures for protecting the resources. The information can also be used to educate management about the threats that the organization faces.

□ **Deterring individuals from violating security policies.** If individuals are aware that their actions are being monitored by IDPS technologies for security policy violations, they may be less likely to commit such violations because of the risk of detection.

Because of the increasing dependence on information systems and the prevalence and potential impact of intrusions against those systems, IDPSs have become a necessary addition to the security infrastructure of nearly every organization.

3. Key Functions of IDPS Technologies

There are many types of IDPS technologies, which are differentiated primarily by the types of events that they can recognize and the methodologies that they use to identify incidents. In addition to monitoring and analyzing events to identify undesirable activity, all types of IDPS technologies typically perform the following functions:

□ **Recording information related to observed events.** Information is usually recorded locally, and might also be sent to separate systems such as centralized logging servers, security information and event management (SIEM) solutions, and enterprise management systems.

□ **Notifying security administrators of important observed events.** This notification, known as an *alert*, occurs through any of several methods, including the following: e-mails, pages, messages on the IDPS user interface, Simple Network Management Protocol (SNMP) traps, syslog messages, and user-defined programs and scripts. A notification message typically includes only basic information regarding an event; administrators need to access the IDPS for additional information.

□ **Producing reports.** Reports summarize the monitored events or provide details on particular events of interest.

Some IDPSs are also able to change their security profile when a new threat is detected. For example, an IDPS might be able to collect more detailed information for a particular session after malicious activity is detected within that session. An IDPS might also alter the settings for when certain alerts are triggered or what priority should be assigned to subsequent alerts after a particular threat is detected.

IPS technologies are differentiated from IDS technologies by one characteristic: IPS technologies can respond to a detected threat by attempting to prevent it from succeeding. They use several response techniques, which can be divided into the following groups:

□ **The IPS stops the attack itself.** Examples of how this could be done are as follows:

2- 2 GUIDE TO INTRUSION DETECTION AND PREVENTION SYSTEMS (IDPS) terminate the network connection or user session that is being used for the attack Block access to the target (or possibly other likely targets) from the offending user account, IP address, or other attacker attribute Block all access to the targeted host, service, application, or other resource.

□ **The IPS changes the security environment.** The IPS could change the configuration of other security controls to disrupt an attack. Common examples are reconfiguring a network device

(e.g., firewall, router, switch) to block access from the attacker or to the target, and altering a host-based firewall on a target to block incoming attacks. Some IPSs can even cause patches to be applied to a host if the IPS detects that the host has vulnerabilities.

□ **The IPS changes the attack's content.** Some IPS technologies can remove or replace malicious portions of an attack to make it benign. A simple example is an IPS removing an infected file attachment from an e-mail and then permitting the cleaned email to reach its recipient. A more complex example is an IPS that acts as a proxy and *normalizes* incoming requests, which means that the proxy repackages the payloads of the requests, discarding header information. This might cause certain attacks to be discarded as part of the normalization process.

Another common attribute of IDPS technologies is that they cannot provide completely accurate detection. When an IDPS incorrectly identifies benign activity as being malicious, a *false positive* has occurred. When an IDPS fails to identify malicious activity, a *false negative* has occurred. It is not possible to eliminate all false positives and negatives; in most cases, reducing the occurrences of one increases the occurrences of the other. Many organizations choose to decrease false negatives at the cost of increasing false positives, which means that more malicious events are detected but more analysis resources are needed to differentiate false positives from true malicious events. Altering the configuration of an IDPS to improve its detection accuracy is known as *tuning*.

Most IDPS technologies also offer features that compensate for the use of common evasion techniques. *Evasion* is modifying the format or timing of malicious activity so that its appearance changes but its effect is the same. Attackers use evasion techniques to try to prevent IDPS technologies from detecting their attacks. For example, an attacker could encode text characters in a particular way, knowing that the target understands the encoding and hoping that any monitoring IDPSs do not. Most IDPS technologies can overcome common evasion techniques by duplicating special processing performed by the targets. If the IDPS can “see” the activity in the same way that the target would, then evasion techniques will generally be unsuccessful at hiding attacks.

4. Common Detection Methodologies

IDPS technologies use many methodologies to detect incidents. discuss the primary classes of detection methodologies: signature-based, anomaly-based, and stateful protocol analysis, respectively. Most IDPS technologies use multiple detection methodologies, either separately or integrated, to provide more broad and accurate detection.

2- 3 GUIDE TO INTRUSION DETECTION AND PREVENTION SYSTEMS (IDPS)

5 Signature-based detection is sometimes referred to as *misuse detection*, but this publication does not use that term because it implies that misuse is only detected using signatures, which is not true. Also, signature-based detection is considered by some parties to include stateful protocol analysis, as described in Section 2.3.3. For the purposes of this publication, signature-based detection is defined so as not to include stateful protocol analysis, but other publications may have different definitions.

1. Signature-Based Detection

A *signature* is a pattern that corresponds to a known threat. *Signature-based detection* is the process of comparing signatures against observed events to identify possible incidents.⁵ Examples of signatures are as follows:

- A telnet attempt with a username of “root”, which is a violation of an organization’s security policy
- An e-mail with a subject of “Free pictures!” and an attachment filename of “freepics.exe”, which are characteristics of a known form of malware
- An operating system log entry with a status code value of 645, which indicates that the host’s auditing has been disabled.

Signature-based detection is very effective at detecting known threats but largely ineffective at detecting previously unknown threats, threats disguised by the use of evasion techniques, and many variants of known threats. For example, if an attacker modified the malware in the previous example to use a filename of “freepics2.exe”, a signature looking for “freepics.exe” would not match it.

Signature-based detection is the simplest detection method because it just compares the current unit of activity, such as a packet or a log entry, to a list of signatures using string comparison operations. Signature-based detection technologies have little understanding of many network or application protocols and cannot track and understand the state of complex communications. For example, they cannot pair a request with the corresponding response, such as knowing that a request to a Web server for a particular page generated a response status code of 403, meaning that the server refused to fill the request. They also lack the ability to remember previous requests when processing the current request. This limitation prevents signature-based detection methods from detecting attacks that comprise multiple events if none of the events contains a clear indication of an attack.

2. Anomaly-Based Detection

Anomaly-based detection is the process of comparing definitions of what activity is considered normal against observed events to identify significant deviations. An IDPS using anomaly-based detection has *profiles* that represent the normal behavior of such things as users, hosts, network connections, or applications. The profiles are developed by monitoring the characteristics of typical activity over a period of time. For example, a profile for a network might show that Web activity comprises an average of 13% of network bandwidth at the Internet border during typical workday hours. The IDPS then uses statistical methods to compare the characteristics of current activity to thresholds related to the profile, such as detecting when Web activity comprises significantly more bandwidth than expected and alerting an administrator of the anomaly. Profiles can be developed for many behavioral attributes, such as the number of e-mails sent by a user, the number of failed login attempts for a host, and the level of processor usage for a host in a given period of time.

The major benefit of anomaly-based detection methods is that they can be very effective at detecting previously unknown threats. For example, suppose that a computer becomes infected with a new type of malware. The malware could consume the computer's processing resources, send large numbers of e-

2- 4 GUIDE TO INTRUSION DETECTION AND PREVENTION SYSTEMS (IDPS)

6 Some vendors use the term “deep packet inspection” to refer to performing some type of stateful protocol analysis, often combined with a firewall capability that can block communications determined to be malicious. This publication uses the term “stateful protocol analysis” because it is appropriate for analyzing both network-based and host-based activity, whereas “deep packet inspection” is an appropriate term for network-based activity only. Also, historically there has not been consensus in the security community as to the meaning of “deep packet inspection”.

mails, initiate large numbers of network connections, and perform other behavior that would be significantly different from the established profiles for the computer.

An initial profile is generated over a period of time (typically days, sometimes weeks) sometimes called a *training period*. Profiles for anomaly-based detection can either be static or dynamic. Once generated, a static profile is unchanged unless the IDPS is specifically directed to generate a new profile. A dynamic profile is adjusted constantly as additional events are observed. Because systems and networks change over time, the corresponding measures of normal behavior also change; a static profile will eventually become inaccurate, so it needs to be regenerated periodically. Dynamic profiles do not have this problem, but they are susceptible to evasion attempts from attackers. For example, an attacker can perform small amounts of malicious activity occasionally, then slowly increase the frequency and quantity of activity. If the rate of change is sufficiently slow, the IDPS might think the malicious activity is normal behavior and include it in its profile. Malicious activity might also be observed by an IDPS while it builds its initial profiles.

Inadvertently including malicious activity as part of a profile is a common problem with anomaly-based IDPS products. (In some cases, administrators can modify the profile to exclude activity in the profile that is known to be malicious.) Another problem with building profiles is that it can be very challenging in some cases to make them accurate, because computing activity can be so complex. For example, if a particular maintenance activity that performs large file transfers occurs only once a month, it might not be observed during the training period; when the maintenance occurs, it is likely to be considered a significant deviation from the profile and trigger an alert. Anomaly-based IDPS products often produce many false positives because of benign activity that deviates significantly from profiles, especially in more diverse or dynamic environments. Another noteworthy problem with the use of anomaly-based detection techniques is that it is often difficult for analysts to determine why a particular alert was generated and to validate that an alert is accurate and not a false positive, because of the complexity of events and number of events that may have caused the alert to be generated.

3. Stateful Protocol Analysis

Stateful protocol analysis is the process of comparing predetermined profiles of generally accepted definitions of benign protocol activity for each protocol state against observed events to identify deviations.⁶ Unlike anomaly-based detection, which uses host or network-specific

profiles, stateful protocol analysis relies on vendor-developed universal profiles that specify how particular protocols should and should not be used. The “stateful” in stateful protocol analysis means that the IDPS is capable of understanding and tracking the state of network, transport, and application protocols that have a notion of state. For example, when a user starts a File Transfer Protocol (FTP) session, the session is initially in the unauthenticated state. Unauthenticated users should only perform a few commands in this state, such as viewing help information or providing usernames and passwords. An important part of understanding state is pairing requests with responses, so when an FTP authentication attempt occurs, the IDPS can determine if it was successful by finding the status code in the corresponding response. Once the user has authenticated successfully, the session is in the authenticated state, and users are expected to perform any of several dozen commands. Performing most of these commands while in the unauthenticated state would be considered suspicious, but in the authenticated state performing most of them is considered benign.

2- 5 GUIDE TO INTRUSION DETECTION AND PREVENTION SYSTEMS (IDPS) Stateful protocol analysis can identify unexpected sequences of commands, such as issuing the same command repeatedly or issuing a command without first issuing a command upon which it is dependent. Another state tracking feature of stateful protocol analysis is that for protocols that perform authentication, the IDPS can keep track of the authenticator used for each session, and record the authenticator used for suspicious activity. This is helpful when investigating an incident. Some IDPSs can also use the authenticator information to define acceptable activity differently for multiple classes of users or specific users.

The “protocol analysis” performed by stateful protocol analysis methods usually includes reasonableness checks for individual commands, such as minimum and maximum lengths for arguments. If a command typically has a username argument, and usernames have a maximum length of 20 characters, then an argument with a length of 1000 characters is suspicious. If the large argument contains binary data, then it is even more suspicious.

Stateful protocol analysis methods use protocol models, which are typically based primarily on protocol standards from software vendors and standards bodies (e.g., Internet Engineering Task Force [IETF] Request for Comments [RFC]). The protocol models also typically take into account variances in each protocol’s implementation. Many standards are not exhaustively complete in explaining the details of the protocol, which causes variations among implementations. Also, many vendors either violate standards or add proprietary features, some of which may replace features from the standards. For proprietary protocols, complete details about the protocols are often not available, making it difficult for IDPS technologies to perform comprehensive, accurate analysis. As protocols are revised and vendors alter their protocol implementations, IDPS protocol models need to be updated to reflect those changes.

The primary drawback to stateful protocol analysis methods is that they are very resource-intensive because of the complexity of the analysis and the overhead involved in performing state tracking for many simultaneous sessions. Another serious problem is that stateful protocol analysis methods cannot detect attacks that do not violate the characteristics of generally acceptable protocol behavior, such as performing many benign actions in a short period of time to cause a denial of service. Yet another problem is that the protocol model used by an IDPS might conflict with the way the protocol is implemented in particular versions of specific applications and operating systems, or how different client and server implementations of the protocol interact.

MCQ

1) What are the different ways to intrude ? (Choose 3)

- a) Buffer overflows
- b) Unexpected combinations and unhandled input
- c) Race conditions
- d) Backdoor

Answer: a,b& c

2) What are major components of intrusion detection system ? (Choose 3)

- a) Analysis Engine
- b) Event provider
- c) Zone system
- d) Alert Database

Answer: a,b& d

3) What are the different ways to classify an IDS ? (Choose 3)

- a) anomaly detection
- b) signature based misuse
- c) stack based
- d) zone based

Answer: a,b& c

4) What are the different ways to classify an IDS ? (Choose 2)

- a) Zone based
- b) Host based
- c) Network based
- d) Level based

Answer: b & c

5) What are characteristics of anomaly based IDS ?

- a) It models the normal usage of network as a noise characterization

- b) It doesn't detect novel attacks
- c) Anything distinct from the noise is assumed to be intrusion activity
- d) It detects based on signature.

Answer: a & c

6) What is major drawback of anomaly detection IDS ?

- a) These are very slow at detection
- b) It generates many false alarms
- c) It doesn't detect novel attacks
- d) None of these

Answer: b

7) What are characteristics of signature based IDS ? (Choose two)

- a) Most are based on simple pattern matching algorithms.
- b) It is programmed to interpret a certain series of packets
- c) It models the normal usage of network as a noise characterization
- d) Anything distinct from the noise is assumed to be intrusion activity

Answer: a & b

8) What are drawbacks of signature based IDS ? (Choose two)

- a) They are able to detect novel attacks
- b) They suffer from false alarms
- c) They have to be programmed again for every new pattern to be detected
- d) They are unable to detect novel attacks

Answer: b, c and d

9) What are characteristics of Host based IDS ? (Choose 3)

- a) The host operating system logs in the audit information
- b) Logs include logins, file opens and program executions
- c) Logs are analysed to detect tails of intrusion
- d) Logs are archived daily

Answer: a,b& c

10) What are drawbacks of the host based IDS ? (Choose two)

- a) Unselective logging of messages may increase the audit burdens
- b) Selective logging runs the risk of missed attacks
- c) They are very fast to detect
- d) They have to be programmed for new patterns

Answer: a & b

11) What are strengths of the host based IDS ? (Choose three)

- a) Attack verification
- b) System specific activity
- c) No additional hardware required
- d) They are very fast

Answer: a,b& c

12) What are characteristics of stack based IDS ?

- a) They are integrated closely with the TCP/IP stack and watch packets
- b) The host operating system logs in the audit information
- c) It is programmed to interpret a certain series of packets
- d) It models the normal usage of network as a noise characterization

Answer: a.

13) What are characteristics of Network based IDS ? (Choose two)

- a) They look for attack signatures in network traffic
- b) Filter decides which traffic will be discarded or passed
- c) It is programmed to interpret a certain series of packets
- d) It models the normal usage of network as a noise characterization

Answer: a & b

14) What are strengths of Network based IDS ? (Choose three)

- a) Cost of ownership reduced

- b) Malicious intent detection
- c) Real time detection and response
- d) No addition hardware required

Answer: a,b& c

15) IDS may be configured to report attack occurrences. You just received a notification that an attack occurred, but after checking, you find that it really wasn't an attack at all. What is the term for this type of alarm?

- a) True positive
- b) False positive
- c) True negative
- d) False negative

Answer : b

=====

Chapter 2:Server Management & Firewall

Introduction to Firewalls

Server management of firewall

- **Firewall concepts**
- **Firewall implementation**
- **Firewall types**
- **DMZ**

What is a Firewall? and Why we need it.

A firewall is a “choke point/guard box” of controlling and monitoring the network traffic.

It allows interconnections between different networks with some level of trust.

It imposes restrictions on network services (only authorized traffic is allowed).

It enforces auditing and controlling access (alarms of abnormal behavior can be generated).

It provides perimeter defence.

Terminology:-

DeMilitarized Zone (DMZ): a portion of a network that is not fully protected and separates an internal network from an external network.

Guard: a host that mediates access to a network to allow or disallow certain types of access on the basis of a predefined policy.

Filtering firewalls: firewalls that perform access control based on the attributes of packet headers, rather than the content.

Proxy: an intermediate agent or server that acts on behalf of an endpoint without allowing a direct connection between two end points.

Proxy Firewall: is a firewall that uses proxies to perform access control. It uses on content and/or header information.

Network security domain: is a contiguous region of a network that operates under a single security policy.

Firewall properties:-

All firewalls must have the following three properties:

- All traffic between the networks must pass through it.
- Only authorized traffic, as defined by the *local* security policy, is allowed to pass through a firewall.
- The firewall machine/system itself SHOULD be immune to penetration.

Limitations of firewall:-

- A firewall cannot prevent users or attackers with modems from dialing in to or out of the internal network, thus bypassing the firewall and its protection completely.
- Firewalls cannot enforce your password policy or prevent misuse of passwords. Your password policy is crucial in this area because it outlines acceptable conduct and sets the ramifications of noncompliance.
- Firewalls are ineffective against nontechnical security risks such as social engineering, as discussed in Chapter 1, “There Be Hackers Here.”
- Firewalls cannot stop internal users from accessing websites with malicious code, making user education critical.
- Firewalls cannot protect you from poor decisions.
- Firewalls cannot protect you when your security policy is too lax.

Firewalls can be either hardware or software

Hardware Firewall:-

Hardware firewalls can be purchased as a stand-alone product but more recently hardware firewalls are typically found in broadband routers, and should be considered an important part of your system and network set-up, especially for anyone on a broadband connection. Hardware firewalls can be effective with little or no configuration, and they can protect every machine on a local network. Most hardware firewalls will have a minimum of four network ports to connect other computers, but for larger networks, business networking firewall solutions are available.

A hardware firewall uses packet filtering to examine the header of a packet to determine its source and destination. This information is compared to a set of predefined or user-created rules that determine whether the packet is to be forwarded or dropped.

Software Firewalls

For individual home users, the most popular firewall choice is a software firewall. Software firewalls are installed on your computer (like any software) and you can customize it; allowing you some control over its function and protection features. A software firewall will protect your computer from outside attempts to control or gain access your computer, and, depending on your choice of software firewall, it could also provide protection against the most common Trojan programs or e-mail worms. Many software firewalls have user defined controls for setting up safe file and printer sharing and to block unsafe applications from running on your system. Additionally, software firewalls may also incorporate privacy controls, web filtering and more. The downside to software firewalls is that they will only protect the computer they are installed on, not a network, so each computer will need to have a software firewall installed on it.

Like hardware firewalls there is a vast number of software firewalls to choose from. To get started you may wish to read reviews of software firewalls and search out the product Web site to glean some information first. Because your software firewall will always be running on your computer, you should make note of the system resources it will require to run and any incompatibilities with your operating system. A good software firewall will run in the background on your system and use only a small amount of system resources. It is important to monitor a software firewall once installed and to download any updates available from the developer.

The differences between a software and hardware firewall are vast, and the best protection for your computer and network is to use both, as each offers different but much-needed security features and benefits. Updating your firewall and your operating system is essential to maintaining optimal protection, as is testing your firewall to ensure it is connected and working correctly.

Types of firewall:-

Packet filter:-

The Packet Filtering Firewall is one of the most basic firewalls. The first step in protecting internal users from the external network threats is to implement this type of security. The first ever firewalls used were of packet filtering type only. As the trends of network threats started changing, so did the firewall building strategies. Most of the routers have packet filtering built-in, but the problem with the routers is that, they are difficult to

configure and don't provide extensive logs of the incidents. In my previous firewall tutorials I talked about firewall policies and few other things. That information is also used while designing such firewalls.

To start with the network security, the packet filtering firewalls are the way to go. This functionality is still the main aim of most of the commercial and non-commercial firewalls. As you know by the definition and the purpose of the firewall, the firewall is the first destination for the traffic coming to your internal network. So, anything which comes to your internal network, passes through the firewall. Of course, reverse is also true. Any outgoing traffic will also pass through the firewall before leaving your network completely. This is the reason that sometimes this type of firewall filter is also called **screening routers**.

Types of Packet Filtering

Packet filtering firewall allows only those packets to pass, which are allowed as per your firewall policy. Each packet passing through is inspected and then the firewall decides to pass it or not. The packet filtering can be divided into two parts:

1. Stateless packet filtering.
2. Stateful packet filtering.

The data travels through the internet in the form of packets. Each packet has a header which provides the information about the packet, its source and destination etc. The packet filtering firewalls inspect these packets to allow or deny them. The information may or may not be remembered by the firewall.

Stateless Packet Filtering

If the information about the passing packets is not remembered by the firewall, then this type of filtering is called stateless packet filtering. This type of firewalls are not smart enough and can be fooled very easily by the hackers. These are especially dangerous for UDP type of data packets. The reason is that, the allow/deny decisions are taken on packet by packet basis and these are not related to the previous allowed/denied packets.

Stateful Packet Filtering

If the firewall remembers the information about the previously passed packets, then that type of filtering is stateful packet filtering. These can be termed as smart firewalls. This type of filtering is also known as Dynamic packet filtering.

What Should Be Inspected In A Packet Header

In a packet header few of the possible things which should be checked are:

1. Source IP address of the packet. This is necessary because IP spoofers might have changed the source IP address to reflect the origin of packet from somewhere else, rather than reflecting the original source.
2. Destination IP Address. The firewall rules should check for IP address rather than DNS names. This prevents abuse of DNS servers.
3. IP Protocol ID.
4. TCP/UDP port number.
5. ICMP message type.
6. Fragmentation flags.
7. IP Options settings.

Important Features of Packet Filters

The great firewalls normally follow few specific rules upon which features are incorporated during firewall designing. Few are listed below:

1. The firewall should provide good deal of logs. The more detailed are the logs, the better the protection.
2. The command line syntax or GUI of firewall should be easy to create new rules and of course firewall exceptions.
3. The packet filter orders should be evaluated carefully in order to make the filtering fruitful.

At the end, a word of caution. You **SHOULD NOT** depend only upon packet filtering firewalls for the security of your network. Firewall network security is not fully reliable, we need to take several other measures in order to have full network security.

Application-Level Gateway

1. An application-level gateway, also called a proxy server because it acts as a relay of application-level traffic.
2. The user contacts the gateway using a TCP/IP application, such as Telnet or FTP, and the gateway asks the user for the name of the remote host to be accessed.
3. When the user responds and provides a valid user ID and authentication information, the gateway contacts the application on the remote host and relays TCP segments containing the application data between the two endpoints.
4. If the gateway does not implement the proxy code for a specific application, the service is not supported and cannot be forwarded across the firewall.
5. Further, the gateway can be configured to support only specific features of an application that the network administrator considers acceptable while denying all other features.

2. Advantages

1. Application-level gateways tend to be more secure than packet filters. Rather than trying to deal with the numerous possible combinations that are to be allowed and forbidden at the TCP and IP level, the application-level gateway need only scrutinize a few allowable applications.
2. In addition, it is easy to log and audit all incoming traffic at the application level.

Disadvantages

1. A prime disadvantage of this type of gateway is the additional processing overhead on each connection.
2. In effect, there are two spliced connections (Connection Point) between the end users, with the gateway at the splice point, and the gateway must examine and forward all traffic in both directions.

A circuit-level gateway :-

Circuit level gateways work at the session layer of the [OSI model](#), or as a "shim-layer" between the [application layer](#) and the [transport layer](#) of the [TCP/IP](#) stack. They monitor TCP handshaking between packets to determine whether a requested session is legitimate. Information passed to a remote computer through a circuit level gateway appears to have originated from the gateway. Circuit-Level Firewall applications represent the technology of next to first generation. Firewall technology supervise TCP handshaking among packets to confirm a session is genuine. Firewall traffic is clean based on particular session rules and may be controlled to acknowledged computers only. Circuit-level firewalls conceal the network itself from the external, which is helpful for interdicting access to impostors. But Circuit-Level Firewalls don't clean entity packets. This is useful for hiding information about protected networks. Circuit level gateways are relatively inexpensive and have the advantage of hiding information about the private network they protect. On the other hand, they do not filter individual packets.

INTRODUCTION OF DMZ:-

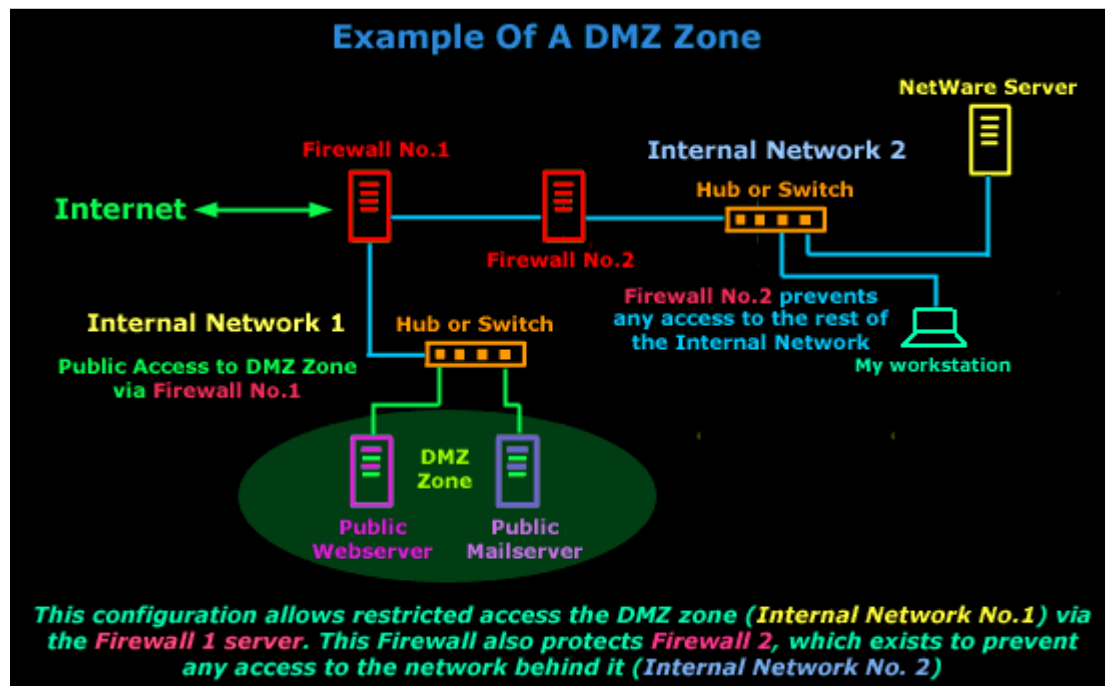
The De-Militarized Zone, or DMZ, is an expression that comes from the Korean War. There, it meant a strip of land forcibly kept clear of enemy soldiers. The idea was to accomplish this without risking your own soldiers' lives, thus mines were scattered throughout the DMZ like grated Romano on a plate of fettucine :) The term has been assimilated into the networking world, without the cheese :)

Another meaning to the term DMZ Zone is *a portion of your network which, although under your control, is outside your heaviest security*. Compared to the rest of your network, machines you place in the DMZ are less protected, or flat-out unprotected, from the Internet.

Once a machine has entered the DMZ, it should not be brought back inside the network again. Assuming that it has been compromised in some way, bringing it back into the network is a big security hazard. **Use of the DMZ**

If you decide to build one, what do you do with it? Machines placed in the DMZ usually offer services to the general public, like Web services, domain name services (DNS), mail relaying and FTP services (all these buzzwords will be explained next). Proxy servers can also go in the DMZ. If you decide to allow your

users Web access only via a proxy server, you can put the proxy in the firewall and set your firewall rules to permit outgoing access only to the proxy server.



As long as you've attended to the following points, your DMZ should be ok:

If you put a machine in the DMZ, it must be for a good reason. Sometimes, companies will set up a few workstations with full Internet access within the DMZ. Employees can use these machines for games and other insecure activities. This is a good reason if the internal machines have no Internet access, or extremely limited access. If your policy is to let employees have moderate access from their desktops, then creating workstations like this sends the wrong message. Think about it: The only reason why they would use a DMZ machine is if they were doing something inappropriate for the workplace !

It should be an isolated island, not a stepping stone. It must not be directly connected to the internal network. Furthermore, it shouldn't contain information that could help hackers compromise other parts of the network. This includes user names, passwords, network hardware configuration information etc.

It must not contain anything you can't bear to lose. Any important files placed on the DMZ should be read-only copies of originals located within the network. Files created in the DMZ should not be able to migrate into the network unless an administrator has examined them. If you're running a news server and would like to archive news, make sure the DMZ has its own archival system.

What sort of things shouldn't you do? Example: If you're running an FTP server in the DMZ, don't let users put confidential information on there so they can get it from home later.

It must be as secure a host as you can make it. Just because you're assuming it's secure doesn't guarantee that it is. Don't make it any easier for a hacker than absolutely necessary. A hacker may not be able to compromise your internal network from your DMZ, but they may decide to use it to compromise somebody else's network. Give serious thought to not running Windows on your DMZ machines; it's inherently insecure and many types of intrusions can't be detected on Windows. Linux or openbsd can provide most, if not all, the needed functionality along with a more secure environment.

MCQ

Questions:-

1) A firewall is a -----

a)choke point b)control unit c)Auditing point d)access point

2) DMZ means –

a) Data manipulation zone **b)Demilitarized zone** c)Data manufacturing zone d)Data mining zone

3) Only authorized traffic ,as defined by the local ----- policy ,is allowed to pass through a firewall.

a) network b)FTP **c)security** d)connection

4) Before you start to design your firewall ,it is important to study –

a) Environment b)Recovery area c)pc network **d)existing network architecture**

5) There are -----basic design policies of firewalls

a) **Two** b)Three c)Four d)Five

6) PFF means -----

a)Packet filling fewalls **b)packet filtering firewalls** c) packet force firewalls d)none of above

7) A stateful packet filtering firewall looks at each packet and applies rules or -----

a) checks b)contexts **c)test** d)tracks

8) A circuit level firewall doesn't simply allow or disallow packets but also determines whether the connection between both ends is valid---

State a) False **b>true**

9) Use an application specific gateway proxy to -----the traffic.

a) control b)avoid c)pass **d)analyse**

10) PF means ----

a) Proxy firewalls b) packet firewalls c)policy firewalls d)pass firewalls

11) Circuit level firewalls are working between the two layers ---

a) Physical-data link layer **b) session –Transport layer**

c) network –Transport layer d)Application-Presentation layer.

12) ----- can block binary content but allow text, and scan incoming FTP files for

Viruses.

a)TCP b)FTTP **c)MSFS** d)UDP

13) Firewalls can be implemented in hardware or -----

a) Program b)Printer c)network **d)software**

14) DMZ zone is portion of your network which although under your-----

a) control b) observation c)service d)protection

15) In a DMZ configuration most computer on the -----run behind computers also run outside the Firewall.

a)WAN **b)LAN** c)MAN d)none of above.

Answer key-

- 1)a 2)b 3)c 4)d 5)a 6)b 7)c 8) b 9)d 10)a
11)b 12)c 13)d 14)a 15)b

Descriptive questions:

- 1)What is firewall?
- 2)what are the different types of firewall?
- 3)what are the properties of firewalls?
- 4)Explain in detail DMZ?
- 5)what are the features of firewall?

=====

Chapter 3: Security For VPN & Next Generation

CONTENTS:

- ❖ **VPN SECURITY**
- ❖ **VARIOUS COMPUTING PLATFORMS: HPC , CLUSTER
AND GRID COMPUTING**
- ❖ **VIRTUALIZATION AND CLOUD TECHNOLOGY**

Abstract

VPN(Virtual Private Network)

Definition :- It is a generic term used to describe a communication network that uses any combination of technologies to secure a connection tunnelled through an otherwise unsecured or untrusted network.

Use:- It is used to protect/secure our data.

Tunneling technology used for secure your data.

In these IPSEC(Internet Protocol Security) is used ,is found by IETF(Internet Engineering Task Force).

In these Two Protocol are used:

- i)AH(Authentication Header):-It authenticates your data & integrate your data.
- ii)ESP(Encapsulated Security Payload):-It encrypt your data & assign virtual IP address.

Digital Watermarking is used for secure multimedia networks.

Various Computing Platforms:

i)HPC(High Performance Computing):- It is used for to solving critical mathematical equation & in defence. This Technology is used in Super Computer.

ii)Cluster Computing:- A cluster is a type of parallel or distributed processing system, which consists of a collection of interconnected stand-alone computers working together as a single, integrated computing resource.

This technology is used in Online Papers.

iii)Grid Computing:- Grid computing is the collection of computer resources from multiple locations to reach a common goal.

Virtualization:- Virtualization is the creation of a virtual (rather than actual) version of something, such as an Operating system ,a server ,a storage device or network resources.

Types of Virtualization:

Operating System Virtualization:- It is the use of software to allow a piece of hardware to run multiple operating system images at the same time. The technology got its start on mainframes decades ago, allowing administrators to avoid wasting expensive processing power.

Example : Vmware software etc.

Network virtualization :-It is a method of combining the available resources in a network by splitting up the available [bandwidth](#) into [channels](#), each of which is independent from the others, and each of which can be assigned (or reassigned) to a particular server or device in [real time](#). The idea is that virtualization disguises the true complexity of the network by

separating it into manageable parts, much like your partitioned hard drive makes it easier to manage your files.

Example: - Radio etc.

Storage virtualization:-It is the pooling of physical storage from multiple network storage devices into what appears to be a single storage device that is managed from a central console. Storage virtualization is commonly used in storage area networks ([SANs](#)).

Server virtualization:-It is the masking of server resources (including the number and identity of individual physical servers, processors, and operating systems) from server users. The intention is to spare the user from having to understand and manage complicated details of server resources while increasing resource sharing and utilization and maintaining the capacity to expand later.

Cloud Computing:- Cloud computing is the delivery of computing services over the Internet.

VPN (Virtual Private Network)

VPN (Virtual Private Network) is a generic term used to describe a communication network that uses any combination of technologies to secure a connection tunnelled through an otherwise unsecured or untrusted network. Instead of using a dedicated connection, such as leased line, a "virtual" connection is made between geographically dispersed users and networks over a shared or public network, like the Internet. Data is transmitted as if it were passing through private connections. VPN transmits data by means of tunnelling. Before a packet is transmitted, it is encapsulated (wrapped) in a new packet, with a new header. This header provides routing information so that it can traverse a shared or public network, before it reaches its tunnel endpoint. This logical path that the encapsulated packets travel through is called a tunnel. When each packet reaches the tunnel endpoint, it is "decapsulated" and forwarded to its final destination. Both tunnel endpoints need to support the same tunnelling protocol. Tunnelling protocols are operated at either the OSI (Open System Interconnection) layer two (data-link layer), or layer three (network layer). The most commonly used tunnelling protocols are IPsec, L2TP, PPTP and SSL. A packet with a private non-routable IP address can be sent inside a packet with globally unique IP address, thereby extending a private network over the Internet.

VPN SECURITY

VPN uses encryption to provide data confidentiality. Once connected, the VPN makes use of the tunnelling mechanism described above to encapsulate encrypted data into a secure tunnel, with openly read headers that can cross a public network. Packets passed over a public network in this way are unreadable without proper decryption keys, thus ensuring that data is not disclosed or changed in any way during transmission. VPN can also provide a data integrity check. This is typically performed using a message digest to ensure that the data has not been tampered with during transmission. By default, VPN does not provide or enforce strong user authentication. Users can enter a simple username and password to gain access to an internal private network

from home or via other insecure networks. Nevertheless, VPN does support add-on authentication mechanisms, such as smart cards, tokens and RADIUS.

III. COMMON VPN TUNNELING TECHNOLOGIES

The following tunnelling technologies are commonly used in VPN:

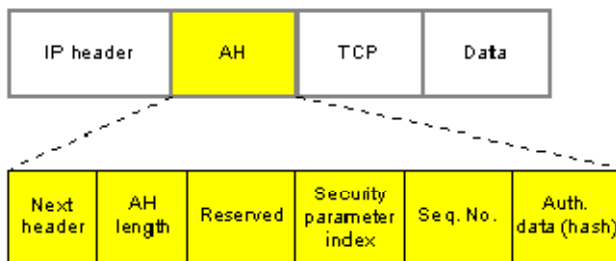
IPSEC (INTERNET PROTOCOL SECURITY)

IPsec was developed by IETF (the Internet Engineering Task Force) for secure transfer of information at the OSI layer three across a public unprotected IP network, such as the Internet. IPsec enables a system to select and negotiate the required security protocols, algorithm(s) and secret keys to be used for the services requested. IPsec provides basic authentication, data integrity and encryption services to protect unauthorised viewing and modification of data. It makes use of two security protocols, AH (Authentication header) and ESP (Encapsulated Security Payload), for required services. However, IPsec is limited to only sending IP packets.

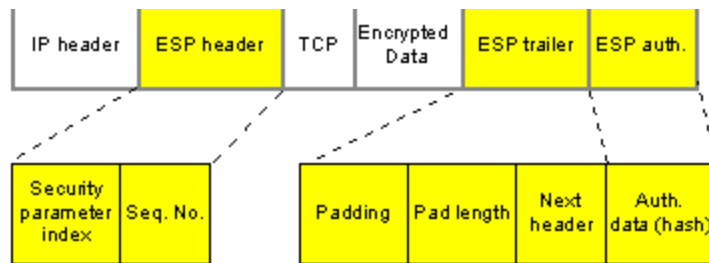
Security Protocols for Traffic Security

IPsec makes use of the AH and ESP protocols to provide security services:

1. AH (Authentication Header) protocol provides source authentication, and integrity of IP packets, but it does not have encryption. An AH header added to the IP packet contains a hash of the data, a sequence number etc., and information that can be used to verify the sender, ensure data integrity and prevent replay attacks



2. ESP (Encapsulated Security Payload) protocol provides data confidentiality, in addition to source authentication and integrity. ESP uses symmetric encryption algorithms, such as 3DES, to provide data privacy. The algorithm needs to be the same on both communicating peers. ESP can also support encryption-only or authentication-only configurations. However, research in 2007 showed that any RFC-compliant implementations of IPsec that make use of encryption-only ESP can be broken.

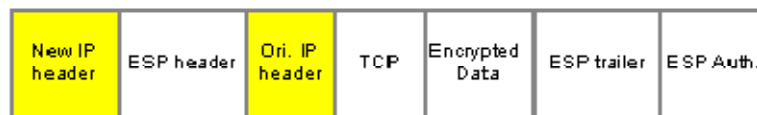


Modes of Operation

Each security protocol supports two modes of operation: a tunnel mode and a transport mode. Tunnel mode encrypts and/or authenticates the header and the data of each packet while transport mode only encrypts and/or authenticates the data itself.

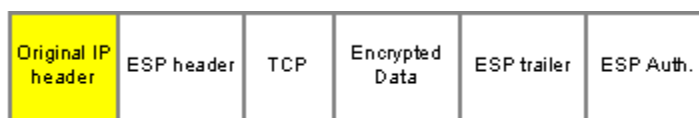
1. Tunnel mode (end-to-end)

Here the entire packet is protected. The original IP packet, with original destination address, is inserted into a new IP packet and the AH and ESP are applied to the new packet. The new IP header points to the end point of the tunnel. Upon receipt of the packet, the tunnel end point will decrypt the content and the original packet is further routed to its final destination in the target network.



2. Transport mode (host-to-host)

Here the AH and ESP headers are applied to the data of the original IP packet. The mode encrypts and / or authenticates the data but not the IP header. The overhead added is less than that required in tunnel mode. However, the final destination and source addresses could be sniffed. Attackers can perform traffic analysis based on header information in this type of header. It is generally only used for host-to-host connections.



Key Exchange and Management

IPsec supports two types of key management over the Internet: automated and manual.

1. Automated Key Management

IKE (Internet Key Exchange) is the default protocol used in IPsec to determine and negotiate protocols, algorithms and keys, and to authenticate the two parties. It is useful for widespread, scalable deployments and implementations of VPN. The IKEv2 protocol was released in 2005. It preserves most of the functionalities of IKEv1 protocol, but also supports the Network Address Translation (NAT) traversal and provides more flexibility. IKE also supports the use of digital certificates. Users authenticate by first signing the data with their digital signature key. The other endpoint will then verify the signature. IKE creates an authenticated, secure tunnel between two

entities, then negotiates a security association (SA) between the two entities, and exchanges key(s). SA is a set of parameters used by negotiating peers to define the services and mechanisms for protecting traffic. These parameters include algorithm identifiers, modes, keys, and so on. IKE also keeps track of the keys and updates them between communicating peers. IKE uses protocols like ISAKMP (The Internet Security Association and Key Management Protocol) and Oakley to define procedures for key generation, creation and management of SA and authentication.

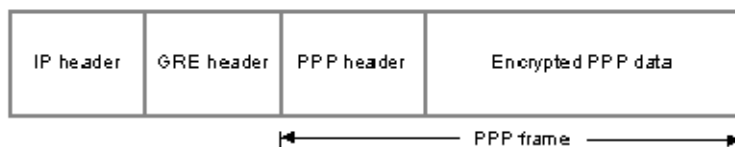
There are several authentication methods that an IPsec VPN gateway works with IKE for remote user authentication⁵, including hybrid authentication, eXtended authentication (Xauth), challenge/response authentication for cryptographic keys (CRACK), and digital certificates. This allows additional third-party authentication services to be used to strengthen the access control process.

2. Manual key management

Secret keys and security associations are manually configured in both VPN communicating peers before a connection starts. Only the sender and recipient know the secret key for the security services at hand. If the authentication data is valid, the recipient knows that the communication came from the sender and it was not modified. This approach is easy to use in small, static environments, but it does not scale well. All keys should be distributed to communicating peers securely beforehand. If the keys are compromised, another person could pose as the user and make a connection into the VPN.

PPTP (POINT-TO-POINT TUNNELING PROTOCOL)

PPTP (Point-to-Point Tunnelling Protocol) is an OSI layer two protocols built on top of the PPP (Point-to-point protocol). PPP is a multi-protocol, dial-up protocol used to connect to the Internet. Remote users can access a private network via PPTP by first dialling into their local ISP. PPTP connects to the target network by creating a virtual network for each remote client. PPTP allows a PPP session, with non-TCP/IP protocols (e.g. IP, IPX or NetBEUI), to be tunnelled through an IP network. PPTP is documented in RFC 2637 as an informational draft. The same authentication mechanism used for PPP connections is supported in a PPTP-based VPN connection. These include EAP (Extensible Authentication Protocol, MS-CHAP (Microsoft Challenge-Handshake Authentication Protocol), CHAP, SPAP (Shiva Password Authentication Protocol), and PAP (Password Authentication Protocol). For encryption, PPP data can be optionally encrypted using MPPE (Microsoft Point-to-Point Encryption) which is based on the RSA RC4 (40/56/128 bit) standard for link encryption.

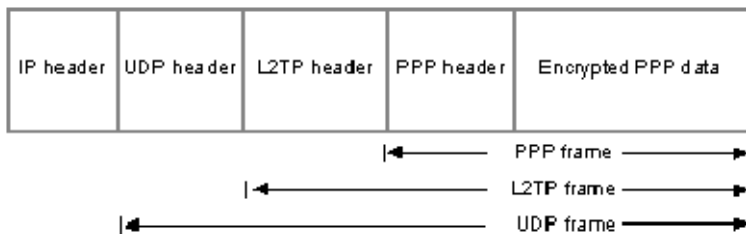


PPTP data tunnelling is accomplished through multiple levels of encapsulation. PPTP encapsulates PPP frames as tunnelled data for transmission over an IP network, such as the Internet or a private intranet, using a modified version of GRE (Generic Routing Encapsulation). GRE provides a flow and congestion controlled encapsulated service for carrying PPP packets. The data in the encapsulated PPP frames can be encrypted (and/or compressed). The resulting GRE-and-PPP-encapsulated data is then encapsulated with an IP header containing the

appropriate source and destination IP addresses for the PPTP client and PPTP server. Upon receipt of the PPTP tunnelled data, the PPTP server processes and removes the IP, GRE and PPP headers, then decrypts (and/or decompresses) the PPP data.

L2TP (LAYER 2 TUNNELING PROTOCOL)

L2TP (Layer 2 Tunneling Protocol) is a combination of Microsoft PPTP (Point-to-Point Tunneling Protocol) and Cisco L2F (Layer 2 Forwarding). L2TP can be used as a tunnelling protocol to encapsulate PPP (Point-to-Point Protocol) frames to be sent over IP, X.25, Frame Relay or ATM networks. Multiple connections are allowed through one tunnel. Like PPTP and L2F, L2TP operates on OSI layer two. Layer two VPN protocols encapsulate data in PPP frames and are capable of transmitting non-IP protocols over an IP network. L2TP is documented in RFC 3931 as standards track. L2TP connections use the same authentication mechanisms as PPP connections, such as EAP, CHAP, MS-CHAP, PAP and SPAP. L2TP tunnelling is accomplished through multiple levels of encapsulation. The PPP data is encapsulated within a PPP header and an L2TP header. The L2TP encapsulated packet is further wrapped in a UDP header with the source and destination ports set to 1701. The final packet is encapsulated with an IP header containing the source and destination IP addresses of the VPN client and VPN server.



Due to the lack of confidentiality provided by L2TP, it is often used in conjunction with IPsec and referred to as L2TP/IPsec. When L2TP is running over IPsec, security services are provided by IPsec, AH and ESP. All L2TP controls and data appear as homogeneous IP data packets to the IPsec system.

RISKS & LIMITATIONS OF VPN

HACKING ATTACKS

A client machine may become a target of attack, or a staging point for an attack, from within the connecting network. An intruder could exploit bugs or mis-configuration in a client machine, or use other types of hacking tools to launch an attack. These can include VPN hijacking or man-in-the-middle attacks:

1. VPN hijacking is the unauthorised take-over of an established VPN connection from a remote client, and impersonating that client on the connecting network.
2. Man-in-the-middle attacks affect traffic being sent between communicating parties, and can include interception, insertion, deletion, and modification of messages, reflecting messages back at the sender, replaying old messages and redirecting messages.

USER AUTHENTICATION

By default VPN does not provide / enforce strong user authentication. A VPN connection should only be established by an authenticated user. If the authentication is not strong enough to restrict

unauthorised access, an unauthorised party could access the connected network and its resources. Most VPN implementations provide limited authentication methods. For example, PAP, used in PPTP, transports both user name and password in clear text. A third party could capture this information and use it to gain subsequent access to the network.

CLIENT SIDE RISKS

The VPN client machines of, say, home users may be connected to the Internet via a standard broadband connection while at the same time holding a VPN connection to a private network, using split tunnelling. This may pose a risk to the private network being connected to. A client machine may also be shared with other parties who are not fully aware of the security implications. In addition, a laptop used by a mobile user may be connected to the Internet, a wireless LAN at a hotel, airport or on other foreign networks. However, the security protection in most of these public connection points is inadequate for VPN access. If the VPN client machine is compromised, either before or during the connection, this poses a risk to the connecting network.

Various Computing Platforms:

1:High Performance Computing:

Why do we need HPC?

- Larger and more complex mathematical models require greater computer performance. Scientific computing is replacing physical models, for example.
- When computer performance increases new problems can be attacked. To solve problems in a reasonable time using available resources in a good way we need competence in the following areas:
 1. algorithms
 2. hardware; limitations and possibilities
 3. code optimization
 4. parallelization and decomposition of problems and algorithms
 5. software tools

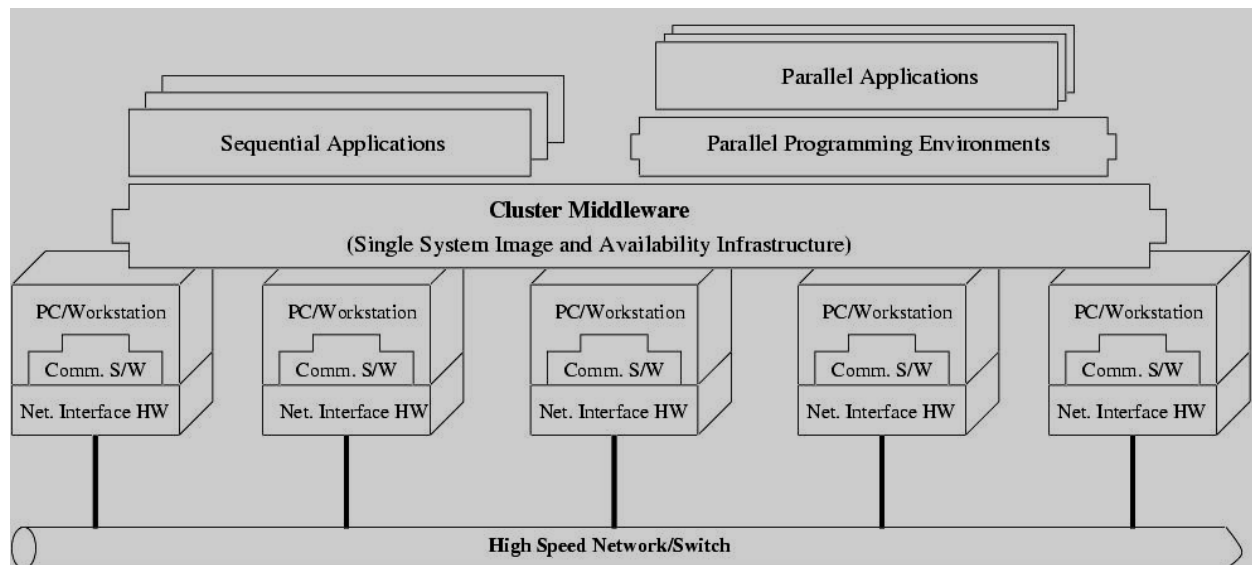
2:Cluster Computing:

Defination:

A cluster is a type of parallel or distributed processing system, which consists of a collection of interconnected stand-alone computers working together as a single, integrated computing resource.

Working:

A computer node can be a single or multiprocessor system (PCs, workstations, or SMPs) with memory, I/O facilities, and an operating system. A cluster generally refers to two or more computers (nodes) connected together. The nodes can exist and applications. Such a system can provide a cost-effective way to gain features and benefits (fast and reliable services) that have historically been found only on more expensive proprietary shared memory systems. The typical architecture of a cluster can be in a single cabinet or be physically separated and connected via a LAN. An inter-connected (LAN-based) cluster of computers can appear as a single system to users. A cluster is shown in Figure



****Cluster computer architecture****

Clusters offer the following features at a relatively low cost:

- _ High Performance
- _ Expandability and Scalability
- _ High Throughput
- _ High Availability

3:Grid Computing:

Defination:

Grid computing is the collection of computer resources from multiple locations to reach a common goal.

Working:

- a) The grid can be thought of as a distributed system with non-interactive workloads that involve a large number of files.
- b) Grid computing is distinguished from conventional high performance computing systems such as cluster computing in that grid computers have each node set to perform a different task/application.
- c) Grid computers also tend to be more heterogeneous and geographically dispersed (thus not physically coupled) than cluster computers.
- d) Although a single grid can be dedicated to a particular application, commonly a grid is used for a variety of purposes. Grids are often constructed with general-purpose grid middleware software libraries.
- e) Grid size varies a considerable amount. Grids are a form of distributed computing whereby a “super virtual computer” is composed of many networked loosely coupled computers acting together to perform large tasks. For certain applications, “distributed” or “grid” computing, can be seen as a special type of parallel computing that relies on complete computers (with onboard CPUs, storage, power supplies, network interfaces, etc.) connected to a network (private, public or the Internet) by a conventional network interface, such as Ethernet. This is in contrast to the traditional notion of a supercomputer, which has many processors connected by a local high-speed computer bus.

Virtualization

Defination:

Virtualization is the creation of a virtual (rather than actual) version of something, such as an Operating system ,a server ,a storage device or network resources.

Types Of Virtualization:

-  Operating System Virtualization
-  Network Virtualization
-  Storage Virtualization
-  Server Virtualization

-  Operating System Virtualization:- It is the use of software to allow a piece of hardware to run multiple operating system images at the same time. The technology got its start on mainframes decades ago, allowing administrators to avoid wasting expensive processing power.

- ✚ Network virtualization :-It is a method of combining the available resources in a network by splitting up the available [bandwidth](#) into [channels](#), each of which is independent from the others, and each of which can be assigned (or reassigned) to a particular server or device in [real time](#). The idea is that virtualization disguises the true complexity of the network by separating it into manageable parts, much like your partitioned hard drive makes it easier to manage your files.
- ✚ Storage virtualization:-It is the pooling of physical storage from multiple network storage devices into what appears to be a single storage device that is managed from a central console. Storage virtualization is commonly used in storage area networks ([SANs](#)).
- ✚ Server virtualization:-It is the masking of server resources (including the number and identity of individual physical servers, processors, and operating systems) from server users. The intention is to spare the user from having to understand and manage complicated details of server resources while increasing resource sharing and utilization and maintaining the capacity to expand later.

Cloud Computing

Introduction:

When you store your photos online instead of on your home computer, or use webmail or a social networking site, you are using a “cloud computing” service.

If you are an organization, and you want to use, for example, an online invoicing service instead of updating the in-house one you have been using for many years, that online invoicing service is a “cloud computing” service.

Cloud computing refers to the delivery of computing resources over the Internet. Instead of keeping data on your own hard drive or updating applications for your needs, you use a service over the Internet, at another location, to store your information or use its applications. Doing so may give rise to certain privacy implications.

Defination:

Cloud computing is the delivery of computing services over the Internet.

Description:

- a) Cloud services allow individuals and businesses to use software and hardware that are managed by third parties at remote locations.
- b) Examples of cloud services are:
 - ✚ online file storage
 - ✚ social networking sites
 - ✚ Webmail
 - ✚ online business applications.
- c) Cloud computing provides **computation**, **software**, **data access**, and **storage** resources without requiring cloud users to know the location and other details of the computing infrastructure.

- d) The cloud computing model allows access to information and computer resources from anywhere that a network connection is available.
- e) Cloud computing provides a shared pool of resources, including data storage space, networks, computer processing power, and specialized corporate and user applications.

Characteristics Of Cloud Computing:

- a) The characteristics of cloud computing include on-demand self service, broad network access, resource pooling, rapid elasticity and measured service.
- b) On-demand self service means that customers (usually organizations) can request and manage their own computing resources.
- c) Broad network access allows services to be offered over the Internet or private networks.
- d) Pooled resources means that customers draw from a pool of computing resources, usually in remote data centres.
- e) Services can be scaled larger or smaller; and use of a service is measured and customers are billed accordingly.

Types of Cloud Computing:

-  **Public Cloud**
-  **Private Cloud**
-  **Community Cloud**

Public Cloud:- They are offered over the Internet and are owned and operated by a cloud provider. Some examples include services aimed at the general public, such as online photo storage services, e-mail services, or social networking sites. However, services for enterprises can also be offered in a public cloud.

Private Cloud:- This cloud infrastructure is operated solely for a specific organization, and is managed by the organization or a third party.

Community Cloud:- This service is shared by several organizations and made available only to those groups. The infrastructure may be owned and operated by the organizations or by a cloud service provider.

****Multiple Choice Questions****

1) _____ is not a tunnelling protocol.

- a) IPsec b) L2TP c) PPTP d) SET

Answer: d) SET

2) AH (Authentication Header) Protocol provides source authentication & _____

- a) Integrity b) Confidentiality c) Encryption d) None

Answer: a) Integrity

3) _____ Computing is the collection of computer resources from multiple locations to reach a common goal.

- a) Cloud b) Grid c) Cluster d) Virtualization

Answer: b) Grid

4) L2TP (Layer Two Tunnelling Protocol) is a combination of Microsoft PPTP & _____.
a) Cisco L2F b) APAP c) CHAP d) PAP

Answer: d)SET

5) IPsec (Internet Protocol Security) was developed by_____
a) IETF b) IEEE c) OSI d) ESP

Answer: a) IETF

6) Virtualization is the creation of _____ version of something.
a) Actual b) Virtual c) Duplicate d) None

Answer a) Actual

7) _____ is not a type of cloud computing.
a) Public b) Private c) Community d) Local

Answer: d) Local

8) _____ data we can store on Gmail.
a) 4 MB b) 1 GB c) 15 GB d) 3 MB

Answer: a) 4 MB

9) _____ technology is used in VPN (Virtual Private Network).
a) Encryption b) Tunnelling c) Cluster d) None

Answer: b) Tunnelling

10) HPC stands for _____.
a) Highly Performance Computing b) High Protocol Computing
c) High Protocol Cluster d) High Performance computing

Answer: d) High Performance computing

11) _____ is the masking of server resources.
a) Network Virtualization b) Storage Virtualization
c) Server Virtualization d) Operating System Virtualization

Answer: c) Server Virtualization

12) _____ type of VPN is by default installed in our device.
a) SSL VPN b)

Answer: a) SSL VPN

=====

Module 4: System & Application Security

Chapter 1: Security Architecture and Models.

1: Designing Secure O.S.

2:Control to enforce security service

3: Information security model

Security Models and Architecture

Computer security can be a slippery term because it means different things to different people. There are many aspects of a system that can be secured, and security can happen at various levels and to varying degrees. We have stated in previous chapters that information security is made up of the following main attributes:

- **Availability** Prevention of loss of access to resources and data
- **Integrity** Prevention of unauthorized modification of data
- **Confidentiality** Prevention of unauthorized disclosure of data

Computer Architecture

Put the processor over there by the plant, the memory by the window, and the secondary storage upstairs.

Computer architecture encompasses all the parts of a computer system necessary for it to function, including the operating system, memory chips, circuits, hard drive, security components, buses, and networking components. The interrelationships and internal working of all of these parts can be quite complex, and making them work together in a secure fashion is comprised of complicated methods and mechanisms. Thank goodness for the smart people who figured this stuff out! Now it is up to us to learn how they did it and why. The more you understand how these different pieces work and process data, the more you will understand how vulnerabilities actually occur and how countermeasures work to impede and hinder vulnerabilities from being introduced, found, and exploited.

Central Processing Unit

Hey, when is it my turn to use the CPU? Answer: When the control unit says it's your turn.

The **central processing unit (CPU)** is a microprocessor that contains a control unit, an **arithmetic logic unit (ALU)**, and registers, which are holding places for data and instructions.

The **control unit** manages and synchronizes the system while different applications' code and operating system instructions are being executed. It determines what application instructions get processed and in what priority and time slice. It controls when instructions are executed and this execution enables applications to process data. The control unit does not actually process the data; it is like the traffic cop telling traffic when to stop and start again.

Memory

The operating system instructions, applications, and data are held in memory, but so are the basic input/output system (BIOS), device controller instructions, and firmware. They do not all reside in the same memory location or even the same type of memory.

The different types of memory, what they are used for, and how each is accessed can get a bit confusing because the CPU deals with several different types for different reasons.

The following paragraphs quickly outline the different types of memory within a computer system.

Random access memory (RAM) is a type of temporary storage facility where data can be held and altered. It is used for read/write activities by the operating system and applications.

It is described as *volatile* because if the computer's power supply is terminated, then all information within this type of memory is lost. There are different types of

RAM, but the most well-known types are dynamic and static RAM. *Static RAM* lives up to its name, because when it stores data, it stays there without the need of being continually refreshed. *Dynamic RAM*, on the other hand, requires that the data held within it be periodically refreshed because the data can dissipate and decay.

Read-only memory (ROM) is a *nonvolatile* storage facility, meaning that when a computer's power is turned off, the data is still held within the memory chips. For the most part, when data is inserted into ROM memory chips, it cannot be altered. The software that is stored within ROM is called *firmware*.

Erasable and programmable read-only memory (EPROM) can be modified, deleted, or upgraded. EPROM holds data that can be electrically erased or written to.

CPU Modes and Protection Rings

If I am corrupted, very bad things can happen. Response: Then you need to go into ring 0.

If an operating system is going to be stable, it must be able to protect itself from its users and their applications. This requires the capability to distinguish between operations performed on behalf of the operating system itself and operations performed on behalf of the users or applications. This can be complex because the operating system software can be accessing memory segments, sending instructions to the CPU for processing, and accessing secondary storage devices. Each user application (e-mail client, antivirus, Web browser, word processor, personal firewall, and so on) can be attempting the same types of activities at the same time. The operating system must keep track of all of these events and ensure that none of them violates the security policy.

The operating system has several protection mechanisms to ensure that processes do not negatively affect each other or the critical components of the system itself. One has already been mentioned: memory segments. Another security mechanism that the system uses is **protection rings**. These rings provide strict boundaries and definitions for what the processes that work within each ring can access and what operations they can successfully execute. The processes that operate within the inner rings have more privileges than the processes operating in the outer rings. This is because the inner rings only permit the most trusted components and processes to operate within them. Although operating systems can vary in the number of protection rings, processes that execute within the inner rings are usually referred to as existing in a **privileged**, or supervisor,

mode. The processes working in the outer rings are said to execute in a **user mode**.

Operating system components operate in a ring that gives them the most access to memory locations, peripheral devices, system drivers, and sensitive configuration parameters.

Because this ring provides much more dangerous access to critical resources, it is the most protected. Applications usually operate in ring 3, which limits the type of memory, peripheral device, and driver access activity, and is controlled through the operating system functions or system calls. The type of commands and instructions that are sent to the CPU from applications in the outer rings are more restrictive in nature. If an application tries to send instructions to the CPU that fall outside of its permission level, the CPU treats this violation

as an exception and may show a general protection fault, panic, or exception error and attempt to shut down the offending application.

Protection rings support the availability, integrity, and confidentiality requirements of multitasking operating systems. Many systems use four protection rings:

- **Ring 0** Operating system kernel
- **Ring 1** Remaining parts of the operating system
- **Ring 2** I/O drivers and utilities
- **Ring 3** Applications and programs

These protection rings provide an intermediate layer between subjects and objects, and are used for access control when a subject tries to access an object. The ring determines the access level to sensitive system resources. The lower the number, the greater the amount of privilege that is given to the process that runs within that ring. Each subject and object is logically assigned a number (0 through 3) depending upon the level of trust the operating system assigns it. A subject in ring 3 cannot directly access an object

In ring 1, but subjects in ring 1 can directly access an object in ring 3. Entities can only access objects within their own ring and outer rings, as shown. When an application needs access to components in rings that it is not allowed to directly access, it makes a request of the operating system to perform the necessary tasks. This is handled through system calls, where the operating system executes instructions not allowed in user mode. The request is passed off to an operating system service, which works at a higher privilege level and can carry out the necessary task. When the operating system executes instructions for processes in rings 0 and 1, it operates in system mode or privileged mode. When the operating system executes instructions for applications and processes in ring 3, it operates in user mode. User mode provides a much more restrictive environment for the application to work in, which in turn protects the system from misbehaving programs.

Operating States

I am in a problem state. Is that bad? Answer: Nope, the CPU is just carrying out your request.

The operating system itself can be in one of two modes at any given point in time. The operating system can operate in privileged (supervisor state) or user mode (problem state) depending on what process made a request to execute instructions, but there are also different *operating states* in which the different processes can work within. The following outlines the four possible states a process can operate in:

- **Stopped** The process is not running.
- **Waiting** The process is waiting for an interrupt to be able to interact with the CPU.
- **Running** The process's instructions are being executed by the CPU.
- **Ready** The process is available to be used and waiting for an instruction.

These protection rings, operational modes, and operating states work together to ensure a secure and predictable operating environment. They enable the system to protect itself and work to protect the availability, integrity, and confidentiality of the system, the information that is being processed, and the applications installed.

segment, and the two would not know that each other even existed. This way the two applications do not interact with each other's data in memory or step on each other's toes while being executed by the CPU. It is a very orchestrated, controlled, and timed event-oriented atmosphere. An analogy is two people with two different offices. George has his office, computer, file cabinet, closet, and window. Marge has an office with the same materials. If George and Marge had to use the same computer, file cabinet, and closet, they could easily move each other's items around, accidentally delete each other's files, or wear each other's coat home. However, because they each have their own office and components, these events will not take place. The granularity of this type of separation and protection becomes very detailed within a computer system. A process is used to request resource access and carry out data manipulation activities, and is the mechanism used to enable applications and the operating system to communicate. A process is like a phone call. If an application wants to print a form, it calls (or communicates via a process) the operating system, which calls the printer driver, and the printer driver calls the printer. These processes can only communicate in a way that has been previously approved by the operating system and outlined in the security model. The application cannot make a direct call to the printer driver because it does not operate in a privileged ring; thus, it does not have the necessary type of authority. The security architecture of the operating system dictates this type of communication authority.

Input/Output Device Management

When a user chooses to print a document, or a word processor displays a file previously stored, or if a user saves files to a zip drive, these requests are going from the application the user is working in, through the operating system, and to the device requested. The operating system uses a device driver to communicate to a device controller, which is an electrical component with its own software used to provide a communication path that enables the device and operating system to exchange data. The operating system sends commands to the device controller's registers and the controller then writes data to the peripheral device or extracts data to be processed by the CPU, depending on the given commands.

System Architecture

Designing a system from the ground up is a complicated task and has many intricate and abstract goals that have to be achieved through mathematics, logic, design, programming code, and implementation. There are fundamental design decisions that need to be made when constructing a system. Security is only one of the goals of a system, but it is the goal security professionals are most concerned about. Availability, integrity, and confidentiality can be enforced at different places within an enterprise. For example, a company may store customer credit card information in a database that many users can access. This information, obviously, requires protection to ensure that it is not accessed or modified in an unauthorized manner. We start with general questions and gradually drill down into the details. Where should this protection be placed? Should there be access controls that screen users when they log in and assign them their rights at that point dictating what data they can and cannot access? Should the data files holding the credit card information be protected at the file system level?

Should protection be provided by restricting users' operations and activities? Or should there be a combination of all of these? The first and most general question is "Where should the protection take place: at the user's end, where the data is stored, or by restricting user activities within the environment. Once these general questions have been answered, the placement of the mechanisms needs to be addressed. Security mechanisms can be placed at the hardware, kernel, operating

system, services, or program layers. At which layer(s) should security mechanisms be implemented? If protection is implemented at the hardware layer, the protection mechanisms will be more simplistic and provide broad and general protection. As we ascend up the layers, more complexity is added, and functionality becomes more specific and granular. The top layer holds the most complexity because it is directed toward providing the user with a vast amount of functionality and options. Functionality and complexity of security increases as it approaches the layers that are closer to the user. The increased complexity lowers the assurance levels of the security mechanisms. The more complex a security mechanism becomes, the less assurance it provides. This

is because the complexity of the mechanism demands more technical understanding from the individuals who install, test, maintain, and use it. The more complex the tools, the more chances there are for errors, and therefore increased chances for security compromises. The more complex the security mechanism, the harder it is to fully test it under all possible conditions. On the other hand, simplistic mechanisms cannot provide the desired richness of functionality and options, although they are easier to install, maintain, use, and test. So the tradeoffs between functionality and assurance need to be fully understood to make the right security mechanism choices when designing a system. Once the designers have an idea of what the security mechanisms should focus on (users, operations, or data), what layer(s) the mechanisms should be placed at (hardware, kernel, operating system, services, or program), and the complexity of each mechanism, the mechanisms need to be built and integrated in a way to have a proper relationship with other parts of the system.

The first step is to decide what system mechanisms need to be trusted and specify how these entities can interact in a secure manner. Although it might seem that you would want to trust all the components within the system, this would cause too much overhead, complexity, and performance bottlenecks. For a mechanism to be trusted, it means that it protects itself and the data it is processing, it performs in predictable and secure manners, and it does not adversely affect other trusted or untrusted mechanisms. In return, these trusted components have access to more privileged services, have direct access to memory, usually have higher priority when requesting CPU processing time, and have more control over system resources. So the trusted subjects and objects need to be identified and distinguished from the untrusted ones and placed into defined subsets.

As functionality
increases,
complexity
increases and
the assurance of
security decreases.

Defined Subset of Subjects and Objects

I totally trust you. You can do whatever you want. Response: I want to leave.

As stated previously, not all components need to be trusted and therefore do not fall within the **trusted computing base (TCB)**. The TCB is defined as the total combination of protection mechanisms within a computer system. The TCB includes hardware, software, and firmware. These are part of the TCB because the system is sure that these components will enforce the security policy and not violate it. The components that do fall under the TCB need to be identified and their accepted capabilities defined. For example, a system that has a lower trust level rating may permit all authenticated users to access and modify all files on the computer. This subset of subjects and objects is large and the relationship between them is loose and relaxed. A system with a much higher trust level rating may permit only two subjects to access all files on a computer system, and only one of those subjects can actually modify all the files. This subset is much smaller and the rules being enforced are more stringent and detailed. Again, it depends upon what type of system the developers are aiming at building. If developers want to develop a system that achieves an Orange Book security rating of D (very low), then what makes up the TCB or not is not much of an issue because the system will not be expected to provide a very high level of security. However, if the developers want to develop a system with an Orange Book rating of B2 or B1 (much higher than rating D), they will need to specify what makes up the TCB. They need to enforce strict rules that dictate how subjects and objects interact. The developers also need to ensure that these items are identified, authenticated, and audited because these are the components that will be scrutinized, tested, and evaluated before a rating of B2 or B1 can be given.

Trusted Computing Base

The term “trusted computing base” originated from the Orange Book and does not address the level of security a system provides, but the level of trust, albeit from a security sense. The Orange Book defines a trusted system as hardware and software that utilize measures to protect the integrity of unclassified or classified data for a range of users without violating access rights and the security policy. It looks at all protection mechanisms within a system to enforce the security policy and provide an environment that will behave in a manner expected of it. This means that each layer of the system must trust the underlying layer to perform the expected functions, provide the expected functionality, and operate in an expected manner under many different situations. When the operating system makes calls to hardware, it is anticipating data to be returned in a specific data format and to behave in a consistent and predictable manner. Applications that run on top of the operating system expect to be able to make certain system calls and receive the required data in return and to be able to operate in a reliable and dependable environment. Users expect the hardware, operating system, and applications to perform in particular fashions and provide a certain level of functionality. For all of these actions to behave in such predictable manners, the requirements of a system must be addressed in the planning stages of development, not afterwards.

Security Perimeter

Now, whom do we trust? Answer: Anyone inside the security perimeter.

As stated previously, not every component and resource falls within the TCB, so some resources fall outside of this imaginary boundary referred to as the **security perimeter**. A perimeter is a

boundary that divides the trusted from the untrusted. For the system to stay in a secure and trusted state when a component within the TCB needs to communicate with a component outside of the TCB, precise communication standards must be developed to ensure that this type of communication cannot bring on unexpected security compromises. This type of communication is handled and controlled through interfaces.

For example, a resource that is within the boundary of the TCB, or security perimeter, must not pass confidential information to resources outside the TCB. The resource within the TCB must also be careful about the commands and information it accepts from less-trusted resources. These limitations and restrictions are built into the interfaces that permit this type of communication to take place and are the mechanisms that enforce the security perimeter, as shown in Figure 5-11. Communication between trusted components and untrusted components needs to be controlled to ensure that confidential information does not flow in an unintended way.

Reference Monitor and Security Kernel

Up to now, our computer system architecture developers have accomplished many things in developing their system. They have defined where the security mechanisms will be located (hardware, kernel, operating system, services, or program), they have defined the objects that are within the TCB and how those components will interact with each other. The security perimeter that separates the trusted components and the untrusted components has been constructed. They have developed proper interfaces for these entities to communicate securely. Now they need to develop and implement a mechanism that ensures that the subjects that access objects have been given the necessary permissions to do so. This means the developers need to develop and implement a reference monitor and security kernel.

The *reference monitor* is an abstract machine, which mediates all access subjects have to objects to ensure that the subjects have the necessary access rights and to protect the objects from unauthorized access and destructive modification. For a system to achieve a higher level of trust, it must enforce subjects (programs, users, or processes) to be fully authorized prior to accessing an object (file, program, or resource). It must be made certain that the subject has been granted access privileges prior to letting the subject use the requested object. The reference monitor is an access control concept, not an actual physical component, and that is why it is normally referred to as the “reference monitor concept.”

The *security kernel* is made up of mechanisms that fall within the TCB and implements and enforces the reference monitor concept. The security kernel is made up of hardware, firmware, and software components that mediate all access and functions between subjects and objects. The security kernel is the core of the TCB and is the most commonly used approach to building trusted computing systems. There are four main requirements of the security kernel:

- It must provide isolation for the processes carrying out the reference monitor concept and they must be tamperproof.
- The reference monitor must be invoked for every access attempt and must be impossible to circumvent. Thus, the reference monitor must be implemented in a complete and foolproof way.
- The reference monitor must be verifiable as being correct. This means that all decisions made by the reference monitor should be written to an audit log, and

verified as being correct.

- It must be small enough to be able to be tested and verified in a complete and comprehensive manner.

These are the requirements of the reference monitor; therefore, they are the requirements of the components that provide and enforce the reference monitor concept—the security kernel.

These issues work in the abstract, but are implemented in the physical world of hardware devices and software code. The assurance that the components are enforcing the abstract idea of the reference monitor is proved through testing and functionality.

Domains

Okay, here are all the marbles you can play with. We will call that your domain of resources.

A **domain** is defined as a set of objects that a subject is able to access. This domain can be all the resources a user can access, all the files available to a program, the memory segments available to a process, or the services and processes available to an application. A subject needs to be able to access and use objects (resources) to perform tasks, and the domain defines which objects are available to the subject and which objects are untouchable and therefore unusable by the subject.

These domains have to be identified, separated, and strictly enforced. An operating system may work in a privileged mode and a user mode. The reason to even use these two different modes is to define two different domains. The privileged mode has a much larger domain to work with (or more resources to access); thus, it can provide much more functionality. When an operating system works in privileged mode, it can physically access memory modules, transfer data from an unprotected domain to a protected

domain, and directly access and communicate with hardware devices. An application that functions in user mode cannot access memory directly and has a more limited amount of resources available to it. Only a certain segment of memory is available to this application and it must be accessed in an indirect and controlled fashion. The application can copy files only within its own domain and cannot access hardware directly.

A program that resides in a privileged domain needs to be able to execute its instructions and process its data with the assurance that programs in a different domain cannot negatively affect its environment. This is referred to as an **execution domain**. Because programs in a privileged domain have access to sensitive resources, the environment needs to be protected from rogue program code or unexpected activities resulting from programs in other domains. Some systems may only have distinct user and privilege areas, whereas other systems may have complex architectures that contain up to ten security domains.

A security domain has a direct correlation to the protection ring that a subject or object is assigned to. The lower the protection ring number, the higher the privilege and the larger the security domain. This concept is depicted in Figure 5-13.

Security Models

An important concept in the design and analysis of secure systems is the security model, because it incorporates the security policy that should be enforced in the system. A model is a symbolic representation of a policy. It maps the desires of the policy makers

into a set of rules that are to be followed by a computer system.

We have continually mentioned the security policy and its importance, but it is an abstract term that represents the objectives and goals a system must meet and accomplish to be deemed secure and acceptable. How do we get from an abstract security policy to an administrator being able to uncheck a box on the graphical user interface (GUI) to disallow David from accessing configuration files on his system? There are many complex steps in between that take place during the system's design and development.

A security model maps the abstract goals of the policy to information system terms by specifying explicit data structures and techniques necessary to enforce the security policy. A security model is usually represented in mathematics and analytical ideas, which are then mapped to system specifications, and then developed by programmers through

A security policy outlines goals with no idea of how they would be accomplished. A model is a framework that gives the policy form and solves security problems for particular situations. Several security models have been developed to enforce security policies, and the following sections provide overviews of each model.

State Machine Models

No matter what state I am in, I am always trustworthy.

In **state machine models**, to verify the security of a system, the state is used, which means all current permissions and all current instances of subjects accessing objects

Analogy of the Relationship Between a Security Policy and a Security Model

If someone tells you to live a healthy and responsible life, this is a very broad, vague, and abstract notion. So when you ask this person how this is accomplished, they outline the things you should and should not do (do not harm others, do not lie, eat your vegetables, and brush your teeth). The security policy provides the abstract goals, and the security model provides the dos and don'ts necessary to fulfill these goals.

must be captured. Maintaining the state of a system deals with each subject's association with objects. If the subjects can only access objects by means that are concurrent with the security policy, the system is secure. State machines have provided a basis for important security models. A state of a system is a snapshot of a system in one moment of time. There are many activities that can alter this state, which is referred to as a **state transition**. The developers of an operating system that will implement the state machine model need to look at all of the different state transitions that are possible and assess if a system starts up in a secure state, can any of these events put the system into an insecure state? If all of the activities that are allowed to happen in the system do not compromise the system and put it into an insecure state, then the system executes a secure state machine model.

So a system that has employed a state machine model will be in a secure state in each and every instance of its existence. It will boot up into a secure state, execute commands and transactions securely, allow subjects to access resources only in secure states, and shut down and fail in a secure state. Failing in a secure state is extremely important. It is imperative that if anything unsafe takes place that the system can "save itself" and not make itself vulnerable. When a user sees error messages, or a system reboots or freezes, these are all safety measures. The operating system has experienced something

that is deemed illegal and it cannot take care of the situation itself, so to make sure it does not enter an insecure state it reacts in one of these fashions. So if an application or system freezes on you, know that it is the system just trying to protect itself and your data.

Bell-LaPadula Model

I don't want anyone to know my secrets. Response: We need Mr. Bell and Mr. LaPadula in here then.

In the 1970s, the U.S. military used time-sharing mainframe systems and was concerned about the security of these systems and leakage of classified information. The **Bell-LaPadula model** was developed to address these concerns. It was the first mathematical model of a multilevel security policy used to define the concept of a secure state machine and modes of access and outline rules of access. Its development was funded by the U.S. government to provide a framework for computer systems that would be used to store and process sensitive information. The model's main goal is to prevent secret information from being accessed in an unauthorized manner.

A system that employs the Bell-LaPadula model is called a multilevel security system because users with different clearances use the systems, and the systems process data with different classifications. The level at which information is classified determines the handling procedures that should be used. These access rights together form a **lattice**, which is an upper bound and lower bound of authorized access. A subject that has top secret clearance can access top-secret, secret, and unclassified data. Top secret is the upper bound and unclassified is the lower bound. Mandatory access control is based on a lattice of security labels.

The Bell-LaPadula model is a state machine model enforcing the confidentiality aspects of access control. A matrix and security levels are used to determine if subjects can access different objects. The subject's clearance is compared to the object's classification; if the clearance is higher or equal to the object's classification, the subject can access the object without violating the security policy.

The model uses subjects, objects, access operations (read, write, and read/write), and security levels. Subjects and objects can reside at different security levels and have relationships and rules dictating the acceptable activities between them. If properly implemented and enforced, this model has been mathematically proven to prevent data from a higher security level from flowing to a lower security level. It is an **information flow security model** also, which means that information does not flow in an insecure manner.

The Bell-LaPadula model is a subject-to-object model. An example would be how you could take an element from a specific database and write it into another database. The Bell-LaPadula has a focus of ensuring that subjects are properly authenticated, by having the necessary security clearance and need-to-know, before accessing an object. There are three main rules used and enforced in the Bell-LaPadula model: the simple security rule, the *-property rule, and the strong star property rule. The **simple security rule** states that a subject at a given security level cannot *read* data that resides at a higher security level. The ***-property rule** states that a subject in a given security level cannot *write* information to a lower security level. The simple security rule is referred to as the "no read up" rule, and the *-property rule is referred to as the "no write down" rule,

The third rule, the **strong star property rule**, states that a subject

that has read and write capabilities can only perform those functions at the same security level, nothing higher and nothing lower. The simple security and *-property rules, and the strong star property rule, indicate what states the system can go into. The state of a system changes as different operations take place. The Bell-LaPadula model defines a secure state, meaning a secure computing environment and the allowed actions, which are security-preserving operations. This means that the model provides a secure state and only permits operations that will keep the system within a secure state and not let it enter into an insecure state. So if 100 people access 2,000 objects in a day using this one system, this system is put through a lot of work and several complex activities have to take place. However, at the end of the day, the system is just as secure as it was in the beginning of the day. This is the definition of the Basic Security Theorem used in computer science.

Biba Model

The *Biba model* was developed after the Bell-LaPadula model. It uses a state machine model and is very similar to the Bell-LaPadula model. Biba addresses the integrity of data being threatened when subjects at lower integrity levels are able to write to objects at higher integrity levels and when subjects can read data at lower levels. If implemented and enforced properly, the Biba model prevents data from any *integrity* level from flowing to a higher integrity level. Biba has two main rules to provide this type of protection. The first rule, referred to as “no write up,” states that a subject cannot write data to an object at a higher *integrity* level. The second rule, referred to as “no read down,” states that a subject cannot read data from a lower integrity level. This second rule might sound a little goofy, but it is protecting the subject and data at a higher integrity level from being corrupted by data in a lower integrity level. An analogy would be if you were writing an article for the *New York Times* about the security trends over the last year, the amount of money businesses lost, and the cost/benefit ratio of implementing firewalls, intrusion detection systems, and vulnerability scanners. You do not want to get your data and numbers from any old Web site without knowing how those figures were calculated and the sources of the information. Your article (data at a higher integrity level) can be compromised if mixed with unfounded information from a bad source (data at a lower integrity level).

When first learning about the Bell-LaPadula and Biba models, they seem very similar, and the reasons for their differences may bring about some confusion. The Bell-LaPadula model was written for the U.S. government, and the government is very paranoid about the leakage of their secret information. In their model, a user cannot write to a lower level because that user might let out some secrets. Similarly, a user at a lower level cannot read anything at a higher level because that user might learn some secrets. However, not everyone is so worried about confidentiality and has such big, important secrets to protect. The commercial industry is more concerned about the integrity of its data. An accounting firm is more worried about keeping their numbers straight and making sure decimal points are not dropped or extra zeros are not added in a process carried out by an application. The accounting firm is more concerned about the integrity of this data and is usually under little threat of someone trying to steal these numbers, so they would employ the Biba model. Of course, the accounting firm does not look for the name Biba on the back of a product or make sure it is in the design of their application.

It is something that was decided upon and implemented when the application was being developed. The security ratings are what consumers use to determine if a system is right for them. So even if the accountants are using a system using the Biba model, they would not know (and we're not going to tell them).

Clark-Wilson Model

The *Clark-Wilson model* was developed after Biba and takes some different approaches to protecting the integrity of information by focusing on preventing authorized users from making unauthorized modification of data, or commit fraud and errors within commercial applications.

As stated earlier, military institutions are usually more concerned about confidentiality, and the commercial sector is usually more concerned with the integrity of the data they process. In the Clark-Wilson model, users cannot access and manipulate objects directly, but must access the object through a program. This provides another layer of protection between the subject and the object and further restricts the type of actions that can take place on that object, thus protecting the integrity of the object.

Let's say Emily is a user of an application that has been built using the Clark-Wilson model. She cannot access files directly, but must open and manipulate files through the program built upon the Clark-Wilson model. The programs have their own set of restrictions dictating what actions the users can and cannot perform on objects. This streamlines the way objects are protected and reduces the methods that could cause the data to be corrupted or changed in an undesirable manner.

critical task cannot be carried out by one entity. Auditing is also required in this model to track the information coming in from the outside of the system.

So the Clark-Wilson model prevents authorized users from making modifications by requiring them to go through programs to modify objects. It also prevents authorized users from making improper modifications by enforcing separation of duties, and maintains an audit log for external transactions.

Information Flow Model

Now, which way is the information flowing in this system? Answer: Not to you.

The Bell-LaPadula model is concerned about information that can flow from a high security level to a low security level. The Biba model is concerned about information that can flow from a high integrity level to a low integrity level. Both of these were built upon the *information flow model*. Information flow models can deal with any kind of information

flow, not only the direction of the flow. This type of model looks at insecure informational flow that can happen at the same level and between objects along with the flow between different levels. When the information flow model is used, a system is secure if there is no illegal information flow permitted.

Basically, information can flow from one security level to another or from one object to another in the same security level until a restricted operation is attempted. In most systems, once a restricted operation is attempted, the system looks at an access control matrix to see if this action has been specifically permitted for this specific subject or object.

Noninterference Model

Stop touching me. Stop touching me. You are interfering with me!

Multilevel security properties can be expressed in other ways, one being *noninterference*. This concept is implemented to ensure that any actions that take place at a higher security level do not affect, or interfere, with actions that take place at a lower level. This type of model does not concern itself with the flow of data, but with what a subject knows about the state of the system. So if an entity at a higher security level performs an action, it cannot change the state for the entity at the lower level.

If a lower-level entity was aware of a certain activity that took place by an entity at a higher level and the state of system changed for this lower-level entity, the entity might be able to deduce too much information about the activities of the higher state, which in turn is a way of leaking information.

Users at a lower security level should not be aware of the commands executed by users at a higher level and should not be affected by those commands in any way.

Goals of Integrity

There are three main goals of integrity:

- Prevent unauthorized users from making modifications
- Prevent authorized users from making improper modifications
- Maintain internal and external consistency

Clark-Wilson addresses each of these goals in its model. Biba only addresses the first goal.

Brewer and Nash Model

The ***Brewer and Nash model***, also called the Chinese Wall model, was created to provide access controls that can change dynamically depending upon a user's previous actions. The main goal of the model is to protect against users accessing data that could be seen as conflicts of interest. For example, if a large marketing company provided marketing promotions and materials for several banks, one individual working on a project for Bank A should not be looking at information the marketing company has for Bank B. So this marketing company could implement a product that tracked the different marketing representatives' access activities and disallow certain access requests that would present a conflict of interest.

.

Graham-Denning and Harrison-Ruzzo-Ullman Models

Remember that these are all models, thus they are not very specific in nature. Each individual vendor must decide upon how it is going to actually meet the rules outlined in the chosen model. Bell-LaPadula and Biba don't define how the security and integrity ratings are defined and modified, nor do they provide a way to delegate or transfer access rights. The ***Graham-Denning model*** addresses these issues and defines a set of basic rights in terms of commands that a specific subject can execute on an object. The ***Harrison-Ruzzo-Ullman model*** outlines how access rights can be changed and how subjects and objects should be created and deleted.

These newer models provide more granularity and direction for vendors on how to actually meet the goals outlined in the earlier models.

Security Modes of Operation

A system can operate at different types of modes depending on the sensitivity of the data being processed, the clearance level of the users, and what those users are authorized to do. The mode of operation describes the security conditions under which the system actually functions. There are four modes of operations a system can function under and the following sections describe each one.

Dedicated Security Mode

A system is operating in a *dedicated security mode* if all users have the clearance and formal need-to-know to *all* data processed within the system. All users have been given formal access approval for *all* information on the system and have signed nondisclosure agreements pertaining to this information. The system can handle a single classification level of information.

Many military systems have been designed to handle only one level of security, which works in dedicated security mode. This requires everyone who uses the system to have the highest level of clearance required by any and all data on the system. If a system held topsecret data, only users with this clearance could use the system. Other military systems work with multiple security levels, which is done by compartmentalizing the data. These types of systems can support users with high and low clearances simultaneously.

System-High Security Mode

A system is operating in *system-high security mode* when all users have a security clearance or authorization to access the information but not necessarily a need-to-know for all the information processed on the system. So the difference between the dedicated security mode and the system-high security mode is that in the dedicated security mode, all users have a need-to-know pertaining to *all* data on the system; in system-high security mode, all users have a need-to-know pertaining to *some* of the data.

This mode also requires all users to have the highest level of clearance required by any and all data on the system. However, just because a user has the necessary security level to access an object, the user could be restricted because they do not have a need-to-know pertaining to that specific object.

Compartmented Security Mode

A system is operating in *compartmented security mode* when all users have the clearance to access all the information processed by the system, but might not have the need-to-know and formal access approval. In compartmented security mode, users are

restricted from being able to access some information because they do not need to access it to perform the functions of their jobs and they have not been given formal approval to access this data. In this mode, users can access a segment, or compartment, of data only.

The objective is to ensure that the minimum possible number of people learn of information at each level. Compartments are categories of data with limited number of subjects cleared to access data at each level. *Compartmented mode workstations (CMWs)* enable users to process multiple compartments of data at the same time, if they have the necessary clearance.

Multilevel Security Mode

A system is operating in *multilevel security mode* when it permits two or more classification levels of information to be processed at the same time when all the users do not have the clearance or formal approval to access all the information being processed by the system. The Bell-LaPadula model is an example of a multilevel security model because it handles multiple information classifications at a number of different security levels within one system.

Systems Evaluation Methods

A *security evaluation* examines the security-relevant parts of a system, meaning the TCB, access control mechanisms, reference monitor, kernel, and protection mechanisms. The relationship and interaction between these components are also evaluated. There are different methods of evaluating and assigning assurance and trust levels to systems. The reason that there is more than one type of security evaluation process is that the methods and ideologies have evolved over time and because various parts of the world look at computer security differently and rate some aspects of security differently than others. Each method will be explained and then at the end of the section they will be compared to each other to show the differences and strengths, and look at where security evaluation methods are heading.

The Orange Book

The U.S. Department of Defense developed the *Trusted Computer System Evaluation Criteria (TCSEC)*, which is used to evaluate operating systems, applications, and different products. This evaluation criteria is published in a book with an orange cover, which is called appropriately the *Orange Book*. (We like to keep things simple in security!) Customers use the security rating that the criteria presents so they have a metric to use when comparing different systems. It also provides direction for manufactures so they know what specifications to build to, and provides a one-stop evaluation process so customers do not need to have individual components within the systems evaluated. The Orange Book evaluates products to assess if they contain the security properties they claim and evaluate if the product is appropriate for a specific application or function. The Orange Book looks at the functionality, effectiveness, and assurance of a system during its evaluation, and it uses classes that were devised to address typical patterns of security requirements. TCSEC provides a graded classification of systems that is divided into hierarchical divisions of security levels:

- A** Verified protection
- B** Mandatory protection
- C** Discretionary protection
- D** Minimal security

The classification A represents the highest level of security and D represents the lowest level of security.

Each division can have one or more numbered classes and each has a corresponding set of requirements that must be met for a system to achieve that particular rating. The classes with higher numbers indicate a greater degree of trust and assurance. So B2

would offer more trust than B1, and C2 would offer more trust than C1.

When a vendor submits a product for evaluation, the product is submitted to the National Computer Security Center (NCSC). The process of evaluation is called the Trusted Products Evaluation Program (TPEP). Successfully evaluated products are placed on the Evaluated Product List (EPL) with their corresponding rating. When consumers are interested in certain products and systems, they can check the EPLs to find out the security level that are assigned to these products.

Division D: Minimal Protection

There is only one class in this division. It is reserved for systems that have been evaluated but fail to meet the criteria and requirements of the higher divisions.

Division C: Discretionary Protection

The C rating category has two individual assurance ratings within it; these ratings are described below. The higher the number of the assurance rating, the more protection that is provided.

C1: Discretionary Security Protection

Discretionary access control is based on individuals and/or groups. It requires a separation of users and information, and identification and authentication of individual entities.

Some type of access control is necessary so users can ensure that their data will not be accessed and corrupted by others. The system architecture must supply a protected execution domain so privileged system processes are not adversely affected by lowerprivileged processes. There must be specific ways of validating the system's operational integrity. The documentation requirements include design documentation, which shows the way the system was built to include protection mechanisms, test documentation (test plan and results), a facility manual so companies know how to install and configure the system's correctly, and user manuals.

The environment that would require this rating would be where users are processing information at the same sensitivity level; thus, strict access control and auditing measures are not required. It would be a trusted environment with low security concerns.

C2: Controlled Access Protection

Users need to be identified individually to provide more precise access control and auditing functionality. Logical access control mechanisms are used to enforce authentication and the uniqueness of each individual's identification. Security-relevant events are audited and these records must be protected from unauthorized modification. The architecture must provide resource, or object, isolation so proper protection can be applied to the resource and that actions taken upon it can be properly audited. The *object reuse* concept must also be invoked, meaning that any medium holding data must not contain any remnants of information after it is released for another subject to use. If a subject uses a segment of memory, that memory space must not hold any information after the subject is done using it. The same is true for storage media, objects being populated, temporary files being created—all data must be efficiently erased once the subject is done with that medium.

This class requires a more granular method of providing access control. The system must enforce strict logon procedures and provide decision-making capabilities when subjects request access to objects. A C2 system cannot guarantee that it will not be compromised,

but it supplies a level of protection that would make compromising attempts harder to accomplish.

The environment that would require systems with a C2 rating would be one that contains users that are trusted, but a certain level of accountability is required. C2, overall, is regarded to be the most reasonable class for commercial applications, but the level of protection is still relatively weak.

Division B: Mandatory Protection

Mandatory access control is enforced by the use of security labels. The architecture is based on the Bell-LaPadula security model and evidence of reference monitor enforcement must be available.

B1: Labeled Security

Each data object must contain a classification label and each subject must have a clearance label. When a subject attempts to access an object, the system must compare the subject and object's security labels to ensure the requested actions are acceptable. Data leaving the system must also contain an accurate security label. The security policy is based on an informal statement and the design specifications are reviewed and verified. It is intended for environments that require systems to handle classified data.

B2: Structured Protection

The security policy is clearly defined and documented, and the system design and implementation are subjected to more thorough review and testing procedures. This class requires more stringent authentication mechanisms and well-defined interfaces among layers. Subjects and devices require labels, and the system must not allow covert channels. A trusted path for logon and authentication processes must be in place, which means there are no trapdoors. A trusted path means that the subject is communicating directly with the application or operating system. There is no way to circumvent or compromise this communication channel. There is a separation of operator and administration functions within the system to provide more trusted and protected operational functionality. Distinct address spaces must be provided to isolate processes, and a covert channel analysis is conducted. This class adds assurance by adding requirements to the design of the system.

The environment that would require B2 systems could process sensitive data that requires a higher degree of security. This environment would require systems that are relatively resistant to penetration and compromise.

B3: Security Domains

In this class, more granularity is provided in each protection mechanism, and the programming code that is not necessary to support the security policy is excluded. The design and implementation should not provide too much complexity because as the complexity of a system increases, the ability of the individuals who need to test, maintain, and configure it reduces; thus, the overall security can be threatened. The reference monitor components must be small enough to test properly and be tamperproof. The security administrator role is clearly defined, and the system must be able to recover from failures without its security level being compromised. When the system starts up and loads its operating system and components, it must be done in an initial secure state to ensure that

any weakness of the system cannot be taken advantage of in this slice of time. An environment that requires B3 systems is a highly secured environment that processes very sensitive information. It requires systems that are highly resistant to penetration.

Division A: Verified Protection

Formal methods are used to ensure all subjects and objects are controlled with the necessary discretionary and mandatory access controls. The design, development, implementation, and documentation are looked at in a formal and detailed way. The security mechanisms between B3 and A1 are not very different, but the way that the system was designed and developed is evaluated in a much more structured and stringent procedure.

A1: Verified Design

The architecture and protection features are not much different from systems that achieve a B3 rating, but the assurance of an A1 system is higher than a B3 system because the formality in the way the system was designed, the way the specifications were developed, and the level of detail in the verification techniques. Formal techniques are used to prove the equivalence between the TCB specifications and the security policy model. More stringent change configuration is put in place with the development of an A1 system, and the overall design can be verified. In many cases, even the way that the system is delivered to the customer is under scrutiny to ensure that there is no way of compromising the system before it reaches its destination.

An environment that would require A1 systems is the most secure of secured environments. This environment deals with top-secret information and cannot adequately trust anyone using the systems without strict authentication, restrictions, and auditing.

Multipal Choice question:-

1. What flaw creates buffer overflows?
A. Application executing in privileged mode
B. Inadequate memory segmentation
C. Inadequate protection ring use
D. Insufficient parameter checking

Ans:-D

2. The operating system performs all except which of the following tasks?
A. Memory allocation
B. Input and output task
C. Resource allocation
D. User access to database views

Ans:-D

3. If an operating system allows sequential use of an object without refreshing it, what security issue can arise?

- A.** Disclosure of residual data
B. Unauthorized access to privileged processes

- C. Data leakage through covert channels
- D. Compromising the execution domain

Ans:-A

4. What is the final step in authorizing a system for use in an environment?

- A. Certification
- B. Security evaluation and rating
- C. Accreditation
- D. Verification

Ans:-C

5. What feature enables code to be executed without the usual security checks?

- A. Antivirus software
- B. Maintenance hook
- C. Timing channel
- D. Ready state

Ans:-B

6. If a component fails, a system should be designed to do which of the following?

- A. Change to a protected execution domain
- B. Change to a problem state
- C. Change to a more secure state
- D. Release all data held in volatile memory

Ans:-C

7. What security advantage does firmware have over software?

- A. It is difficult to modify without physical access.
- B. It requires a smaller memory segment.
- C. It does not need to enforce the security policy.
- D. It is easier to reprogram.

Ans:-A

8. Which is the first level of the Orange Book that requires classification labeling of data?

- A. B3
- B. B2
- C. B1
- D. C2

Ans:-C

9. The Information Technology Security Evaluation Criteria was developed for which of the following?

- A. International use
- B. U.S. use
- C. European use
- D. Global use

Ans:-C

10. A security kernel contains which of the following?

- A. Software, hardware, and firmware**
- B. Software, hardware, and system design**
- C. Security policy, protection mechanisms, and software**
- D. Security policy, protection mechanisms, and system design**

Ans:-A

11. What characteristic of a trusted process does not allow users unrestricted access to sensitive data?

- A. Process isolation enforcement**
- B. Security domain enforcement**
- C. Need-to-know enforcement**
- D. TCB enforcement**

Ans:-C

12. The Orange Book states that a system should uniquely identify each user for accountability purposes and _____.

- A. Require the user to perform object reuse operations**
- B. Associate this identity with all auditable actions taken by that individual**
- C. Associate this identity with all processes the user initiates**
- D. Require that only that user have access to his specific audit information**

Ans:-B

13. The trusted computing base (TCB) controls which of the following?

- A. All trusted processes and software components**
- B. All trusted security policies and implementation mechanisms**
- C. All trusted software and design mechanisms**
- D. All trusted software and hardware components**

Ans:-D

14. What is the imaginary boundary that separates components that maintain security from components that are not security related?

- A. Reference monitor**
- B. Security kernel**
- C. Security perimeter**
- D. Security policy**

Ans:-C

15. Which model deals only with confidentiality?

- A. Bell-LaPadula**
- B. Clark-Wilson**
- C. Biba**
- D. Reference monitor**

Ans:-A

16. What is the best description of a security kernel from a security point of view?

- A. Reference monitor**

- B. Resource manager
- C. Memory mapper
- D. Security perimeter

Ans:-A

17. When is security of a system most effective and economical?

- A. If it is designed and implemented from the beginning of the development of the system
- B. If it is designed and implemented as a secure and trusted front end
- C. If it is customized to fight specific types of attacks
- D. If the system is optimized before security is added

Ans:-A

18. In secure computing systems, why is there a logical form of separation used between processes?

- A. Processes are contained within their own security domains so that each does not make unauthorized accesses to other objects or their resources.
- B. Processes are contained within their own security perimeter so that they can only access protection levels above them.
- C. Processes are contained within their own security perimeter so that they can only access protection levels equal to them.
- D. The separation is hardware and not logical in nature.

Ans:-A

19. Which best describes the *-integrity axiom?

- A. No write up in the Biba model
- B. No read down in the Biba model
- C. No write down in the Bell-LaPadula model
- D. No read up in the Bell-LaPadula model

Ans:-A

20. Which best describes the simple security rule?

- A. No write up in the Biba model
- B. No read down in the Biba model
- C. No write down in the Bell-LaPadula model
- D. No read up in the Bell-LaPadula model

Ans:-D

21. Which of the following was the first mathematical model of a multilevel security policy used to define the concept of a security state, modes of access, and outlines rules of access?

- A. Biba
- B. Bell-LaPadula
- C. Clark-Wilson
- D. State machine

Ans:-B

22. Which of the following is not a characteristic of the Bell-LaPadula model?

- A. Confidentiality model**
- B. Integrity model**
- C. Developed and used by the U.S. DoD**
- D. First mathematical multilevel security model**

Ans:-B

=====

Modul-4

Chapter 2:

System Security

ABSTRACT

Basic principle of security

There are four basic principle of security. Consider sender is A and receiver is B. A wants to send some data to B then he/she should maintains the following four things:

1) Confidentiality:-It is expected that the message must and should read and access by sender and receiver only.

2) Integrity :-Assurance that data has real and correct.

3) Authentication :-It is the proof of identities.

A) DESKTOP SECURITY :-

- ☐ Practice good physical security.
- ☐ Use update- to- date antivirus software.
- ☐ Use a locked screensaver.
- ☐ Use a firewall and follow the firewall guidelines.
- ☐ Set up separate user accounts for desktop sharing.
- ☐ Disable filesharing.
- ☐ Remove all spyware from your machine.

B) EMAIL SECURITY

Email is the transmission of data or message using electronic device through the internet.

Two main email security protocols are used to provide the security to email messages

1) Pretty Good Privacy(PGP)

2) Secure MIME (S/MIME)

1) Pretty Good Privacy

The email security features offered by PGP are,

a) Encryption b) Non-repudiation c) Message integrity

Working of PGP:

In PGP, Broad level steps are,

1) Digital signature

2) Compression

3) Encryption

4) Enveloping

5) Base-64 Encoding

2) Secure Multipurpose Internet Mail Extensions(S/MIME)

The traditional email system using the SMTP protocol are text based, People want to exchange multimedia files , documents in various format, etc. to cater to this needs, the MIME system extends the basic email system by permitting users to send binary files using the basic email system.

C) WEB SECURITY

Web security or Internet security has assumed great importance, The world's most famous security protocol, the secure socket layer and the secure electronic transaction protocol.

1) Secure Socket Layer (SSL)

The SSL protocol is an Internet protocol for secure exchange of information between a web browser and a web server. It provides two basic security services: authentication and confidentiality.

Position of SSL in TCP/IP

The SSL layer is located between the application layer and the transport layer.

WORKING OF SSL:

SSL has three sub-protocols, namely the Handshake protocol, Record protocol and Alert protocol.

The Handshake protocol:

It's the first protocol of SSL layer, used by the client and server to communicate using an SSL-enabled connection.

RECORD PROTOCOL:

This protocol comes after the client and the server have optionally authenticated each other.

ALERT PROTOCOL:

When either the client or the server detects an error, the detecting party sends an Alert message to the other party. If the error is fatal, both the parties immediately close the SSL connection.

SET(Secure Electronic Transaction):-

The Secure Electronic Transaction(SET) is an open encryption and security specification that is designed for protecting credit card transactions on the Internet.

SET PARTICIPANTS

- ☐ Card holder: Authorized person who holds the card.
- ☐ Merchant: Person or organization that wants to sell the goods to card holder.
- ☐ Issuer :Bank who provides the card.
- ☐ Acquirer :Receiver side bank.
- ☐ A payment gateway: is an e-commerce application service provider service that authorizes credit card payments for e-businesses, online retailers.

D) DATABASE SECURITY

Database security concerns the use of a broad range of information security controls to protect databases (potentially including the data, the database applications or stored functions, the database system, the database servers and the associated network links).

Security risks to database systems include, for example:

- ☐ Unauthorized activity or misuse by authorized database users.
- ☐ Malware infections causing incidents such as unauthorized access, leakage or disclosure of personal data.
- ☐ Physical damage to database servers caused by computer room fires or floods, overheating, lightning, accidental liquid spills, static discharge, electronic breakdowns/equipment failures.
- ☐ Programming bugs in databases.
- ☐ Data corruption and/or loss caused by the entry of invalid data or commands, mistakes in database or system administration processes.

Basic principle of security

There are four basic principle of security. Consider sender is A and receiver is B. A wants to send some data to B then he/she should maintains the following four things:

- 1) Confidentiality When A is sending the message (eg letter or cheque) to B then, it is expected that the message must and should read and access by A and B only, no one other than these. If some third person can have the access to this data then that message is no more confidential. That is, the confidentiality of message is loosed.
- 2) Integrity Here , confidentiality is lost and the message is now accessed by the person C(third unauthorized person). If C is now able to change the content of original message then the integrity if that message is going to be lost.
- 3) Authentication It is the proof of identities. The receiver B wants to guaranty that message is originally came from the sender A, and not from somebody else who is posing as A. That is, B is authenticating A.
- 4) Non repudiation Here , message is successfully reached at B without any modification. B have processed the message. After the process is completed, if A denies the message sent. Then its violating the non-repudiation.

A) DESKTOP SECURITY

A personal computer is anything but personal. Our network and Internet connections link your computer to the outside world back to your computer. With the proliferation of viruses, worms, Trojans and identity theft, it's possible that someone besides you is looking at your data. In this environment, its necessary for all members of the university community to be proactive in protecting the data and personal information stored on the computers on the network. The following things describe desktop security measures designed to thwart Internet predators.

☐ Practice good physical security. ☐ Use update- to- date antivirus software. ☐ Use a locked screensaver. ☐ Use a firewall and follow the firewall guidelines. ☐ Set up separate user accounts for desktop sharing. ☐ Disable filesharing. ☐ Remove all spyware from your machine.

B) EMAIL SECURITY

Introduction

E-mail is the most widely used application on the Internet. Using E-mail, an Internet user can send a message to other Internet users. Consequently, the security on email messages has becomes an extremely important issue. The Simple mail Transfer Protocol(SMTP) is used for email communication. The email software at the sender's end gives email message to the local SMTP server. This SMTP server actually transfer the email message from to the SMTP server of the receiver. Its main job is to carry the email message between the sender and receiver. It uses the TCP/IP protocol underneath. That is, SMTP runs on the top of TCP/IP.

Two main email security protocols are used to provide the security to email messages

1) Pretty Good Privacy(PGP) 2) Secure MIME (S/MIME)

1) Pretty Good Privacy

Phil Zimmerman is the father of the PGP protocol. He is credited with the creation of PGP. The most significant aspects of PGP are that it support the basic requirements of cryptography, is quite simple to use and is free. PGP has becomes extremely popular and is far more widely used. The email security features offered by PGP are,

a) Encryption b) Non-repudiation c) Message integrity

Working of PGP:

In PGP, Broad level steps are,

1) Digital signature 2) Compression 3) Encryption 4) Enveloping 5) Base-64 Encoding

PGP allows for three security options when sending an email message. These options are, ☐ Signature only(step1 and step 2) ☐ Signature and Base-64 encoding(step 1,2 and 5) ☐ Signature, Encryption, Enveloping and Base-64 encoding(step 1 and 5)

1) Digital signature: In PGP, it consist of the creation of message digest of email message using SHA algorithm. The resulting digest is then encrypted with the senders private key. The result is the senders digital signature.

2) Compression

Here, the input message as well as the digital signature are compressed together to reduce the size of the final message that will be transmitted. For this, the famous ZIP program is used. ZIP is based on the Lempel-Ziv algorithm.

3) Encryption

In this step, the compressed output of step 2 are encrypted with a symmetric key. For this, generally the IDEA algorithm is used.

4) Digital enveloping

In this step, the symmetric key used for encryption in step 3 is now encrypted with the receiver's public key. The output of step 3 and step 4 together form a digital envelop.

5) Base 64 encoding

This is the last step in PGP. The Base 64 encoding process transforms arbitrary binary input into printable character output.

2) Secure Multipurpose Internet Mail Extensions(S/MIME)

The traditional email system using the SMTP protocol are text based, which that a person can compose a text message using an editor and then send it over the Internet to another recipient. However in modern era, exchanging only text messages is not quite sufficient. People want to exchange multimedia files, documents in various format, etc. to cater to this needs, the MIME system extends the basic email system by permitting users to send binary files using the basic email system.

Knowing why SMTP cannot work with non-text data is important. SMTP uses the 7-bit ASCII representation for character of an email message. 7-bit ASCII cannot represent special characters above the ASCII value 127. SMTP cannot also send binary data.

A MIME email message contains a normal Internet text message along with some special headers and formatted sections of text. Each such section can hold an ASCII encoded portion of data. Each section starts with an explanation as to how the data that follows should be decoded at the receiver's end. The receiver's email system uses this explanation to decode the data.

Traditional email headers

MIME-version: 1.1

Content type: type/subtype

Content transfer encoding: encoding type

Content Id: msg id

Content Description: textual desc

Email body

Fg: MIME header's in an Email messages

C) WEB SECURITY

Web security or Internet security has assumed great importance, as it is the world's prime computer network(or network of networks). The various security protocols are associated with Internet. Since Internet technology is vast and encompasses many areas, there are various security mechanisms exist for specialized Internet services, such as email, electronic commerce and payments, wireless Internet, etc.

This section is for the readers who are not familiar with the world's most famous security protocol, the secure socket layer and the secure electronic transaction protocol.

1) Secure Socket Layer (SSL)

The SSL protocol is an Internet protocol for secure exchange of information between a web browser and a web server. It provides two basic security services: authentication and confidentiality. Logically , it provides a secure pipe between the web browser and the server. Netscape Corporation developed SSL in 1994. Since then, SSL has becomes the world's most popular Web browser support SSL. Currently, SSL comes in three versions: 2,3 and 3.1. The most popular of them is Version 3, which was released in 1995.

Position of SSL in TCP/IP

SSL can be conceptually considered as an additional layer in the TCP/IP protocol suite. The SSL layer is located between the application layer and the transport layer as shown in fg

WORKING OF SSL:

SSL has three sub-protocols, namely the Handshake protocol, Record protocol and Alert protocol.

These three sub-protocols constitute the overall working of SSL.

Application Layer

Transport Layer

Internet Layer

Data Link Layer

Physical Layer

SSL Layer

We shall take a look at all the three protocols now.

The Handshake protocol:

It's the first protocol of SSL layer, used by the client and server to communicate using an SSL-enabled connection. This is similar to how A and B would first shake hands with each other with a Hello before they start conversing.

As the fg shows, the handshake protocol consists of a series of messages between the client and server. Each of these messages has the format

1 byte 3 bytes 1 or more bytes

Fg. Format of the handshake protocol messages

Type : this field indicates one of the ten possible message types. These ten message types are listed in Fg. Below.

Length : This field indicates the length of the message in bytes

Contents : This field contains the parameters associated with this message, depending on the message type.

Type Length Content

Message Type	Parameters
Hello request	None
Client hello	Version, Random number, Session id, Cipher suite, Compression method
Server hello	Version, Random number, Session id, Cipher suite, Compression method
Certificate	Chain of X.509V3 certificates
Server key exchange	Parameters, signature
Certificate request	Type, authorities
Server hello done	None
Certificate verify	Signature
Client key exchange	Parameters, signature
Finished	Hash value

By using this Handshake protocol, a symmetric key is generated. After that the Record protocol starts its working.

RECORD PROTOCOL:

The Record protocol in SSL comes into picture after a successful handshake is completed between the client and the server. That is, after the client and the server have optionally authenticated each other and have decided what algorithms to use for secure information exchange, we enter into the SSL record protocol. This protocol provides two services to an SSL connection, as follows:

□ Confidentiality : This is achieved by using the secret key that is defined by the handshake protocol. □ Integrity: The handshake protocol also defines a shared secret key that is used for assuring the message integrity.

SSL RECORD PROTOCOL

Application data

FRAGMENTATION

COMPRESSION

MAC

ENCRYPTION

APPEND HEADER

As the fg shows, the SSL record protocol takes an application message as input. First , it fragments it into smaller blocks, optionally compresses each block, adds MAC, encrypts it, adds a header and gives it to the transport layer, where the TCP protocol processes it likes any other TCP block. At the receiver's end, the header of each block is removed; the block is then decrypted, verified, decompressed and reassembled into application messages.

ALERT PROTOCOL:

When either the client or the server detects an error, the detecting party sends an Alert message to the other party. If the error is fatal, both the parties immediately close the SSL connection. Both the parties also destroy the session identifiers, secrets and keys associated with this connection before it is terminated. Other errors, which are not so severe, do not result in the termination of the connection. Instead, the parties handle the error and continue. 2) Secure Electronic Transaction (SET)

Introduction

The Secure Electronic Transaction(SET) is an open encryption and security specification that is design for protecting credit card transactions on the Internet. The pioneering work in this area was done in 1996 by MasterCard and Visa jointly. They were joined by IBM, Microsoft, Netscape and RSA and VeriSign , starting from that time , there have been many test of the concept and by 1998 the first generation of SET-compliant products appeared in the market .

SET is not a payment system. Instead, it is a set of security protocols and format that enable the users to employ the existing credit card payment infrastructure on the Internet in a secure manner. SET services can be customized as follows :

1. It provides a secure communication channel among all the parties involved in an e-commerce transaction.

2. It provides authentication by the use of digital certificate. 3. It ensures confidentiality, because the information is only available to the parties involved in transaction and that to only when and where necessary,

SET is a very complex specification. In fact, when released, it took 971 pages to describe SET across 3 books. Thus, it is not possible to describe it in great detail. However, we shall summarize the key points.

SET PARTICIPANTS

Before we discuss SET, let us summarize the participants in the set system.

□ Card holder : Using the Internet, consumer and corporate purchasers interact with merchants for buying goods and services. A card holder is an authorized holder for a payment card such as MasterCard or Visa has been issued by an issuer. □ Merchant: A merchant is a person or an organization that wants to sell the goods or services to the goods holder. A merchant must have a relationship with an Acquirer for accepting payment on Internet. □ Issuer: the issuer is a financial institution (such as bank) that provides a payment card to a card holder. The most critical point is that issuer is the ultimately responsible for payment of card holder's debt. □ Acquirer: An acquiring bank (or acquirer) is a bank or financial institution that processes credit or debit card payments on behalf of a merchant. The term acquirer indicates that the bank accepts or acquires credit card payments from the card-issuing banks within an association.

□ A payment gateway: is an e-commerce application service provider service that authorizes credit card payments for e-businesses, online retailers, bricks and clicks, or traditional brick and mortar. It is the equivalent of a physical point of sale terminal located in most retail outlets. Payment gateways protect credit card details by encrypting sensitive information, such as credit card numbers, to ensure that information is passed securely between the customer and the merchant and also between merchant and the payment processor. A payment gateway facilitates the transfer of information between a payment portal (such as a website, mobile phone or interactive voice response service) and the Front End Processor or acquiring bank.

□ Certification authority (CA) : is an entity that issues digital certificates. A digital certificate certifies the ownership of a public key by the named subject of the certificate. This allows others (relying parties) to rely upon signatures or on assertions made by the private key that corresponds to the certified public key. In this model of trust relationships, a CA is a trusted third party - trusted both by the subject (owner) of the certificate and by the party relying upon the certificate. Many public-key infrastructure (PKI) schemes feature CAs.

SET Transaction: The sequence of events required for a transaction is as follows:

□ The customer obtains a credit card account with a bank that supports electronic payment and SET □ The customer receives a X.509v3 digital certificate signed by the bank. □ Merchants have their own certificates

□ The customer places an order with the merchant. □ The merchant sends the customer his public key and a copy of his certificate so that the customer can verify that it's a valid store. □ The customer sends the merchant: □ His certificate. □ His order details, unencrypted. □ His bank account details encrypted with the bank's public key. □ The merchant requests payment authorization by sending the bank: □ The payment details encrypted with the bank's public key. □ The customer's bank account details encrypted with the bank's public key.

Note that the merchant doesn't know the client's payment and bank account details.

□ The bank sends the merchant a confirmation encrypted with the merchant's public key.

□ The merchant sends the client the bank's response encrypted with the client's public key. □ The merchant ships the goods or provides the service to the customer. □ The merchant sends the bank a transaction request encrypted with the bank's public key. □ The bank transfers the payment to the merchant.

D) DATABASE SECURITY

Database security concerns the use of a broad range of information security controls to protect databases (potentially including the data, the database applications or stored functions, the database system, the database servers and the associated network links) against compromises of their confidentiality, integrity and availability . It involves various types or categories of controls, such as technical, procedural/administrative and physical. Database security is a specialist topic within the broader realms of computer security, information security and risk management.

Security risks to database systems include, for example:

□ Unauthorized or unintended activity or misuse by authorized database users, database administrators, or network/systems managers, or by unauthorized users or hackers (e.g. inappropriate access to sensitive data, metadata or functions within databases, or inappropriate changes to the database programs, structures or security configurations); □ Malware infections causing incidents such as unauthorized access, leakage or disclosure of personal or proprietary data, deletion of or damage to the data or programs, interruption or denial of authorized access to the database, attacks on other systems and the unanticipated failure of database services; □ Overloads, performance constraints and capacity issues resulting in the inability of authorized users to use databases as intended; □ Physical damage to database servers caused by computer room fires or floods, overheating, lightning, accidental liquid spills, static discharge, electronic breakdowns/equipment failures and obsolescence; □ Design flaws and programming bugs in

databases and the associated programs and systems, creating various security vulnerabilities (e.g.)

unauthorized privilege escalation), data loss/corruption, performance degradation etc.; □ Data corruption and/or loss caused by the entry of invalid data or commands, mistakes in database or system administration processes, sabotage/criminal damage etc.

Multiple Choice Question

- 1) _____ is assurance that data has real & correct.
a) Integrity b) Confidentiality c) Authentication d) Non- repudation
- 2) _____ protocol is used for email communication
a) FTP b) TCP c) SMTP d) None
- 3) _____ is not a sub-protocol of SSL protocol.
a) Handshake b) Alert c) Record d) TCP
- 4) The zip program is used for _____.
a) Digital Signature b) Encryption c) Compression d) Envelope
- 5) _____ is a person or organization that wants to sell the goods & services
a) Issure b) Merchant c) Acquirer d) Card Holder
- 6) _____ is the email security protocol.
a) PGP b)SMTP c) TCP d)SET
- 7) _____ is used to transforms arbitrary binary input into printable character output.
a) Compression b) Base -64 encoding c) Encryption d) Digital Signature
- 8) We can send _____ size of data from gmail at a one time.
a) 100 MB b) 25 MB c) 75 MB d) 10 MB
- 9) Leakage of personal data is caused due to _____
a) Physical Damage b) Malware infection
c) Capacity issues d) None of these
- 10) Locked Screensever is used for _____.
a) Web security b)E-mail security c) Desktop security d) All of these

ANSWERS:

- 1) a
- 2) c
- 3) d
- 4) c
- 5) b
- 6) a
- 7) b
- 8) b
- 9) d
- 10) c

=====

1. OS Security Vulnerabilities, updates and patches
2. OS integrity checks
3. Anti-virus software
4. Configuring the OS for security

Configuring the OS for security

OS Security Vulnerabilities:

The exploitation of vulnerabilities i.e. errors in operating system code or applications is one of the most common ways for cybercriminals to infect computers. Although finding a suitable vulnerability and writing malicious code (called an exploit) to take advantage of it is a fairly complex process, malicious users continue to devote time and resources to this in the hope of profiting from successful infections. Popular software often plays an intermediary role: in 2012, over half of all active exploits targeted vulnerabilities in Java, while 28% targeted code errors in malware infiltrations, wireless intrusions and more. I can't think of a good reason not to use a personal firewall on all workstations and most servers.

File and share permissions that give up everything to everyone -- This is easily the biggest vulnerability I'm seeing with Windows systems regardless of the type of system or Windows version. Users who create shares to make their local files available across the network are typically the culprits. Sometimes it's careless admins; other times they're honest mistakes. Unfortunately, all too often the "Everyone group" is given full access to every file on the system. Then, all it takes is for an insider to search for sensitive keywords stored in .pdf, .xls, .doc and other file formats using a text search tool such as [Effective File Search](#) or [FileLocator Pro](#). Odds are -- nearly 100% of the time -- the attacker will come across sensitive information (SSNs, credit card numbers, you name it) that they shouldn't have access to. Best case scenario, this is an identity theft in the making. Worst case, this becomes a serious breach that makes the headlines.

- ☐ Lack of malware protection -- I know, I know, it's really basic but I'm seeing it more now than ever. I've seen antivirus and antispyware software both disabled and not installed at all with no one being aware of the problem.
- ☐ Lack of personal firewall protection -- This is another basic security control that's still not enabled on many Windows systems. Even the basic (and free) Windows Firewall can prevent connections to the IPC\$ and ADMIN\$ shares that are often open and providing information and access that they shouldn't be divulging. Personal firewalls can also block

- ❑ Weak or nonexistent drive encryption -- The drive encryption marketing machine is working its magic, but I'm still seeing the majority of organizations (large and small) not using encryption. I'm of the belief that whole-disk encryption is the only way to go. If a laptop or desktop machine is lost or stolen, the only way to prevent someone from cracking the Windows password and gaining full access to the hard drive is to encrypt everything using reasonable passphrases. Relying on Windows Encrypted File System (EFS) or other file/directory/volume-level encryption puts too much security control in the hands of users and is a breach waiting to happen.
- ❑ Missing patches in Windows as well as third-party software, such as VNC, RealPlayer and others -- This is a big problem that often gets overlooked. I'm not saying you should try to find these types of holes just to claim that patches are missing. Using Metasploit or its commercial alternatives CANVAS and CORE IMPACT, many missing patches can actually be exploited by a rogue insider or outsider who's gotten into your network via other means. Full remote access anyone?
- ❑ Weak Windows security policy settings -- Some examples of this include audit logging that is not being enabled for failed events; no password-protected screensavers; not requiring Ctrl+Alt+Del for login; not requiring password complexity; and displaying the last user name that logged in. Policies to control these issues are easy to implement locally on each Windows system for smaller Windows shops not running Active Directory. It's even easier for larger enterprises via Active Directory Group Policy.
- ❑ Weak or nonexistent passwords -- I can't tell you how many systems (especially Windows laptops) I see that do not have a password assigned to the Administrator account or the default user's password is the same as the user name. The password problem has been around since the dawn of time, so there's no excuse for this one.
- ❑ Windows Mobile and other mobile device weaknesses -- In today's mobile world, I'd be remiss to not at least mention the vulnerabilities associated with Windows Mobile and similar mobile devices. Some mobile-specific issues are essential to have on your radar.

Most vulnerable operating systems in 2013

Operating system	# of vulnerabilities		# of HIGH vulnerabilities		# of MEDIUM vulnerabilities		# of LOW vulnerabilities	
	2013	2012	2013	2012	2013	2012	2013	2012
Microsoft Windows Server 2008	↑104	48	↑58	35	↑46	12	↓0	1
Microsoft Windows 7	↑100	42	↑55	33	↑45	8	↓0	1
Microsoft Windows Vista	↑96	41	↑53	34	↑43	6	↓0	1
Microsoft Windows XP	↑88	42	↑47	37	↑41	5	⊙0	0
Microsoft Windows Server 2003	↑86	45	↑46	40	↑40	5	⊙0	0
Microsoft Windows 8	↑58	5	↑43	5	↑14	0	↑1	0
Linux Kernel	↑158	45	↑15	12	↑119	28	↑24	5
Microsoft Windows Server 2012	↑51	5	↑37	4	↑13	1	↑1	0
Microsoft Windows RT	↑42	2	↑32	2	↑9	0	↑1	0
Apple iOS	↑89	86	↓19	46	↑55	28	↑15	12
Cisco IOS	↓34	36	↓19	23	↑15	10	↓0	3
Ubuntu Linux	↑72	6	↑10	0	↑55	5	↑7	1
Cisco IOS XE	↑23	9	↑16	9	↑7	0	⊙0	0
Red Hat Enterprise Linux	↑54	2	↑9	0	↑37	1	↑8	1
openSUSE	↑49	0	↑11	0	↑26	0	↑12	0
Apple Mac OS X	↑63	21	↑5	3	↑44	16	↑14	2

Vulnerability Attributes:

All four types of security problems ultimately have the same basic attributes, so any taxonomy of problems for policy issues will have the same basic model for computer vulnerabilities.

Vulnerabilities have five basic attributes, which are Fault, Severity, Authentication, Tactic, and Consequence. Examining these attributes can provide a complete understanding of the vulnerability.

Fault: - Faults describes how the vulnerability came to be, as in what type of mistake was made to create the problem.

Severity: - It describes the degree of the compromise, such as if they gained administrator access or access to files a regular user normally would not see.

Authentication: - describes if the intruder must have successfully registered with the host proof of identity before exploiting the vulnerability.

Tactic: - It describes the issue of who is exploiting whom, in terms of location. If a user must have an account on the computer already, that is one situation. If the user can come from a location other than the keyboard, that is another.

Consequence: - describes the outcome. Consequence is the mechanics behind access promotion, and demonstrates how a small amount of access can lead to far greater compromises.

□ Updates and Patches

What Are Updates?

Software updates, are released for a variety of reasons. Sometimes the patch will upgrade a piece of software to the latest version with new features in the software. Sometimes an update will improve an application's stability. And sometimes an update is issued to fix a bug or security hole within the program. It is this last type of update is the most important when it comes to computer security.

What is patch?

A patch is a piece of software designed to update a computer program or its supporting data, to fix or improve it. This includes fixing security vulnerabilities and other bugs, and improving the usability or performance. Though meant to fix problems, poorly designed patches can sometimes introduce new problems (see software regressions). In some special cases updates may knowingly break the functionality, for instance, by removing components for which the update provider is no longer licensed or disabling a device.

Why Patch At All?

Security researchers have shown that installing system and software updates is the best defence against the most common viruses and malware online, particularly for computers running Windows. Software makers often release updates to address specific security threats that have come to their attention. By downloading and installing the system and software updates, you patch the vulnerabilities that virus writers rely on to infect your computer.

Use A Supported Operating System

Just because your old computer is still running doesn't mean that you're going to continue to receive updates. Both Apple and Microsoft stop providing updates for older operating systems. For example, Microsoft no longer provides updates for Windows XP, and Apple does not provide updates for early versions of OS X.

If the creator is no longer providing updates for a particular operating system, then that operating system becomes more dangerous every day you continue to use it. If a new vulnerability emerges, an update to remove the vulnerability may never be released. Virus writers know this and use it to their advantage, often preying on computers that are not just behind on a few updates, but computers still running an unsupported operating system.

Software and Application Updates

Apple and Microsoft to fortify their operating systems with patches, but certain pieces of software also need to be updated. In fact, some applications and software, such as Adobe Flash, Adobe Acrobat, and Microsoft Office, are just as important to keep up-to-date as the operating system. When these programs release updates, make sure you install them right away.

You should also check for updates right away if you open an old application for the first time in a long time. Sometimes applications only look for updates, including crucial security updates, when they are running. If you haven't used a particular program in a long time, there's a chance you'll have at least a few software updates that need to be installed before using the program.

☐ Antivirus software

Antivirus or anti-virus software (often abbreviated as AV), sometimes known as anti-malware software, is computer software used to prevent, detect and remove malicious software.

Antivirus software was originally developed to detect and remove computer viruses, hence the name. However, with the proliferation of other kinds of malware, antivirus software started to provide protection from other computer threats. In particular, modern antivirus software can protect from: malicious Browser Helper Objects (BHOs), browser hijackers, ransomware, keyloggers, backdoors, rootkits, trojan horses, worms, malicious LSPs, dialers, fraudtools, adware and spyware.[1] Some products also include protection from other computer threats, such as infected and malicious URLs, spam, scam and phishing attacks, online identity (privacy),

Online banking attacks, social engineering techniques, Advanced Persistent Threat (APT), botnets, DDoS attacks.

Some Anti-virus softwares are, McAfee, QuickHeal, Norton, Avast, AVG, PANDA, KASPERSKY, bitdefender, Net-Protector etc.

There are several different companies that build and offer anti-virus software and what each offers can vary but all perform some basic functions:

- ☐ Scan specific files or directories for any malware or known malicious patterns
- ☐ Allow you to schedule scans to automatically run for you
- ☐ Allow you to initiate a scan of a specific file or of your computer, or of a CD or flash drive at any time.
- ☐ Remove any malicious code detected –sometimes you will be notified of an infection and asked if you want to clean the file, other programs will automatically do this behind the scenes.
- ☐ Show you the ‘health’ of your computer

Always be sure you have the best, up-to-date security software installed to protect your computers, laptops, tablets and smartphones.

OS integrity check:

System File Checker (SFC) is a utility will check the integrity of your Windows 7 Operating system. It will check for the damaged, corrupted or changed version of files and replace it with the original version of that file.

Configuring OS Security:

Operating system security (OS security) is the process of ensuring OS integrity, confidentiality and availability.

OS security refers to specified steps or measures used to protect the OS from threats, viruses, worms, malware or remote hacker intrusions. OS security encompasses all preventive-control techniques, which safeguard any computer assets capable of being stolen, edited or deleted if OS security is compromised.

Overview of Windows XP:

- ☐ Windows XP is a general purpose OS designed to support a wide variety of security features and methods. It is based on user accounts which can be grouped in any manner.
- ☐ When a user logs on, a security access token is issued that includes the security ID for the user, security IDs for any groups of which the user is a member, and a list of any special privileges the user has, such as performing backups, shutting down the system, and changing the system clock.
- ☐ Every process running on behalf of a user gets a copy of the user's security token, which determines the privileges of that process running on behalf of that user.
- ☐ Authentication is normally done via passwords, but the modular design of XP allows for alternative authentication such as retinal scans or fingerprint readers.
- ☐ Windows XP includes built-in auditing that allows many common security threats to be monitored, such as successful and unsuccessful logins, logouts, attempts to write to executable files, and access to certain sensitive files.
- ☐ Security attributes of objects are described by security descriptors, which include the ID of the owner, group ownership for POSIX subsystems only, a discretionary access-control list describing exactly what permissions each user or group on the system has for this particular object, and auditing control information.

Multiple Choice Question

1) Which of the following are basic attributes of Vulnerabilities.

- a) Faults
- b) Severity
- c) Authentication
- d) Tactic Consequence
- e) All of the above

Answer=e)

2) Out of the following which is an Anti-Virus?

- a) McAfee
- b) QuickHeal
- c) Avast
- d) All of the above

Answer=d)

3. Operating system is an_____ between a user and a computer.

- a)Firewall
- b)Interface
- c)Application program
- d)None of the above

Answer=b)

4.A Patch may do the following things

Fix a software bug and upgrades the software

- a) Install new drivers
- b) Address new security vulnerabilities
- c) Address software stability issues
- d) All of the above.

Answer=e)

5.Name given by Microsoft Windows operating system patches are

- a)MS-patches
- b)Both a) and c)
- c)Service Packs
- d)None of the above

Answer=c)

6.Which of the below is an operating system?

- a)Andriod
- b) ios
- c)Mac OS
- d) All the above

Answer=d)

7. A set of process is deadlock when each is in the blocked state because it is waiting for a another resource that is allocate to one of the other

- a)Statement is true
- b)Statement is false
- c) Both
- d)All of the above

Answer=a)

8.Which of the following can be a cause of the deadlock?

- a) Circular waits
- b) No preemption
- c) Mutual exclusions
- d) All

Answer=d)

9.Type of operating systems are

- a)Single user
- b)Multiuser
- c)Both
- d)None

Answer=c)

10._____ is a firewall

- a) Zone labs
- b) Trojans
- c) Spyware
- d) None of the above

Answer=a)

11._____ is a hardware firewalls

- a)Cisco Sells
- b)Trojans
- c)Spyware
- d)None of the above

Answer=a)

12. Programs that exploit the Vulnerabilities in computer system are referred as

- _____
- a) Malware
 - b) Firewall
 - c) Anti-Viruses
 - d) None of the above

Answer=a)

13.IDS stands for _____

- a)Intrusion Definition system
- b)Interface Definition system
- c) Intrusion Detection system
- d)All of the

Answer =c)

14.Updates of the anti-virus is not an important task to protect your operating system

- a)True
- b)False
- c)Both
- d)All

Answer= a)

15.Means of authentication can be through

- a>Password and PIN
- b)Static Biometrics
- c)Dynamic Biometrics
- d)All

Answer=d)

16. Viruses, Worms, Trojans and spyware are the type of _____

- a) Malware
- b) Firewall
- c) Anti-Viruses
- d) None of the above

Answer=a)

17. Zone alarm is a type of _____

- a) Malware
- b) Firewall
- c) Anti-Viruses
- d) None of the above

Answer=b)

18) Which is a firewall for Windows

- a) NetBarrier
- b) Iptables
- c) winroute
- d) All

Answer=d)

19) TCP/IP is a _____

- a) Malware
- b) Protocol
- c) Anti-Viruses
- d) None of the above

Answer=b)

20) In "Windows 7" 7 signifies

- a) 2007
- b) 7
- c) Both
- d) All of the above

Answer=a)

- 1) What is operating system?
- 2) What is the need of operating system Security?
- 3) What is the use of Anti-Virus?
- 4) What is the need of Updates?
- 5) What are Patches?

Modul-4

Wireless Network & Security

Lecture No. 1: Components of Wireless Networks

Wireless networks use an "access point (AP)", also called a "wireless access point (WAP)", to provide a gateway to the wired network and a "wireless local area network adapter (WLAN adapter" or simply "wireless adapter)" to provide a link between a wireless client PC and the AP.

"DO IT ALL WITH ONE BOX"

1.1) Access points: An AP connects to the wired network (or directly to a cable/DSL modem) and can simultaneously provide wireless links to many wireless adapters. A typical AP allows 32 or 64 wireless adapters to be connected simultaneously. All wireless adapters that connect to an AP share the wireless bandwidth provided by that AP. For example, if the AP provides 54 Mb/s of wireless bandwidth, all connected wireless adapters share that 54 Mb/s even though each adapter may have a maximum individual bandwidth of 54 Mb/s or more.

If only one wireless adapter is transferring data at a particular moment, that adapter gets the full available bandwidth. If several adapters are transferring data simultaneously, the available bandwidth is shared among them. Accordingly, the instantaneous bandwidth available to any particular adapter varies dynamically, depending on how many other adapters are also using bandwidth at that moment and how much bandwidth they are using.

"IT'S NOT NICE TO SHARE"

Bandwidth sharing means that wireless networking may be a poor choice for applications, such as streaming video, that require real-time, high-bandwidth communications. The bandwidth of modern wireless components is barely sufficient to stream DVD-quality video under ideal conditions. If one or more other wireless clients are also using bandwidth, the delivered video will be choppy. For that reason, we always recommend using wired networking for video or, alternatively, a dedicated or 802.11a wireless networking connection.

A wireless network may have one or many APs. Although most home or SOHO networks get along fine with one AP, using a second AP provides additional area coverage, allows more wireless adapters to connect to the network simultaneously, and provides additional shared bandwidth. For example, one AP might have insufficient range to cover a large home, particularly one built with stone, steel studs, heavy plaster walls, or other materials that block radio waves. We can't imagine that the limit of 32 or 64 connected wireless adapters would be a problem in any home or SOHO environment, but the limited shared bandwidth might be.

Adding a second AP at some distance from the first AP extends the coverage area and doubles the bandwidth available to be shared among the wireless clients. Depending on their location, some wireless adapters may be within range of both APs, while others will be in range of only one or the other AP. If the wireless network is properly configured, client wireless

adapters simply connect transparently to an available AP without user intervention. If the client is mobile for example, a notebook computer being carried from room to room the connection automatically hops from one AP to the next as the client moves within the coverage area.

"Figure 14-2" shows a typical AP intended for home or small-business use. This AP, a D-Link DWL-2100AP model, uses the ubiquitous low-gain, omnidirectional "rubber duck" antenna used by most wireless devices. The mounts used for these antennae allow the antennae to be oriented in all three dimensions to maximize signal strength and optimize coverage area. Some APs use permanently affixed antennae. Others, including this model, provide a socket for an external antenna. Various external antennae are available, including models suitable for outdoor mounting, models that provide higher gain than standard rubber duck antennae, and models that are highly directional.



Figure 14-2: The D-Link DWL-2100AP, a typical AP

1.2) Wireless adapters:

Clients connect to the wireless network using wireless adapters, which are functionally analogous to the standard Ethernet adapters used in a wired network. Wireless adapters are available in various interfaces, including PCI (for desktop systems), "CardBus" (for notebooks), "PCMCIA (People Can't Memorize Computer Industry Acronyms)" card adapters (for older notebooks and handheld devices), and USB (for any system). Like APs, PCI and USB wireless adapters are normally supplied with a low-gain, omnidirectional rubber-duck antenna that can usually be replaced with an external high-gain or unidirectional antenna. "Figure 14-3" shows a D-Link AirPlus XtremeG DWL-G520, which is a typical PCI wireless adapter. CardBus wireless adapters, like the D-Link DWL-G650 shown in "Figure 14-4", have an internal, low-gain, omnidirectional antenna, and make no provision for using an external antenna. However, certain models of CardBus (or PCMCIA) adapters, such as some Proxim Orinoco cards, include an external antenna port.



Figure 14-3: The D-Link DWL-G520, a typical PCI wireless adapter



Figure 14-4: The D-Link DWL-G650, a typical CardBus wireless card

""Wireless Component Interoperability"":

APs and wireless adapters support one or more 802.11 standards, and may also support proprietary protocols. Standards-based APs and wireless adapters from different companies generally interoperate well, with minor exceptions. You can, for example, usually connect to a D-Link AP with a NETGEAR or wireless adapter or vice versa, assuming that both products are designed for the same standard or standards. Some APs and wireless adapters are single-standard (i.e., 802.11g or 802.11a), and other APs and wireless clients support multiple standards (e.g., 802.11a/b/g).

Some wireless vendors particularly those who focus on businesses anticipate the standards-making process by adding proprietary features that have not yet been ratified as a standard (and may never be ratified). Such enhanced products are attractive to businesses for their added features and are usually able to interoperate with standards-based products, but generally only at a least-common-denominator level. For example, Belkin jumped the gun on the emerging 802.11n standard by introducing so-called "Pre-N" APs and wireless adapters. These Pre-N products which may or may not end up being compatible with the 802.11n standard when

it is finalized provide higher speed and longer range when they are used together, but when they are used with 802.11g or earlier components, they function as standard components.

In general, we recommend avoiding whenever possible wireless components that depend on proprietary extensions to provide the required level of functionality. Current standards-based wireless components provide adequate security and manageability for any home or small business environment.

1.3) Transmitter power, receiver sensitivity, and antenna considerations:

The range of a wireless connection depends on many factors, including its speed, amount of interference, obstructions in the signal path, and the types of antennae used. All other things being equal, though, the range of a connection is determined by how powerful the transmitter is and how sensitive the receiver. Different brands and models of wireless components may differ significantly in both respects.

==== Transmitter power =====

The transmitter power of wireless networking components is usually stated in "dBm", and may range from 0 dBm (defined as 1 milliwatt or mW) to 30 dBm (just over 1,000 mW). An increase or decrease of about 3 dBm corresponds to a doubling or halving of transmission power. For example, an output of 3 dBm corresponds to about 2 mW. An increase or decrease of 10 dBm corresponds to increasing or decreasing transmitter power by a factor of 10. For example, an output of 10 dBm is about 10 mW; 20 dBm about 100 mW; and 30 dBm about 1,000 mW. All other things being equal, increasing power output increases range and transmission speed.

Wireless devices may use fixed transmission power, set transmission power dynamically under firmware control, or allow transmission power to be set manually. The amount of transmission power needed varies with the distance between devices, the sensitivity of the receiver, the data rate of the link, the amount of obstruction in the signal path, and other factors. In general, longer distances between devices and higher data rates require more transmission power.

You might think the best idea would be for all devices to use maximum transmission power all the time, but high power is not always desirable. Using more power than needed does not improve the speed or quality of the wireless link; it simply introduces unnecessary RF into the environment, where it may interfere with other wireless devices that would otherwise be able to use the same channel without conflicts.

Accordingly, the firmware of some wireless devices is programmed to negotiate link characteristics with other wireless devices, including transmitter power, to establish an optimum connection at the minimum required power level. This negotiation can be done at very low data rates, so the initial contact between the devices can occur at low power. Each device tells the other about its own capabilities, including the fastest link speed it supports. The devices then increase their transmitter power to the minimum level needed to support the highest common data rate. If the maximum available transmitter power is insufficient to support their highest common data rate, they fall back to a lower data rate, using whatever power level is needed to support that lower data rate.

Other wireless devices allow transmission power to be set manually, usually within a range of a few mW up to perhaps 100 or 200 mW. Often, the output power is not stated numerically, but instead is named (Full, Half, Quarter, Eighth, and so on) or as a maximum output power with options to reduce output by a series of 3 dB steps, each of which halves output

power. Still other wireless devices make no provision for adjusting transmission power, instead using a fixed transmission power, usually 30 mW or so.

==== Receiver sensitivity ====

The flip side of transmitter power is receiver sensitivity. All other things being equal, a more sensitive receiver can sustain a connection with a weaker signal than a receiver with lower sensitivity. A sensitive receiver is as important as a powerful transmitter, because signal strength drops rapidly with increasing distance from the transmitter and because higher data rates require stronger signals.

If you are building a wireless network for which range is critical, particularly if your signal paths are obstructed, it's worth paying attention to the receiver sensitivity of components you are considering using. For example, the D-Link DWL-2100AP has excellent receiver sensitivity. A cheap, no-name component might have actual receiver sensitivity 10 dBm lower than the D-Link model (the documentation for the cheesy AP probably won't admit that, but we're talking real-world here). That means when the D-Link AP is at its maximum range to sustain a 54 Mb/s link, the cheap AP might sustain only a 24 or 36 Mb/s link. Worse still, if the D-Link AP is at its maximum range to support a 36 Mb/s link, the cheap AP might sustain only a 6 or 9 Mb/s link.

==== Antenna considerations ====

Most mainstream wireless components are supplied with a standard "rubber duck" antenna, which is usually described as omnidirectional. That's true in a sense, but the standard antenna radiates omnidirectionally primarily in one plane. For example, with the antenna oriented vertically (at 90°, relative to the horizontal plane), as shown in "Figure 14-5", the radiation pattern resembles a doughnut extending horizontally outward in all directions. If this AP were installed on one floor of a home, for example, its coverage area might include all rooms on that same floor, but rooms on floors above and below its location would receive a weak signal.



Figure 14-5: Antenna oriented vertically to maximize horizontal coverage

Because antenna orientation has a major effect on coverage area, most antenna mounts permit the antenna to be rotated in all dimensions. For example, "Figure 14-6" shows the antenna in the same vertical plane as the preceding image, but oriented at 45°, relative to the horizontal plane. With the antenna oriented this way, the AP provides a smaller coverage area on the floor where it is located, with added coverage on that portion of the floor above located to the right of the AP and added coverage on that portion of the floor below located to the left of the AP.



Figure 14-6: Antenna tilted to provide additional vertical coverage at the expense of horizontal coverage

Similarly, "Figure 14-7" shows the antenna tilted at 45° in both the horizontal and vertical planes relative to the first image. With the antenna oriented this way, the AP provides some horizontal coverage on the floor where it is located, with added coverage on that portion of the floor above located to the right front of the AP and added coverage on that portion of the floor below located to the left rear of the AP.



Figure 14-7: Antenna tilted to provide additional front-to-rear vertical coverage at the expense of horizontal and vertical right-to-left coverage

AP antenna orientation has a major impact on coverage area. Changing antenna orientation by even a few degrees can make major differences in signal strength throughout the coverage area, benefiting some areas at the expense of others. Also, obstructions are not necessarily equally obstructive at different antenna orientations. When you install a wireless network, don't simply orient the AP antenna vertically and hope for the best. Spend some time playing around with antenna orientation to see how it affects signal strength throughout your coverage area. Use a notebook with a wireless adapter and run the site-survey software provided with the wireless adapter, or a package such as Network Stumbler (<http://www.stumbler.net>), to optimize the coverage area.

: Wireless Networks

This lesson presents an overview of wireless-network technology. You are introduced to the characteristics of the various wireless environments as well as the major wireless transmission and reception components.

After this lesson, you will be able to:

- Identify the three types of wireless networks and the uses of each.
- Describe the four transmission techniques used in local area networking.
- Describe the three types of signal transmission used in mobile computing.

The Wireless Environment:

The wireless environment is an often appropriate, and sometimes necessary, networking option. Today, manufacturers are offering more products at attractive prices that, in turn, will mean increased sales and demand in the future. As demand increases, the wireless environment will grow and improve.

The phrase "wireless environment" is misleading because it implies a network completely free of cabling. In most cases, this is not true. Most wireless networks actually consist of wireless components communicating with a network that uses the cabling discussed earlier in this chapter in a mixed-component network called a *hybrid network*.

Wireless Network Capabilities:

Wireless networks are attracting attention because wireless components can:

- Provide temporary connections to an existing, cabled network.
- Help provide backup to an existing network.
- Provide some degree of portability.
- Extend networks beyond the limits of physical connectivity.

Uses for Wireless-Network Connectivity:

The inherent difficulty of setting up cable networks is a factor that will continue to push wireless environments toward greater acceptance. Wireless connectivity can be especially useful for networking:

- Busy locations, such as lobbies and reception areas.
- Users who are constantly on the move, such as doctors and nurses in hospitals.
- Isolated areas and buildings.
- Departments in which the physical setting changes frequently and unpredictably.
- Structures, such as historic buildings, for which cabling presents challenges.

Types of Wireless Networks:

Wireless networks can be divided into three categories based on their technology:

- LANs
- Extended LANs
- Mobile computing

The primary difference between these categories lies in the transmission facilities. Wireless LANs and extended LANs use transmitters and receivers owned by the company in which the network operates. Mobile computing uses public carriers, such as long distance telephone companies, along with local telephone companies and their public services, to transmit and receive signals.

LANs:

Except for the media used, a typical wireless network operates almost like a cabled network: a wireless network interface card with a transceiver is installed in each computer, and users communicate with the network just as if they were using cabled computers.

Access Points:

The transceiver, sometimes called an access point, broadcasts and receives signals to and from the surrounding computers and passes data back and forth between the wireless computers and the cabled network.

These wireless LANs use small wall-mounted transceivers to connect to the wired network. Figure 2.32 shows a wireless connection between a laptop computer and a LAN. The transceivers establish radio contact with portable networked devices. Note that this is not a true wireless LAN, because it uses a wall-mounted transceiver to connect to a standard, cabled LAN.

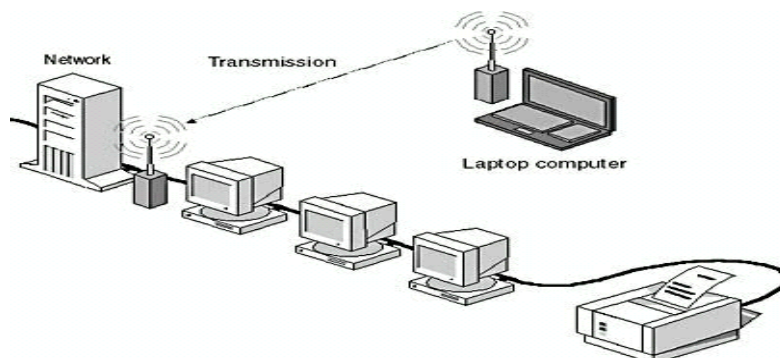


Figure 2.32 *Wireless portable computer connecting to a cabled network access point*

Transmission Techniques:

Wireless LANs use four techniques for transmitting data:

- Infrared transmission
- Laser transmission
- Narrowband (single-frequency) radio transmission
- Spread-spectrum radio transmission

Infrared Transmission: All infrared wireless networks operate by using an infrared light beam to carry the data between devices. These systems need to generate very strong signals because weak transmission signals are susceptible to interference from light sources such as windows. Many of the high-end printers sold today are preconfigured to accept infrared signals. Figure 2.33 shows a laptop computer using an infrared light beam to send data to a printer.

This method can transmit signals at high rates because of infrared light's high bandwidth. An infrared network can normally broadcast at 10 Mbps.

There are four types of infrared networks:

- **Line-of-sight networks:** As the name implies, this version of infrared networking transmits only if the transmitter and receiver have a clear line of sight between them.
- **Scatter infrared networks:** In this technology, broadcast transmissions are bounced off walls and ceilings and eventually hit the receiver. They are effective within an area limited to about 30.5 meters (100 feet).
- **Reflective networks:** Optical transceivers situated near the computers transmit to a common location that redirects the transmissions to the appropriate computer.
- **Broadband optical telepoint:** This infrared wireless LAN provides broadband services and is capable of handling high-quality multimedia requirements that can match those provided by a cabled network.

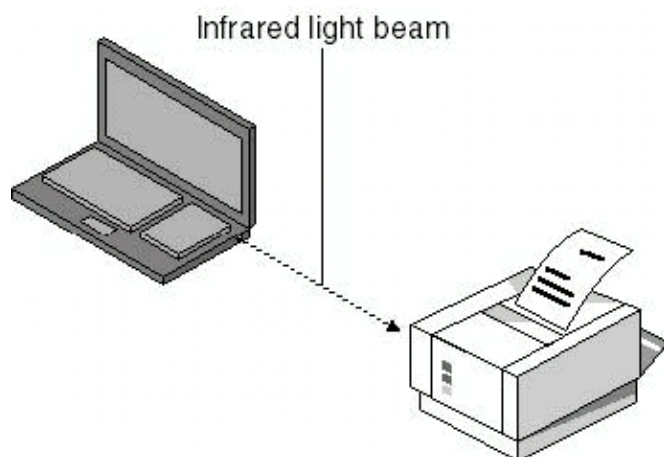


Figure 2.33 *Wireless portable computer using an infrared light beam to send data to a printer*

While its speed and convenience are generating interest, infrared has difficulty transmitting for distances greater than 30.5 meters (100 feet). It is also subject to interference from the strong ambient light found in most business environments.

Laser Transmission: Laser technology is similar to infrared technology in that it requires a direct line of sight, and any person or thing that breaks the laser beam will block the transmission.

Narrowband (Single-Frequency) Radio Transmission: This approach is similar to broadcasting from a radio station. The user tunes both the transmitter and the receiver to a certain frequency. This does not require line-of-sight focusing because the broadcast range is 3000 meters (9842 feet). However, because the signal is high frequency, it is subject to attenuation from steel and load-bearing walls.

Narrowband radio is a subscription service. The service provider handles all the Federal Communications Commission (FCC) licensing requirements. This method is relatively slow; transmission is in the 4.8 Mbps range.

Spread-Spectrum Radio Transmission: Spread-spectrum radio broadcasts signals over a range of frequencies. This helps it avoid narrowband communication problems.

The available frequencies are divided into channels, known as *hops*, which are comparable to one leg of a journey that includes intervening stops between the starting point and the destination. The spread-spectrum adapters tune in to a specific hop for a predetermined length of time, after which they switch to a different hop. A hopping sequence determines the timing. The computers in the network are all synchronized to the hop timing. This type of signaling provides some built-in security in that the frequency-hopping algorithm of the network would have to be known in order to tap into the data stream.

To further enhance security and to keep unauthorized users from listening in to the broadcast, the sender and the receiver can encrypt the transmission.

Spread-spectrum radio technology provides for a truly wireless network. For example, two or more computers equipped with spread-spectrum network adapters and an operating system with built-in networking capability can act as a peer-to-peer network with no connecting cables. In addition, such a wireless network can be tied into an existing network by adding an appropriate interface to one of the computers on that network.

Although some implementations of spread-spectrum radio can offer transmission speeds of 4 Mbps over distances of about 3.22 kilometers (two miles) outdoors and 244 meters (800 feet) indoors, the typical speed of 250 Kbps (kilobits per second) makes this method much slower than the other wireless networking options discussed.

Point-to-Point Transmission:

The *point-to-point* method of data communication does not fall neatly into the present definitions of networking. It uses a point-to-point technology that transfers data from one computer to another instead of communicating among several computers and peripherals. However, additional components such as single and host transceivers are available. These can be implemented in either stand-alone computers or computers already on a network to form a wireless data-transfer network.

This technology involves wireless serial data transfer that:

- Uses a point-to-point radio link for fast, error-free data transmission.
- Penetrates through walls, ceilings, and floors.
- Supports data rates from 1.2 to 38.4 Kbps up to 61 meters (200 feet) indoors or about 0.5 kilometers (0.30 miles) with line-of-sight transmission.

This type of system transfers data between computers, or between computers and other devices such as printers or bar-code readers.

Extended LANs:

Other types of wireless components are able to function in the extended LAN environment similarly to their cabled counterparts. A wireless LAN bridge, for example, can connect networks up to 4.8 kilometers (three miles) apart.

Multipoint Wireless Connectivity:

A *wireless bridge* is a component that offers an easy way to link buildings without using cable. In the same way that a footbridge provides a path between two points, a wireless bridge provides a data path between two buildings. Figure 2.34 shows a wireless bridge connecting two LANs. The AIRLAN/Bridge Plus, for example, uses spread-spectrum radio technology to create a wireless backbone to tie locations together over distances beyond the reach of LANs. With variations that depend on atmospheric and geographic conditions, this distance can be up to 4.8 kilometers (three miles).

Though costly, such a component might be justified because it eliminates the expense of leased lines.

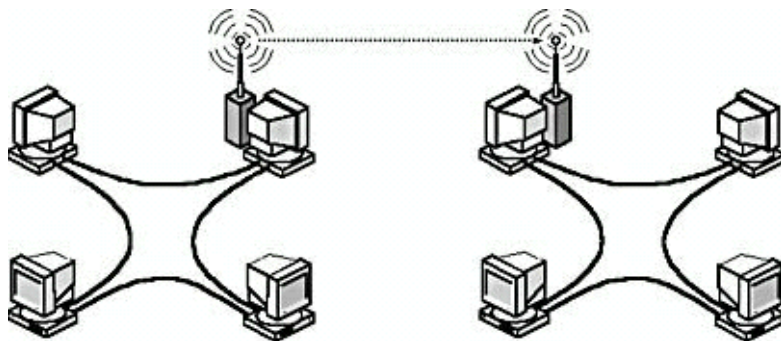


Figure 2.34 *Wireless bridge connecting two LANs*

The Long-Range Wireless Bridge:

If the wireless bridge will not reach far enough, another alternative to consider is a long-range wireless bridge. These also use spread-spectrum radio technology to provide both Ethernet and Token Ring bridging, but for a distance of up to 40 kilometers (about 25 miles).

As with the original wireless bridge, the cost of the long-range bridge might be justified because it eliminates the need for T1 line or microwave connections.

NOTE:

A *T1 line* is a high-speed communications line that can handle digital communications and Internet access at the rate of 1.544 Mbps.

Mobile Computing:

Wireless mobile networks use telephone carriers and public services to transmit and receive signals using:

- Packet-radio communication.
- Cellular networks.
- Satellite stations.

Traveling employees can use this technology with portable computers or personal digital assistants (PDAs) to exchange e-mail messages, files, or other information.

While this form of communication offers convenience, it is slow. Transmission rates range from 8 Kbps to 19.2 Kbps. The rates slow further when error correction is included.

Mobile computing incorporates wireless adapters that use cellular-telephone technology to connect portable computers with the cabled network. Portable computers use small antennas to communicate with radio towers in the surrounding area. Satellites in near-earth orbit pick up low-powered signals from portable and mobile networked devices.

Packet-Radio Communication;

This system breaks a transmission into packets.

NOTE:

A *packet* is a unit of information transmitted as a whole from one device to another on a network.

These radio packets are similar to other network packets. They include:

- The source address.
- The destination address.
- Error-correction information.

The packets are linked up to a satellite that broadcasts them. Only devices with the correct address can receive the broadcast packets.

Cellular Networks:

Cellular Digital Packet Data (CDPD) uses the same technology and some of the same systems that cellular telephones use. It offers computer data transmissions over existing analog voice networks between voice calls when the system is not busy. This is very fast technology that suffers only subsecond delays, making it reliable enough for real-time transmission.

As in other wireless networks, there must be a way to tie the cellular network in to the existing cabled network. An Ethernet interface unit (EIU) can provide this connection.

Satellite Stations:

Microwave systems are a good choice for interconnecting buildings in small, short-distance systems such as those on a campus or in an industrial park.

Microwave transmission is currently the most widely used long-distance transmission method in the United States. It is excellent for communicating between two line-of-sight points such as:

- Satellite-to-ground links.

- Between two buildings.
- Across large, flat, open areas, such as bodies of water or deserts.

A microwave system consists of the following:

- Two radio transceivers: one to generate (transmitting station) and one to receive (receiving station) the broadcast.
- Two directional antennas pointed at each other to implement communication of the signals broadcast by the transceivers. These antennas are often installed on towers to give them more range and to raise them above anything that might block their signals.

Lesson Summary:

The following points summarize the main elements of this lesson:

- The wireless environment is an often appropriate, and sometimes necessary, networking option.
- Computers operating on a wireless network function like their wire-bound counterparts, except that the network interface card is connected to a transceiver instead of a cable.
- A wireless segment can be either point-to-point (separated by short distances or in view of each other) or long-range.
- Wireless networks use infrared, laser, narrowband radio, or spread-spectrum radio signals for transmitting data.
- A wireless bridge can connect buildings that are situated as much as 40 kilometers (about 25 miles) apart.
- Cellular communication, satellite stations, and packet-radio communications are adding mobility to networks.

Security Issues in Wireless Networks

Threats in MAC Layer:

Denial of Service

- Can hog the medium by sending noise continuously.
- Can be done without draining the power of the adversary.
- Depends on physical carrier sensing threshold.

Ad hoc networks

- Network layer
 - Denial-of-service attacks
 - Broadcast nature of communication
 - Packet dropping
 - Route discovery failure in ad hoc network
 - Packet rerouting

Some Open Problems:

- Problem 1: Secure Admission Control
 - For fixed infrastructure networks, how to decide admitting a new node into the network?
 - EAP-TLS, EAP-TTLS are expensive in terms of computation and do not work well in ad hoc mode
 - Access points should be able to handle more decisions to enable easy roaming
 - Need for a scalable but practical solution for admission control especially for roaming accessibility
 - If key management is used dynamics and storage become issues
- Problem 2 : Application Layer Security for fixed infrastructure networks
 - Equivalent notions of wired networks.
 - Require Light-weight sand boxing mechanisms
 - Privacy-preserving light-weight content filtering techniques
 - Existing solutions: J2ME KVM, DownloadFun, QualComm BREW
- Problem 3: Real-time Cell Communication Security
 - Key management solutions may not work due to real-time voice data
 - Hacking/tapping cell phones is possible depending on the encoding scheme used

Conclusions Of topics :

- Situations are more complex in wireless networks, even with infrastructural support.
- Threats exist at various layers of operation.
- Present solutions to address these threats are not scalable or not strong enough.
- Simple key management solutions can help.
 - But not always.

- Still, lots of interesting and open issues to be solved.

Making Networks Secure:

Planning for Network Security:

In a networking environment there must be assurance that sensitive data will remain private. Not only is it important to secure sensitive information, it is equally important to protect network operations from deliberate or unintentional damage.

Maintaining network security requires a balance between facilitating easy access to data by authorized users and restricting access to data by unauthorized users. It's the job of the network administrator to create this balance.

Even in networks that handle sensitive and valuable business data, security is sometimes an afterthought. Four major threats to the security of data on a network are:

- Unauthorized access.
- Electronic tampering.
- Theft.
- Intentional or unintentional damage.

Despite the seriousness of these threats, data security is not always implemented or supported properly. The administrator's task is to ensure that the network remains reliable and secure, free from those threats.

Level of Security:

The extent and level of the network security system required depends on the type of environment in which the network is running. A network that stores data for a major bank, for example, requires more extensive security than a LAN that links the computers in a small community volunteer organization.

Setting Policies:

Making a network secure requires establishing a set of rules, regulations, and policies so that nothing is left to chance. The first step toward ensuring data security is to implement policies that set the tone and help to guide the administrator and users through changes, both expected and unplanned, in their network's development.

Prevention:

The best way to design data security policies is to take a proactive, preventive approach. When unauthorized access is prevented, the data remains secure. A prevention-based system requires that the administrator understand the tools and methods available with which to keep data safe.

Authentication:

To access a network, a user must enter a valid user name and password. Because passwords are linked to user accounts, a password authentication system is the first line of defense against unauthorized users.

It is important not to let overreliance on this authentication process fool you into a false sense of security. For example, in a peer-to-peer network, almost anyone can log on with a unique name and password. This alone can provide a user with complete access to the network, so that anything that is shared becomes available to that user. Authentication works only in a server-based network in which the user name and password must be authenticated from the security database.

Training:

Unintentional errors can lead to security failures. A well-trained network user is less likely than an inexperienced novice to accidentally cause an error and ruin a resource by permanently corrupting or deleting data. Figure 10.1 illustrates such a problem.

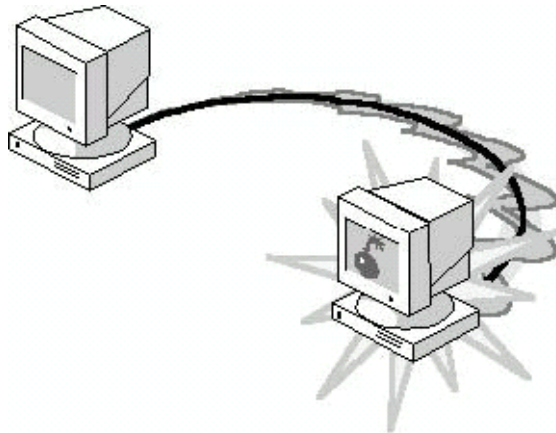


Figure 10.1 Training helps reduce costly user errors

The administrator should ensure that everyone who uses the network is familiar with its operating and security procedures. To accomplish this, the administrator can develop a short, clear guide to what users need to know, and require that new users attend appropriate training classes.

Securing Equipment:

The first step in keeping data safe is to provide for the physical security of the network hardware. (Establishing and maintaining an optimal environment for the physical network is discussed in detail in Lesson 2.) The extent of security required depends on:

- The size of the company.
- The sensitivity of the data.
- The available resources.

In a peer-to-peer network, there is sometimes no organized hardware-security policy, and users are responsible for the security of their own computers and data. In a server-based network, security is the responsibility of the network administrator.

Securing the Servers:

In a larger, centralized system, in which much individual user and organization data is sensitive, it is important to secure the servers from accidental or deliberate tampering.

It is not uncommon for some individuals to want to demonstrate their technical abilities when the servers have problems. They may or may not know what they are doing. It is best to tactfully prevent these people from "fixing" the server. The simplest solution is to lock the

servers in a dedicated computer room with limited access; depending on the size of the company, this might not be workable. Locking the servers in an office or even a large storage closet is often practicable and goes some way toward securing the servers.

Securing the Cables:

Copper media, such as coaxial cable, much like a radio emits electronic signals that mimic the information it carries. Information carried in these signals can be monitored with electronic listening equipment. Copper cable can also be tapped into so that information can be stolen directly from the original cable.

Cable runs that handle sensitive data should be accessible only to authorized people. Proper planning can make cable runs inaccessible to unauthorized people. For example, cable can be run inside the building structure, through ceilings, walls, and floors.

Security Models:

After implementing security for the network's physical components, the administrator needs to ensure that the network resources will be safe from both unauthorized access and accidental or deliberate damage. Policies for assigning permissions and rights to network resources are at the heart of securing the network.

Two security models have evolved for keeping data and hardware resources safe:

- Password-protected shares
- Access permissions

These models are also called "share-level security" (for password-protected shares) and "user-level security" (for access permissions).

Password-Protected Shares:

Implementing password-protected shares requires assigning a password to each shared resource. Access to the shared resource is granted when a user enters the correct password.

In many systems, resources can be shared with different types of permissions. To illustrate, we use Windows 95 and 98 as examples. For these operating systems, as described in "Establishing Network Shares and Accounts," directories can be shared as Read Only, Full, or Depends On Password.

- **Read Only** If a share is set up as Read Only, users who know the password have Read access to the files in that directory. They can view the documents, copy them to their machines, and print them, but they cannot change the original documents.
- **Full** With Full access, users who know the password have complete access to the files in that directory. In other words, they can view, modify, add, and delete the shared directory's files.
- **Depends On Password** Depends On Password involves setting up a share that uses two levels of passwords: Read access and Full access. Users who know the Read access password have Read access, and users who know the Full access password have Full access.

The password-protected share system is a simple security method that allows anyone who knows the password to obtain access to that particular resource.

Access Permissions:

Access-permission security involves assigning certain rights on a user-by-user basis. A user types a password when logging on to the network. The server validates this user name and password combination and uses it to grant or deny access to shared resources by checking access to the resource against a user- access database on the server.

Access-permission security provides a higher level of control over access rights. It is much easier for one person to give another person a printer password, as in share-level security. It is less likely for that person to give away a personal password.

Because user-level security is more extensive and can determine various levels of security, it is usually the preferred model in larger organizations.

Resource Security:

After the user has been authenticated and allowed on the network, the security system gives the user access to the appropriate resources.

Users have passwords, but resources have permissions. In a sense, a security fence guards each resource. The fence has several gates through which users can pass to access the resource. Certain gates allow users to do more to the resource than other gates. Certain gates, in other words, allow the user more privileges with the resource.

The administrator determines which users should be allowed through which gates. One gate grants the user full access to or full control of a resource. Another gate grants the user read-only access.

As shown in Figure 10.2, each shared resource or file is stored with a list of users or groups and their associated permissions (gates).

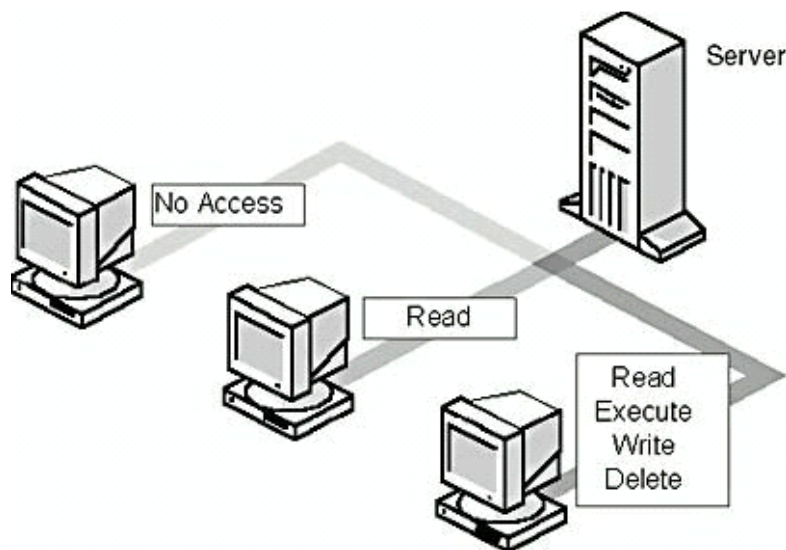


Figure 10.2 Permissions control the type of access to a resource

Security Enhancements:

The network administrator can increase the level of security on a network in several ways. This section explores some of the options.

Firewalls:

A *firewall* is a security system, usually a combination of hardware and software, that is intended to protect an organization's network against external threats coming from another network, including the Internet.

Firewalls prevent an organization's networked computers from communicating directly with computers that are external to the network, and vice versa. Instead, all incoming and outgoing communication is routed through a proxy server outside the organization's network. Firewalls also audit network activity, recording the volume of traffic and providing information about unauthorized attempts to gain access.

A proxy server is a firewall component that manages Internet traffic to and from a local area network (LAN). The proxy server decides whether it is safe to let a particular message or file pass through to the organization's network. It provides access control to the network, filtering and discarding requests that the owner does not consider appropriate, including requests for unauthorized access to proprietary data.

Auditing:

Reviewing records of events in the security log of a server is called *auditing*. This process tracks network activities by user accounts. Auditing should be a routine element of network security. Audit records list the users that have accessed—or attempted to access—specific resources. Auditing helps administrators identify unauthorized activity. It can also provide usage information for departments that charge a fee for making certain network resources available and need some way to determine the cost of those resources.

Auditing can track functions such as:

- Logon attempts.
- Connection and disconnection from designated resources.
- Connection termination.
- Disabling of accounts.
- Opening and closing of files.
- Changes made to files.
- Creation or deletion of directories.
- Directory modification.
- Server events and modifications.
- Password changes.
- Logon parameter changes.

Audit records can indicate how the network is being used. The administrator can use the audit records to produce reports that show activities and their date and time ranges. For example, repeated failed logon attempts or efforts to log on at odd hours can indicate that an unauthorized user is attempting to gain access to the network.

Diskless Computers:

Diskless computers, as the name implies, have no floppy-disk drives or hard disks. They can do everything a computer with disk drives can do except store data on a local floppy disk or hard disk. Diskless computers are an ideal choice for maintaining security because users cannot download data and take it away.

Diskless computers do not require boot disks. They communicate with the server and log on by means of a special ROM boot chip installed on the computer's network interface card (NIC). When the diskless computer is turned on, the ROM boot chip signals the server that it is ready to start. The server responds by downloading boot software into the diskless computer's RAM and automatically presents the user with a logon screen as part of the boot process. After the user logs on, the computer is connected to the network.

Although a diskless computer can provide a high level of security, it has shortcomings. Without a local disk available on which to store applications and data, all computer activity must be conducted over the network. Network traffic will increase accordingly, and the network will have to be capable of handling increased demands.

Data Encryption:

A data-encryption utility scrambles data before it goes onto the network. This makes the data unreadable even by someone who taps the cable and attempts to read the data as it passes over the network. When the data arrives at the proper computer, the code for deciphering encrypted data decodes the bits, translating them into understandable information. Advanced data-encryption schemes automate both encryption and decryption. The best encryption systems are hardware-based and can be expensive.

The traditional standard for encryption is the Data Encryption Standard (DES). Developed by IBM and adopted in 1975 as a specification for encryption by the government of the United States, this system describes how data should be encrypted and provides the specifications for the key to decryption. The U.S. Government continues to use DES. Both the sender and the receiver need to have access to the decryption key. However, the only way to get the key from one location to another is to physically or electronically transmit it, which makes DES vulnerable to unauthorized interception.

Today, the U. S. Government is also using a newer standard, called the Commercial COMSEC Endorsement Program (CCEP), which may eventually replace DES. The National Security Agency (NSA) introduced CCEP and allows vendors with the proper security clearance to join CCEP. Approved vendors are authorized to incorporate classified algorithms into communications systems.

Computer Viruses:

Computer viruses are becoming an all-too-familiar fact of life. It is not uncommon to see a report on a local news channel describing the latest virus and warning about its destructive impact. Computer viruses are bits of computer programming, or code, that hide in computer programs or on the boot sector of storage devices, such as hard-disk drives and floppy-disk drives. The primary purpose of a virus is to reproduce itself as often as possible and thereby disrupt the operation of the infected computer or the program. Once activated, a virus can be a simple annoyance or completely catastrophic in its effect. Viruses are written by people with an intent to do harm.

Viruses are classified into two categories, based on how they propagate themselves. The first type, called a "boot-sector virus," resides in the first sector of a floppy-disk or hard-disk drive. When the computer is booted, the virus executes. This is a common method of transmitting viruses from one floppy disk to another. Each time a new disk is inserted and accessed, the virus replicates itself onto the new drive. The second type of virus is known as a "file infector." Such a virus attaches itself to a file or program and activates any time the file is used. Many subcategories of file infectors exist.

The following list describes a few of the more common file infectors:

- **Companion Virus:** A companion virus is so named because it uses the name of a real program—its companion. A companion virus activates by using a different file extension from its companion. For example, suppose we decide to start a program called "wordprocessor.exe." When the command is given to execute the application, a virus named "wordprocessor.com" will execute in its place. It is able to do so because a .com file takes priority over an .exe file.
- **Macro Virus:** A macro virus is difficult to detect and is becoming more common. It is so named because it is written as a macro for a specific application. Popular applications, such as Microsoft Word, are targets for these viruses. When the user opens a file that contains the virus, the virus attaches itself to the application and then infects any other files accessed by that application.
- **Polymorphic Virus:** A polymorphic virus is so named because it changes its appearance every time it is replicated. This renders it more difficult to detect because no two are exactly the same.
- **Stealth Virus:** A stealth virus is so named because it attempts to hide from detection. When an antivirus program attempts to find it, the stealth virus tries to intercept the probe and return false information indicating that it does not exist.

Virus Propagation:

Just as computer viruses do not create themselves, neither do they spread through the air unaided. Some kind of exchange between the two computers must take place before transmission can occur. In the early days of computing and viruses, the principal source of infection was through the exchange of data on floppy disks. One infected computer in an organization could easily infect all the computers in the organization, merely by a single user passing around a copy of the latest screensaver program.

The proliferation of LANs and the growth of the Internet have opened many new pathways to rapidly spreading viruses. Now, virtually any computer in the world can be connected to any other computer in the world. As a consequence, the creation of viruses is also on the rise. In fact, some virus creators provide easy-to-use software containing directions for how to create a virus.

A recently emerging method of spreading a virus is through e-mail services. After an e-mail message containing the virus is opened, it attaches itself to the computer and can even send itself to names in the computer's e-mail address book. Usually, the virus is located in an inviting attachment to an e-mail message.

Convincing unsuspecting victims to activate a virus is a goal for virus writers. This is often accomplished by packaging the virus in an enticing cover. Such a virus is known as a

"Trojan horse." To attract users, it is presented in the guise of something familiar, safe, or intriguing.

Remember that any means by which computers exchange information provides a potential path for a virus. Methods in common use include:

- CD-ROMs.
- Cabling directly connecting two computers.
- Floppy-disk drives.
- Hard-disk drives.
- Internet connections.
- LAN connections.
- Modem connections.
- Portable or removable drives.
- Tape.

Consequences of a Virus:

A virus can cause many kinds of harm to a computer; the creativity of its creator is the only limitation. The following list describes common symptoms of computer virus infection:

- The computer won't boot.
- The data is scrambled or corrupted.
- The computer operates erratically.
- A partition is lost.
- The hard drive is reformatted.

The most common symptom of virus infection in a network is one or more misbehaving workstations. A peer-to-peer network is the most vulnerable. A peer-to-peer network all things are shared equally; therefore, any infected computer has direct access to any computer or resource that is shared to the network. Server-based networks have some built-in protection because permission is required to obtain access to some portions of the server and, therefore, the network. In these networks, it is more likely that workstations will be infected than a server, although servers are not immune. The server, as the conduit from one computer to another, participates in the transmission of the virus, even though it might not be affected.

Virus Prevention:

Disastrous viruses are becoming more commonplace and should be taken into account when network security procedures are developed. An effective antivirus strategy is an essential part of a network plan. Good antivirus software is essential. Although no virus protection software can prevent all viruses, it can do some of the following:

- Warn of a potential virus
 - Keep a virus from activating
 - Remove a virus
 - Repair some of the damage that a virus has caused
 - Keep a virus in check after it activates
- ***

MULTIPLE CHOICE QUESTIONS

Q.1) A computer communication technology that provides a way to interconnect multiple computers across short distance is _____

- (A) LAN (B) MAN (C) WAN (D) Wireless networks

Ans.: (A) LAN

Q.2) A device that forwards data packet from one network to another is called a _____

- (A) Bridge (B) Switch (C) Hub (D) Gateway

Ans.: (B) Switch

Q.3) Which of the following is the fastest media of data transfer _____

- (A) Co-axial Cable (B) Untwisted Wire (C) Telephone Lines (D) Fibre Optic

Ans.: (D) Fiber Optic

Q. 4) What is wireless networking?

- (A) Technology that enables two or more computers to communicate using standard network protocols, but without network cabling
(B) Technology with wired
(C) Both (A) and (B)
(D) None of the above

Ans.: (A) Technology that enables two or more computers to communicate using standard network protocols, but without network cabling.

Q. 5) Can I have more than one access point?

- (A) Yes (B) No

Ans.: (A) Yes

Q. 6) ICMP stands for _____

- (A) Internet control mail protocol
(B) Internet controlling mark protocol
(C) Internet control master protocol
(D) Internet control message protocol

Ans.: (D) Internet control message protocol

Q. 7) Clients connect to the wireless network using _____

- (A) wireless adapters (B) Untwisted Wire (C) Telephone Lines (D) Fibre Optic

Ans.: (A) wireless adapters

Q.8) The transmitter power of wireless networking components is usually stated _____

- (A) in KBP (B) IN DB (C) in Mw (D) in “dBm”

Ans.: (D) in ‘dBm’

Q. 9) The flip side of transmitter power is _____

- (A) Sensitivity (B) Senders signal (C) receiver sensitivity (D) Transister

Ans.: (C) receiver sensitivity

Q. 10) Most mainstream wireless components are supplied with a standard _____

- (A) Duck (B) "rubber duck" antenna (C) Receiver (D) Transister

Ans.: (B) "rubber duck" antenna

Q.11) LAN stands for _____

- (A) Local Area Network (B) Local Area Net (C) Local Areal Net (D) Local Area Neuron

Ans.: (A) Local Area Network

Q.12) Wireless networks are attracting attention because wireless components can _____

- (A) Provide temporary connections to an existing, cabled network
(B) Help provide backup to an existing network (C) Provide some degree of portability.
(D) All of the above

Ans.: (D) All of the above

Q.13) A virus can cause many kinds of _____ to a computer.

- (A)Harm (B) Useful (C) Advantage (D) None of Above

Ans.: (A) Harm

Q.14) Four major threats to the security of data on a network are _____

- (A) Unauthorized access (B) Electronic-tampering. (C) Theft. (D)All of the above

Ans.: (D) All of the above

Q. 15) Wireless connectivity can be especially useful for networking _____

- (A) Busy locations, such as lobbies and reception areas (B) Isolated areas and buildings
(C)Both (A) & (B) (D) None of Above

Ans.: (C) Both (A) & (B)

Q.16) Wireless networks can be divided into _____ categories based on their technology.

- (A) Three (B) Two (C)one (D) Five

Ans.: (A) Three

Q.17) Wireless networks not contains _____

- (A) Wires (B) LAN (C)Extended LAN (D) Mobile

Ans.: (A) wires

Q.18) These radio packets are similar to other network packets. They include _____

- (A) The source address (B) The destination address (C) Error-correction information (D)
All of the Above

Ans.: (D) The destination address

Q.19. CDPD stands for _____

- (A) Cellular Digital Packet Data (B) Cellular Digital Packet Dag

(C) Cellular Digital Packet Dog (D) Cellular Digital Pac Data

Ans.: (A) Cellular Digital Packet Data

Q. 20. AP Stands for _____

(A) Access Point (B) Access Peer (C) Access Pain (D) None of the above

Ans.: (A) Access Point

END